

Toward Passwordless Document Encryption

Isaac Henry Teuscher

A thesis submitted to the faculty of
Brigham Young University
in partial fulfillment of the requirements for the degree of
Master of Science

Benjamin Schooley, Chair
Derek Hansen
Albert Tay

Department of Electrical and Computer Engineering
Brigham Young University

Copyright © 2026 Isaac Henry Teuscher

All Rights Reserved

Toward Passwordless Document Encryption

Isaac Henry Teuscher
Department of Electrical and Computer Engineering
Master of Science

BYU Engineering

Abstract

Document files with sensitive information are used across nearly every industry. In recent years, cyberattacks targeting cloud-based file transfer applications have resulted in millions of sensitive documents being exposed. Although document encryption methods exist, they are often limited in usability, security, or deployability. Password-based encryption, the most widely available option, remains vulnerable to brute-force attacks, unauthorized sharing, and human error.

We address these gaps in three phases. First, we present a structured comparative framework adapted from the usability-deployability-security model to evaluate nine document encryption methods across 15 design properties, identifying the benefits and limitations of current approaches. Second, we design and implement a novel document encryption system leveraging FIDO2 passkeys, the WebAuthn PRF extension, and open-source age encryption to provide end-to-end protection of digital documents without passwords. Third, we evaluate this system through a counterbalanced within-subjects user study ($N=21$) comparing the passwordless approach to traditional password-based encryption as provided by Adobe Acrobat®.

Mixed-methods results show the passwordless prototype achieved comparable usability to Adobe Acrobat on first use (SUS 72.0 vs. 73.3, $p = .944$) while being rated significantly more useful on the Van der Laan acceptance scale ($p = .014$). When asked which system they would prefer for sharing multiple documents, 19 of 21 participants chose the passwordless approach. Qualitative analysis revealed the password sharing burden was a major pain point with the traditional method, while trust in biometric authentication was a key driver of preference for the passwordless system.

To our knowledge, this is the first study to apply FIDO2 and WebAuthn PRF to end-to-end document encryption rather than user authentication, and one of the first human-subjects usability evaluations of the WebAuthn PRF extension in any context.

Keywords: document encryption, passwordless authentication, FIDO2, WebAuthn, passkeys, PRF extension, usable security

Acknowledgments

I would like to thank several people who supported me throughout the process of completing my thesis.

I'm grateful to Dr. Schooley, who was patient, supportive, and gave great direction throughout the process while letting me explore and dig into what interested me. Thank you for trusting me to see this through. I'm grateful for Dr. Hansen, Dr. Tay, and Audra McHoes for their help and faith in me. Thank you to Mary Hedengren for listening and helping me improve my writing. Thank you to Dr. Page for welcoming me into your lab and teaching me that academic research can be exciting and impactful. Thank you to Dr. Seamons for the great discussions on usable security which inspired me and gave direction for this research.

This work was supported by the CyberCorps®: Scholarship for Service (SFS) under NSF Grant #2336409. I'm also grateful for the support of BYU Graduate Studies and the BYU Electrical and Computer Engineering Department, which made it possible for me to publish and present my work.

Thank you to my BYU peers, friends, and coworkers at Paramify who checked in on me, volunteered to participate in the user study, and encouraged me to keep going. I'm especially grateful to Kenny Scott, Mike Cook, and the whole team at Paramify for letting me work flexible hours to finish my degree. Here's to never having another password-protected SSP!

Most of all, thank you to my family. To my parents, for encouraging me to "get as much education as you can" and for always believing I can do great things. And to my wife Anne, who loved, encouraged, and supported me through all the ups and downs. I love you!

Lastly, I'm thankful for the singular opportunity to study at BYU and seek learning by study and by faith. I will be forever grateful for what I've learned and who I've become.

Table of Contents

List of Figures vii

List of Tables viii

1	Introduction	1
1.1	Overview of Thesis	3
2	Background and Related Work	4
2.1	Threat Analysis	4
2.2	Document Encryption	8
2.3	The Quest to Replace Passwords	11
2.4	Open Source Encryption Tools	14
2.5	Passwordless Authentication and FIDO2	15
3	Methodology	26
4	Framework for Analysis	28
4.1	Usability-Deployability-Security Framework	28
4.2	Benefits	29
4.3	Groups	29
4.4	Evaluation and Analysis of Solutions	32
4.5	Summary of Analysis	34
5	System Design	36
5.1	Design Requirements	36
5.2	Technology Selection	37
5.3	System Architecture	39
5.4	System Implementation Walkthrough	43
5.5	Evaluation Against Requirements	54
6	User Study Methods	56
6.1	Hypothesis	56
6.2	Procedure	56
6.3	Participants	58
6.4	Instruments	60
6.5	Data Processing	62
7	User Study Results	63

7.1	Quantitative Results	63
7.2	Qualitative Results	69
8	Discussion and Conclusion	80
8.1	Discussion	80
8.2	Limitations	83
8.3	Future Research Directions	84
8.4	Conclusion	86
	References	88
	Appendices	96
A	Glossary of Terms	97
B	Study Recruitment Materials	100
B.1	Recruitment Flyer	100
B.2	Participant Instructions	100
C	Study Instruments	103
C.1	Qualtrics Screening Survey	103
C.2	In-Session Usability Study	107
C.3	Post-Session Interview Questions	111
D	Data and Analysis	112
D.1	Codebook	112
D.2	Per-Participant Scored Data	112
E	Supplementary System Diagrams	114
E.1	Basic Offline Architecture	115
E.2	Request Access Flow (as recipient)	116
E.3	Share Access Link (as sender)	117
E.4	Credential Creation Sequence Diagram	118
E.5	Adobe Acrobat Comparison Condition	119
F	System Artifact and Source Code	120
F.1	Code Base Repository	120
F.2	Working Website and Access Instructions	120

List of Figures

- 2.1 FIDO2 architecture. 17
- 2.2 WebAuthn PRF extension flow. 19
- 2.3 Access levels of passkey sharing. 25

- 5.1 Cloud/server-based architecture diagram. 41
- 5.2 File upload interface of the application. 44
- 5.3 Identity verification step with new passkey option. 45
- 5.4 Save passkey prompts during credential creation. 46
- 5.5 Use existing credential panel. 47
- 5.6 Add recipients step of the encryption workflow. 48
- 5.7 Share options after encryption. 49
- 5.8 Decryption identity step. 50
- 5.9 Settings panel with encryption algorithm selection. 51
- 5.10 Technical info panel. 52

- 6.1 Overview of the study procedure. 57
- 6.2 SUS score interpretation framework. 61

- 7.1 Distribution of system usability scale scores. 64
- 7.2 Distribution of Van der Laan usefulness and satisfaction scores. 66
- 7.3 Scatterplots of affinity for technology interaction scores against system usability scale scores. 68

- B.1 Recruitment Flyer for User Study. 101

- C.1 System usability scale instrument. 109
- C.2 Van der Laan acceptance scale instrument. 110

- E.1 Basic offline architecture diagram. 115
- E.2 Request access flow diagram. 116
- E.3 Share access link flow diagram. 117
- E.4 Credential creation sequence diagram. 118
- E.5 Adobe Acrobat online password-protection flow. 119

List of Tables

2.1	Actively exploited vulnerabilities in Managed File Transfer (MFT) systems (2020–2025).	5
2.2	Organizations with the most individuals impacted by the MOVEit incident.	6
2.3	Adversary threat mapping to design requirements and UDS framework benefits.	8
2.4	Security and usability differences between FIDO2 Passkey form factors.	21
4.1	Usability, Deployability, and Security Benefits.	30
4.2	Comparison of Document Encryption Methods by Usability, Deployability, and Security Benefits	31
5.1	Evaluation of Implemented System Against Design Requirements	53
6.1	Participant Demographics	59
7.1	Van der Laan Acceptance Scale Results	65
7.2	Spearman Correlations Between Control and Dependent Variables	67
7.3	Internal Consistency (Cronbach’s α)	69
7.4	Participant willingness to adopt the passwordless method for personal use.	71
B.1	Task Instructions by Condition	102
D.1	Per-Participant Scored Data	113

Introduction

Electronic documents with sensitive information are used across nearly every industry and profession. Examples include health records, legal counsel, financial data, trade secrets, and employment contracts. These sensitive documents are often stored and shared using cloud services like managed file transfer (MFT) applications because while security and data protection are of critical importance, the files must also be easily accessible and shareable in order to be useful. Users trust these platforms to keep their data secure. Documents remain an important means of digital transmission deserving robust cybersecurity protections.

However, in recent years, a series of hacking incidents targeting cloud-based file transfer applications compromised millions of confidential documents, including personal health data, government records, and legal files [1, 2]. The largest incident in 2023 resulted in the exposure of 95,788,491 individuals' personal information [3]. Worse, these incidents represent an ongoing pattern. Despite mass exploit events, the same attack pattern has continued unabated as it exposes a systematic design flaw with how many documents are protected today. From 2020 to 2025, more than eight vulnerabilities allowing remote privileged access to MFTs were discovered and abused, resulting in major data breaches (see Section 2.1.1 for further discussion) [2]. Although MFT applications encrypt files "at rest," all documents are unencrypted and readable by a privileged user session. Once an attacker gains access every document on the server can be exfiltrated. The current security model fails because it relies on perimeter defense rather than per-document protection. Perimeter defense follows a "verify once, trust forever" approach where an authenticated session can read every document on the server, while per-document protection aligns with zero trust principles, requiring access to be verified for each individual file. There is a pressing need to understand the limitations of existing document protection systems and develop novel systems to provide better security.

While much research and development has been performed to provide confidentiality for web traffic (HTTPS, TLS, etc.) and instant messaging (end-to-end encrypted Signal™, WhatsApp™, etc.), document-level encryption has received comparatively little attention. From a usability perspective, the state of document encryption is troublesome. Password-based encryption built into tools like Microsoft Word® and Adobe Acrobat® today works nearly the same as it did when introduced in

the 1990s [4]: set a password and hope you don't forget it. It has major usability issues such as the inability to recover or reset a forgotten password. Password-based file encryption is also vulnerable to brute-force attacks [5, 6] and unauthorized sharing. The result is that despite the availability of encryption features, many sensitive documents remain inadequately protected in practice. A successful document encryption system must provide adequate usability, security, and deployability; without all three, adoption will not follow.

Significant advances in passwordless authentication—notably FIDO2 and WebAuthn, developed by the FIDO Alliance and W3C—provide compelling components for a novel document encryption method that offers strong, modern protection without compromising usability. As of 2026, FIDO2 and WebAuthn have begun to cross the deployability and adoption barriers that have historically prevented password replacement mechanisms from gaining traction [7]. To date, FIDO2 and WebAuthn applications have focused primarily on user authentication (the average consumer's user login to a website). However, the potential benefits extend beyond user authentication. The WebAuthn PRF extension enables end-to-end encryption derived from a passkey. While the WebAuthn PRF extension has seen early use in password managers and cryptocurrency wallets, no prior work has applied FIDO2 and WebAuthn to perform document encryption where files must be shared between parties, nor has any academic study evaluated the feasibility, deployment, and usability of such an approach.

This research bridges that gap. We first conducted a systematic analysis of existing document protection methods using a structured comparative framework adapted from usable security research methods for evaluating password alternatives [8] and secure email [9]. We applied this framework to compare nine document protection methods across 15 design properties, identifying the benefits and limitations of current approaches. From this analysis, we derived design requirements for a system that is not password-based, not proprietary, does not require recipients to install software, and encrypts documents individually. We then designed and implemented a novel document encryption system leveraging FIDO2 passkeys, the WebAuthn PRF extension, and open-source age encryption to provide end-to-end protection of digital documents without passwords. Finally, we evaluated this system through a within-subjects user study ($N=21$) comparing the passwordless approach to traditional password-based encryption as provided by Adobe Acrobat, measuring usability and user acceptance with established instruments alongside qualitative interview data. Results show that the passwordless prototype achieved usability parity with Adobe Acrobat on first use (SUS 72.0 vs. 73.3, $p = .944$), while being rated significantly more useful by participants (VdL $p = .014$). When asked which method they would prefer for sharing multiple documents, 19 of 21 participants chose the passwordless approach, citing the password sharing burden and trust in biometric authentication as key factors.

This study is guided by the following research questions:

- R1:** What usability, deployability, and security limitations exist in current document encryption methods?
- R2:** How can open-source protocols be used to design a document protection system that is passwordless, non-proprietary, and provides per-file encryption?^a
- R3:** What is the user acceptance and usability of a passwordless document encryption system?

^a(1) *Passwordless* meaning: no password or memory aspect needed for the scheme to work. (2) *Non-proprietary* meaning: free, open-source and when files are shared, the receiver doesn't need custom software to view or interact with the file. (3) *Per-file encryption* meaning: individual document files are encrypted uniquely and not all accessible at once.

The main contributions of this work are as follows. First, to our knowledge this is the first study to apply FIDO2 and WebAuthn PRF to end-to-end document encryption rather than user authentication, and one of the first human-subjects usability evaluations of the PRF extension in any context. Second, we provide analysis of the pattern of MFT hacks and limitations of document encryption methods which grounds the research in real-world deployability, addressing a pressing problem demonstrated by millions of individuals affected by MFT data breaches. Third, we present a structured comparative framework for evaluating document encryption methods. Fourth, we provide empirical evidence on the usability and user acceptance of passwordless document encryption through a controlled lab study.

1.1 Overview of Thesis

Chapter 1 gave an introduction and explained the problem and research questions motivating this research. Chapter 2 provides a summary of recent MFT hacking incidents and related work in existing literature to give context and background to the research. Chapter 3 outlines the methodology of the research which is divided into three phases. Chapter 4 details the method and results of careful analysis and comparison of existing document encryption methods. Chapter 5 explains the design requirements and process of developing the passwordless document encryption system. Chapter 6 reviews the user testing performed including the IRB approval, screening criteria, tasks performed, and results gathered through both quantitative scales and qualitative interview questions. Chapter 7 presents the results of the user study. Chapter 8 presents discussion, limitations, and concluding perspectives.

Background and Related Work

This chapter presents important context to understand both the problem space and current state of research in passwordless document encryption. Most work addressing real-world problems is interdisciplinary, and this topic is no different. This research overlaps with multiple fields and niche areas including document encryption, usable security, passwordless authentication (FIDO2), and the usability and adoption of passwordless systems. First, a threat analysis of the attack patterns on MFTs which frames the problem space is presented, followed by a literature review of the history of document encryption methods, the challenges of replacing passwords, available open-source encryption tools, and the current state of passwordless authentication provided by FIDO2 and WebAuthn.

2.1 Threat Analysis

2.1.1 A Pattern of MFT Hacks

From 2020–2025, several mass exploit events compromised millions of confidential documents, including personal health data, government records, and legal files [1]. The largest incident resulted in the exposure of 95,788,491 individuals’ personal information [3]. While each incident had major impacts, perhaps most notable is that this represents a recurring, systematic attack pattern with a specific type of software targeted again and again in similar ways. Capable professional hacking groups—such as the Cl0p hacking group—have repeatedly attacked file transfer platforms including MFT (Managed File Transfer) and FTP (File Transfer Protocol) applications because these systems allow direct access to sensitive files without the need for lateral movement. As Sandra Joyce, VP at Mandiant, noted, “Mass exploitation of a vulnerability in file transfer software can allow threat actors to efficiently gain access to many organizations’ sensitive files without the need for additional lateral movement” [10]. The effectiveness of this threat model is demonstrated by its recurrence: the same attack pattern has been exploited against file transfer platforms more than eight times between 2020 and 2025.

Table 2.1 shows several of the vulnerabilities exploited from 2020–2025, which follow the same threat model. All of the vulnerabilities included are CISA KEV-listed vulnerabilities meaning they are known to be actively exploited “in the wild.” The CVSS scores are nearly all high or critical. Many of these were zero-day vulnerabilities discovered and

intentionally exploited by capable professional hacking groups including multiple by the same threat actors (e.g., Cl0p).

Table 2.1: Actively exploited vulnerabilities in Managed File Transfer (MFT) systems (2020–2025).

Date	MFT Provider	CVE ID	CVSS 3.1	CISA KEY
Dec 2020	Accellion FTA	CVE-2021-27101	9.8 (Critical)	Yes, Added 11/03/2021
Jan 2022	SolarWinds Serv-U	CVE-2021-35247	5.3 (Medium)	Yes, Added 01/21/2022
Feb 2023	Fortra GoAnywhere	CVE-2023-0669	7.2 (High)	Yes, Added 02/10/2023
May 2023	Progress MOVEit	CVE-2023-34362	9.8 (Critical)	Yes, Added 06/02/2023
Apr 2024	CrushFTP	CVE-2024-4040	10.0 (Critical)	Yes, Added 04/24/2024
Jun 2024	SolarWinds Serv-U	CVE-2024-28995	8.6 (High)	Yes, Added 07/17/2024
Dec 2024	Cleo MFT	CVE-2024-50623	9.8 (Critical)	Yes, Added 12/13/2024
Jul 2025	Wing FTP Server	CVE-2025-47812	10.0 (Critical)	Yes, Added 07/14/2025
Sep 2025	Fortra GoAnywhere	CVE-2025-10035	10.0 (Critical)	Yes, Added 09/29/2025

To illustrate the attack pattern, we will describe details of two of the hacking incidents: Accellion FTA (2020–2021) and MOVEit MFT (2023). These two examples share many similarities to the other vulnerabilities included in Table 2.1 and are selected because they represent the earliest incident and the largest incident.

2.1.2 Accellion FTA Incident

In the Accellion Kitemworks File Transfer Appliances (FTA) incident, which began in December 2020 and extended into 2021, Cl0p chained together four vulnerabilities including zero-day exploits to install a web shell on internet-facing Accellion FTA servers [2]. Cl0p used this exploit chain to target federal, state, and local government organizations as well as private organizations across the medical, legal, telecommunications, finance, and energy sectors [11]. According to data breach reports and legal proceedings, the stolen data included various forms of personally identifiable information (PII) such as personal health information (PHI), Social Security numbers, addresses, emails, and financial information from many large organizations including Bombardier, Jones Day Law Firm, Shell, Kroger, Morgan Stanley, the Reserve Bank of New Zealand, Trinity Health, and the University of California [12].

This incident was significant as it was the first major data breach in what became a series of MFT hacks. The incident occurred in 2020 and impacted diverse sectors from banking and legal to health care, education, and retail. This incident should have been a wake-up call prompting changes in cybersecurity defensive strategy but instead became the first of many similar incidents that would follow over the next five years.

2.1.3 MOVEit MFT Incident

The largest incident of this kind was the hack of Progress Software’s MOVEit MFT in July 2023. Now a classic example of a third-party exploit leading to data exfiltration, the MOVEit MFT was widely used by many large organizations who were affected. A zero-day SQL injection exploit led to a webshell which gave access to execute operating system commands and exfiltrate files stored in the MFT server [2].

Estimates of affected organizations based on state breach notifications, SEC filings, other public disclosures and Cl0p’s website total to 2,773 organizations and 95,788,491 individuals [3, 13]. The organizations with the most impacted individuals are listed in Table 2.2.

Table 2.2: Organizations with the most individuals impacted by the MOVEit incident.

Organization	Impacted Individuals	Industry
Welltok	14.76 million	Health care
Maximus	11.3 million	Government IT Contractor
Delta Dental of California and affiliates	6.9 million	Dental Insurance
Louisiana Office of Motor Vehicles	6 million	Government
Alogent	4.5 million	Banking

This incident was significant because it was the largest breach by number of impacted individuals. The total estimated count of 95 million impacted individuals represents 28%^a of the United States population in 2023 [14]. Regardless of the exact numbers it is clear this incident had widespread impacts affecting many ordinary individuals who simply registered their car with the Louisiana Office of Motor Vehicles, or had their dental and healthcare records stored in MFT services from major businesses like Welltok and Delta Dental. Incident investigation found that “Welltok used the MOVEit Transfer tool for transferring large datasets across the Internet as part of its contracted services with health plans” [15]. Similar to the Accellion FTA incident described earlier and the other incidents listed in Table 2.1, the MOVEit MFT breach impacted several industries including healthcare, IT, finance, government, and insurance. The common thread across the impacted organizations is the use of large datasets transferred through internet reachable means (i.e., a cloud-based or publicly accessible managed file transfer service).

A notable detail of the MOVEit incident is that the vulnerability patch development and deployment were completed quickly and efficiently. Patches to protect against the MOVEit vulnerability (CVE-2023-34362)

^a28.65% = 95,788,491/334,233,854, U.S. Census estimated population Jan 1 2023 [14].

were quickly developed once the zero-day issue was identified and were rapidly adopted by affected organizations. One study found that organizations remediated the MOVEit vulnerability roughly 21 times faster than typical remediation rates, reaching in 42 days what would normally take 29 months [16].

Despite the speed with which the patch was developed and implemented across many organizations, millions of individuals were impacted by the data exfiltration that occurred within the brief window when MOVEit servers were vulnerable. This illustrates the key systematic risk of public facing MFTs that do not protect files with per-document granular encryption. In short, the vulnerability patching was fast—essentially a best case scenario for cyber defenders—but because it was a zero-day of public-facing servers and the data was protected in an all-or-nothing encryption approach, it still had a major impact.

2.1.4 Summary and Threat Model

The significance of the incidents described is that managed file storage options are playing catch up to skilled threat actors instead of designing a better system that can proactively prevent these types of incidents. The repeated pattern of exploits often by the same threat actors targeting the same type of software indicates a systematic problem more than a “one-off” issue. Although MFTs encrypt files “at rest” all documents are unencrypted and readable by a privileged user session. Once an attacker gains a privileged session on the server—via a zero-day exploit or otherwise—all documents on the server are accessible and can be exfiltrated. While detection, response [17], and patching are important reactions to help mitigate the impacts of incidents, in order to fully prevent this attack category, a new defensive approach must be designed and implemented. The current security model fails because it relies on a perimeter defense rather than a zero-trust, per-document protection model. This argument motivates our research. These events highlight the real world need for improved design of document protection systems. In real-world adoption there are always tradeoffs between security and usability; frequently deployability and adoption are the limiting factors for effective security being used in the real world.

Based on the pattern of MFT incidents described above, a general adversarial threat model can be stated. We assume an attacker who has gained initial privileged access to a document repository (e.g., an internet-reachable MFT via a zero-day exploit) and is focused on data exfiltration rather than ransomware or destruction. The threat model does not assume the attacker has local access to individual users’ devices or authenticators, rather the attack surface is the server and its stored documents. Table 2.3 maps each threat to the design requirement that mitigates it and the corresponding security, usability, or deployability benefit from the framework presented in Chapter 4.

Table 2.3: Adversary threat mapping to design requirements and UDS framework benefits.

	Threat	Design Requirement	Benefit(s)
I	Bulk server-side file access	Granular per-document encryption, no shared encryption key	S4 Granular-Protection
II	Brute-force password cracking post-exfiltration	Passwordless key derivation	S2 Resilient-to-Guessing U1 Memorywise-Effortless
III	Unauthorized redistribution of exfiltrated files	Recipient-bound encryption	S3 Resilient-to-Third-Party-Leak
IV	Server compromise exposing encryption keys	Non-custodial, client-side key derivation, zero-knowledge server	S3 Resilient-to-Third-Party-Leak

2.2 Document Encryption

2.2.1 History of Protecting Documents

Written documents have long held sensitive information and methods to protect that information have developed alongside them. In ancient Mesopotamia, a cuneiform clay tablet dating to 1500 BCE contains one of the earliest known examples of a formula for making pottery glazes. The ancient scribe used cuneiform signs with multiple possible values and truncated symbols in an effort to guard the professional secret [18]. Protecting sensitive information in documents (be it a pottery glaze recipe, legal document, or financial data) remains just as important today, but the methods are often a digital version of the same approach: obscure the contents behind a secret that only the intended reader knows. As digital tools became widespread in the 1990s, the feature to protect a document by encrypting the contents based on a fixed password was developed and added to Microsoft Word and Adobe Acrobat [4]. It soon became a standard feature across document file types and operating systems. Today, the encryption works in a similar way as it did when first introduced; however, the technical details of cipher strength and key length have been gradually upgraded. Since the development and distribution of password-protected encrypted documents across Word,

PDF, and many operating systems, innovation in protecting documents has lagged.

Efforts have been made by researchers to create simple and cost-effective methods of encrypting individual documents. The most common form of document encryption is password-based AES encryption which is built into Microsoft Word [19] and PDF processing software like Adobe Acrobat [20]. Typically, AES (128 or 256-bit) encryption is used with a single password as the key to protect the entire document. A major problem with this method (used by Microsoft Word and most PDF documents) is that unlike a web-based password, once a password has been set to encrypt a document, it cannot be changed or recovered if forgotten [21]. One group of researchers discuss the potential implementation of new ciphers for PDF encryption, however the focus of their proposed solution is on minimizing the file size rather than improving the security and usability of the encryption features [22].

2.2.2 Protected Documents Today

Electronic documents containing sensitive data are used across nearly every industry and profession. Examples include health records, legal counsel, financial data, trade secrets, and employment contracts. These documents frequently must be protected, especially before being shared externally. The PDF format has become a de facto standard for encrypting and transmitting sensitive documents. Müller et al. (2019) document that PDF encryption is widely deployed: companies like Canon and Samsung use it in document scanners to protect sensitive information, IBM offers PDF encryption services for wrapping confidential data including images, and healthcare organizations use encrypted PDFs to transfer protected health records. Some organizations have adopted gateway systems that automatically encrypt outgoing email messages as password-protected PDF attachments, with the password communicated over a second channel such as SMS [22]. The prevalence of PDF encryption across these use cases underscores both the importance of the format and the urgency of addressing its limitations, which are examined in detail in Chapter 4.

These sensitive documents are often stored and shared using cloud services like managed file transfer (MFT) applications, as discussed in the threat analysis in Section 2.1. The focus of this research is document protection in the sense of confidentiality: ensuring that only the intended recipients can read the contents of a document. However, confidentiality without usability or deployability is impractical because such a system will not be used in real-world scenarios; thus the requirements are security, usability, and deployability [8, 9]. Related topics such as document integrity, digital signatures, and content modification detection—which primarily address the integrity aspect of cybersecurity—are outside the scope of this work.

2.2.3 Document Encryption Hacking

Research on document encryption security has focused primarily on demonstrating weaknesses in password-based protection. Müller et al. in their 2019 CCS paper [22] trace a pattern of researchers cracking PDF passwords and ensuing patches from 2001 through 2020. In 2001 Komulainen et al. performed a security analysis of encrypted PDFs and pointed out risks of 40-bit key length encryption. Sklyarov et al. demonstrated brute-force tools to crack PDF encryption at DEF CON 9 in the same year. This led Adobe^b to increase the key length from 40 to 128 bits for RC4 encryption in the PDF version 1.4. In 2008, Sklyarov et al. returned and found security issues which enabled brute-force attacks in the latest PDF version 1.7. Adobe again updated the key derivation in the PDF standard. In 2013, Danczul et al. showed methods for brute-forcing encrypted PDF passwords across different processors including GPUs [5]. This research found that nearly any password-based document encryption can be cracked with “little overhead” given enough time and the proper computational resources [5]. In 2015, August et al. measured the time to brute force a PDF password based on the password’s length. In 2017, Stevens et al. demonstrated a method to crack PDF passwords within seconds by downgrading to old algorithms and using tools like pdf2john. Some commercial tools such as Elcomsoft apply these techniques and sell the ability to break encrypted documents which are used by law enforcement agencies and others. Results from prior research have also found methods to break XML encryption. In 2019, Müller et al. demonstrated a novel solution for breaking the confidentiality of a protected PDF by adding exfil content at the bottom of the PDF which executes when the document is opened [22]. The most recent and relevant research article on breaking PDF encryption emphasized that there are likely additional security flaws in document encryption, but limited research has been performed in the area [22]. Novel methods of breaking the encryption of password protected documents have been developed and published as recently as November 2024 [6].

^bAdobe owned and managed the PDF standard from inception until 2008 when it became ISO standard 32000.

Beyond document encryption, several research efforts have demonstrated weaknesses with current file security measures. In 2021, researchers published their findings of two new vulnerabilities allowing undetected content modification on certification-signed 2.0 PDFs [23]. These findings resulted in new CVEs being created for several software vendors who in turn released off-cycle patches to remediate the security issues found. The researchers found that 24 of the 26 commonly used PDF viewer applications they tested were vulnerable to attack [23]. Security researchers have also uncovered vulnerabilities in the digital signature process used to sign and verify PDF [23], Microsoft Office (OOXML), and OpenDocument files. Novel attacks such as content masking and modification of signed PDF files have also been discovered and reported. Microsoft’s Rights Management Services, which enforces access controls on Word documents across Azure and Office 365, was also found vulnerable to attacks that could completely strip protection

from view-only documents [24] (see MSRC Case 33210).

In summary, despite decades of ongoing vulnerabilities and patching, the typical approach to document encryption of deriving the offline key based on a user-selected password to protect the file remains largely unchanged.

2.2.4 Design Research

Design research on document protection methods has primarily focused on maintaining privacy and integrity. For example, CryptPad is an open-source anonymous document editing software for which the design process has been analyzed. Efforts to improve the integrity of the PDF specification include strengthening the PDF trust chain [25] and employing the zero-trust file methodology of Content Disarm and Reconstruction (CDR) [26]. Research to maintain offline document integrity resulted in a Microsoft Word plugin that tracks document changes and provides integrity and non-repudiation, but does not handle confidentiality [27]. Further related work has addressed serializing document encryption enforcement and investigated a blockchain method to protect documents. While design research on protecting documents is active there is relatively little design work focused on the underlying confidentiality mechanism to protect a document's contents.

2.2.5 Usability Gap

Regarding the usability of encrypted documents, very little work has been done to directly assess the usability of current document protection methods. However, extensive usability research has been performed on passwords [8], passwordless technology [28], and encrypted email [9], which each presents important connections to the problem of usability in document encryption. Passwords are the incumbent solution for document protection but have key differences when compared to website login passwords used for user authentication. Unlike web-based authentication, password-protected documents cannot throttle guess attempts, cannot recover or reset a forgotten password, and offer no mechanism for revoking access once the password has been shared. These differences mean that password-based document encryption provides less security and less usability than passwords used for web authentication (a method that itself has well-documented limitations). The implications of these limitations and the broader quest to replace passwords are discussed in Section 2.3.

2.3 The Quest to Replace Passwords

Considerable research has focused on the quest to replace passwords with new authentication methods that provide improved security and usability benefits. In 1999, the study “Why Johnny Can’t Encrypt” evaluated PGP through a lab study and found that PGP’s encryption system “[was] not usable enough to provide effective security for most

computer users, despite its attractive graphical user interface, supporting our hypothesis that user interface design for effective security remains an open problem.” [29]. This study became a landmark paper in usable security as it highlighted the need to study usability and user acceptance of security systems in order to understand user adoption. Passwords specifically have known usability problems of increased cognitive load which leads to weak security practices including password reuse and the selection of simple passwords. The reader is likely familiar from lived experience of this. As researchers note, “With every new user account and every new password cognitive load is increasing so that usability is often preferred over security by users: For example, users often choose the same password across accounts, keep an insecurely stored written record or choose unsecure dictionary passwords” (e.g., Adams et al. 1997, Johnson and Grawemeyer, 2011, Wash et al., 2016).

Despite the security weaknesses and usability flaws of passwords, however, their use persists. Another landmark paper in usable security zeroed in on this question: Why have so many password-replacement concepts not caught on? Their systematization of knowledge on the topic involved a formalized evaluation of passwords and password-replacement methods against a set of benefits grouped into three categories: usability, deployability, and security [8]. This methodology and formal evaluation approach is adapted in this work by applying the UDS benchmarking to the document encryption context in Chapter 4. The authors [8] find that while password-alternative methods often provide superior security and/or usability, no system provides equal or superior benefits in deployability. Deployability includes a low per-user cost to set up and operate a system. A highly deployable system is compatible with existing technology and can be implemented and used by anyone without having to pay a fee. The authors conclude that deployability is a major reason why no method has gained traction to replace traditional passwords for user authentication. In many respects, 2-factor-authentication is to balance the security, usability, and deployability tradeoffs that exist between different authentication methods.

In a later article continuing the analysis, Herley and Van Oorschot (two of the authors of *The Quest to Replace Passwords* study) write “The ‘password replacement problem’ is both underspecified (in vagueness of specific goals or concrete requirements) and over-constrained (it is simply impossible to find a single solution addressing all security and usability needs in all scenarios). Regarding the latter, rather than seeking a silver bullet, we must consider best-fit solutions” after acknowledging that “[passwords] are likely to persist for some time” they point out that “there are scenarios where passwords are not the best-fit. To determine these cases and find suitable alternatives requires (a) clearly and specifically identifying the requirements; and (b) devising a practical, reliable methodology to evaluate, score, and compare competing alternatives against these requirements. The research avenue suggested is to gain better insight into actual threat likelihoods and actual harms experienced when things fail. An important step is to replace unsupported opinions

by factual evidence and real-world data” [30]. This research is grounded in this approach starting with an analysis of “actual harms experienced when things fail” as described in Section 2.1, followed by a set of requirements and evaluation method presented in Chapter 3 and 4 which is then assessed in a lab study in Chapter 6.

While the quest to replace passwords has focused primarily on user authentication, the same usability-deployability-security tensions apply to document encryption. Encrypted documents present a related but distinct model with two important differences. First, an encrypted file often must be shared with another user to access, where a user’s login should not be shared with others for access. Second, a document or file must be self-sufficient, meaning it functions standalone from any server, while user authentication often depends on connection to a server either through the internet or directly through user login. These two differences shift the usable security model for document encryption compared to user authentication: multiple parties are expected to access the same resource, and the file must function independently of a server.

The practical consequences of these differences are visible in how organizations handle sensitive documents today. Even government agencies with formal data protection requirements rely on password-based file encryption with manual password communication. For example, the U.S. Department of Education instructs individuals submitting documents with personally identifiable information (PII) to “encrypt [and email] the file and send a second email. . . with the password to decrypt that file” [31]. This two-email process—one for the file, one for the password—illustrates the usability and security limitations that motivate this research: the sender must create, remember, and securely transmit a password through a separate channel for every encrypted document shared and the process is prone to interception, unauthorized sharing, and human error.

The challenges of protecting shared documents have many similarities with secure email—in fact, sensitive documents are often sent as encrypted email attachments—thus the usability research performed in this domain has important implications for protected documents. Like email, document file formats were not originally designed with security in mind, and most encryption features have been bolted on after the fact. A systematization of knowledge on secure email found that regular users often do not encrypt their communications, and that usability is not the only obstacle to adoption [9]. Garfinkel et al. found that half of surveyed users did not use encrypted email because they did not know how, while the remainder indicated they did not think it was necessary or that the effort would be wasted [32]. More broadly, users do not perceive significant risk, lack knowledge about effective ways to mitigate risk, and lack confidence in their ability to use secure systems effectively [9]. These findings parallel the document encryption context directly: if users do not understand how to encrypt a document, do not perceive the risk of leaving it unencrypted, or do not feel confident they can do it correctly, adoption will not follow regardless of the technical security properties

of the tool.

Beyond secure email and password replacement research, broader cybersecurity research has identified self-efficacy—a belief in one’s own ability to enact cybersecurity-related skills—as a key predictor of security behavior adoption. An evidence review by the European Union Agency for Cybersecurity (ENISA) found across studies of Protection Motivation Theory and Theory of Planned Behaviour that self-efficacy was “a reliable, moderately strong predictor of cyber-security intention and behaviour” outweighing threat-based factors [33]. A systematic review of 174 studies reinforced the centrality of self-efficacy in cybersecurity behavior research [34]. Self-efficacy has also been shown to predict perceived ease of use, which in turn predicts perceived usefulness of a technology [35]. When users feel confident in their ability to use a tool, they perceive it as easier and more worthwhile to use. Importantly, response efficacy must accompany self-efficacy, meaning users must believe that they are capable of using the tool and that the tool will effectively protect them in order for user acceptance and adoption to occur [33]. In short, interventions that enable users to feel confident in using a security tool are more likely to increase user adoption than interventions that emphasize the severity of threats. These findings inform the qualitative themes explored in the user study in Chapter 6 and underscore that the problem space is not simply a technical encryption challenge but relies on human-centric psychological factors.

In summary, the literature on password replacement and security behavior demonstrates that achieving real-world adoption requires addressing usability and deployability alongside security, and that human-centric factors such as self-efficacy and perceived effort are as important as the technical properties of the system itself [8].

2.4 Open Source Encryption Tools

Deployability of a system is most likely when the system can be implemented without fees or significant material costs. Proprietary systems with licensing fees often struggle to gain widespread adoption due to the financial disincentive. As such, open source software (OSS) is an appealing area to consider for this problem space as the software is typically provided free of use and can be installed within various architectures without resulting in licensing fees. There are several open source data encryption standards and software libraries. This section will share a few open source tools that are particularly relevant to the research performed.

Age is an open-source, modern file encryption tool designed by Filippo Valsorda [36]. A formal specification of age is defined as part of the Community Cryptography Specification Project [37]. Designed in part to replace GPG for file encryption, age has small explicit keys and UNIX-style composability. Age uses authenticated encryption (ChaCha20 as cipher and Poly1305 as message authentication code) in a streaming chunk design to provide confidentiality and integrity by

default and support large files. Since version 1.3.0 age includes support for post-quantum schemes (via ML-KEM-768 and X25519).

Initially developed as a Go library to perform file encryption, the age specification has been implemented in multiple programming languages and supports plugins and integrations with several encryption management tools. A Rust implementation (rage) and TypeScript implementation (typage) exist alongside plugins for YubiKey®s and other identity authenticators. Age is designed to support multiple recipients where each recipient can independently decrypt the file. In its default mode, age encrypts to either a passphrase (password) or public key string(s). Both of these modes require users to manage and exchange cryptographic material out-of-band. Age is intentionally focused on file encryption and does not handle key exchange or secure messaging, leaving those problems to other tools. Notably, the typage browser implementation supports passkey-based encryption via the WebAuthn PRF extension, discussed in Section 2.5.4, which provides an alternative to password-based and manual key exchange for file encryption.

Picocrypt [38] (now maintained as Picocrypt NG) is a lightweight, open-source file encryption tool with strong cryptographic features. While not used directly in this work, it is an alternative option for open-source file encryption. Picocrypt also relies on password-based key derivation focusing on the file encryption problem instead of the key distribution or access control problems relevant to sharing encrypted documents.

OpenTDF [39] is the open-source implementation of the Trusted Data Format which is a standard of the U.S. Director of National Intelligence [40] that enables attribute-based access control (ABAC) to be cryptographically tied to a data object. ABAC enables more granular access control than the all-or-nothing access control of traditional password-based file encryption. The role of OpenTDF in future extensions of this work is discussed in Section 5.2.3.

These tools primarily address the file encryption process and do not fully address how a user can authenticate—prove their identity—without the factor of something you know (e.g., password, secret key). This requires a separate set of protocols discussed in the next section.

2.5 Passwordless Authentication and FIDO2

While MFTs continue to be hacked and sensitive documents are protected either individually by passwords or all together by cloud based storage, there has been vast improvement in recent years to develop and standardize passwordless authentication protocols.

2.5.1 Hardware-based Authentication

One of the most well-known weaknesses of passwords is that they are often exploited in phishing attempts because users assume the phishing site is legitimate. To remedy this, early work on passwordless authentication focused on creating phishing-resistant forms of user

authentication. Many modern devices now include a secure hardware enclave—such as a Trusted Platform Module (TPM) on Windows and Linux devices and Secure Enclave on Apple devices—a hardware-based security feature that can generate and store cryptographic keys isolated from the device’s main processing components. Hardware tokens such as YubiKeys provide a similar secure hardware enclave to calculate random numbers which is used to generate and store cryptographic keys. The biometrics in modern devices (e.g., a fingerprint or facial scan) work with the on-device secure enclave to provide hardware-bound secrets and remove the password and memory aspect from the user authentication. A hardware token works similarly as a portable physical asset that is separate from the computer device. These methods of hardware-based authentication secure user login by transferring the work of key creation and management from the user to a dedicated computational device. This means users can authenticate their identity without relying on memory (passwords, security questions) or basic 2FA (text, email code). This work to build standardized hardware-based authentication—motivated by an effort to have phishing resistant authentication—in many ways led to the FIDO2 standardization (for instance, Yubico, Google, Apple, and Microsoft who included trusted compute environments in their devices have been important contributors to FIDO2 standards).

2.5.2 Passwordless Authentication Outside of FIDO2

Various passwordless authentication schemes have been proposed; some are now defunct or are proposed in academic research but are not widely used in practice today. These approaches include:

- Hardware Authenticator Binding [41]
- Pico [42]
- Let’s Authenticate [43, 44]
- Mozilla Persona (BrowserID) [45]
- TUSH-Key: Transferable User Secrets on Hardware Key [46]

However, none have achieved the industry adoption or standardization momentum of FIDO2.

2.5.3 FIDO2

FIDO2 is an open standard for passwordless authentication developed and maintained by the FIDO (Fast IDentity Online) Alliance, whose membership includes major technology companies such as Google, Microsoft, and Apple. Unlike earlier passwordless authentication schemes, FIDO2 has substantial industry backing that has driven widespread support across browsers, operating systems, and common websites. This gives FIDO2 the potential to overcome the deployability barriers that have

historically prevented password replacement mechanisms from gaining traction.

As of 2026, this potential is being realized at scale. The FIDO Alliance’s *State of Passkeys 2026* report, based on a survey of 11,000 consumers across ten countries, found 90% of consumers are now familiar with passkeys and 75% have enabled them on at least some accounts. In workforce environments, 68% of organizations are deploying, piloting, or rolling out passkeys for employee authentication [7]. In total, there are an estimated 5 billion active passkeys globally [7]. These figures represent a significant shift from even two years prior and suggest that FIDO2 has begun to cross the adoption threshold from a novel technology to mainstream use.

At its core, FIDO2 is made up of two standardized protocols: CTAP2 (Client to Authenticator Protocol) [47] and WebAuthn (W3C’s Web Authentication API) [48]. Together, these protocols shift authentication from the knowledge factor (“what you know”) to the possession factor (“what you have”). There is no shared secret between the server and client. FIDO2 is resistant to phishing, replay attacks, and server-side credential breaches because unique keys are created for each authentication ceremony and the secret is never stored or shared with the server. The user’s secret is derived on their authenticator which can be either a platform authenticator (e.g., Windows Hello™, Face ID®) where the keys are typically stored in the device’s secure hardware enclave, or a roaming authenticator (e.g., YubiKey) which is device-independent. Users authenticate locally to the authenticator using a PIN or biometric factor such as a fingerprint or facial scan. The CTAP protocol defines communication between the client browser and the authenticator, while WebAuthn defines the API through which the browser communicates with the server (called the relying party). Figure 2.1 illustrates this architecture.

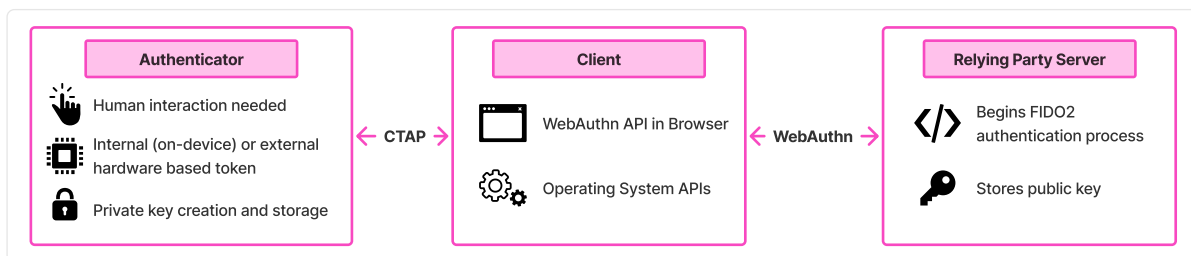


Figure 2.1: FIDO2 architecture. The authenticator creates and stores the private key, communicating with the client via the CTAP protocol. The client communicates with the relying party server via the WebAuthn API. The server begins the process and stores the public key.

By integrating CTAP and WebAuthn into a standard with backing from major technology vendors, FIDO2 offers a standardized password-less authentication protocol with broad support across the modern internet infrastructure. Deployment is promising but not yet universal.

A recent analysis of 111 websites found that FIDO2 passkey implementations generally adhere to the FIDO Alliance Design Guidelines approximately 77% of the time, with higher-ranked websites exhibiting more consistent passkey user experiences and closer alignment with the guidelines [49]. Jannett et al. found steady growth in passkey adoption from 2021–2025 across the internet but that many sites had security flaws in their implementation of WebAuthn [50]. In summary, FIDO2 is gaining significant traction but is not yet without implementation challenges.

2.5.4 WebAuthn PRF Extension

FIDO2 and WebAuthn provide a robust authentication ceremony with many benefits, but as they are built for user authentication they do not on their own provide file encryption. The remaining question is: how do you derive encryption keys without a password or server-stored key? The WebAuthn PRF extension addresses this gap.

WebAuthn PRF is an optional extension in the Web Authentication Level 3 specification (Section 10.1.4) where the relying party provides a salt to the authenticator via WebAuthn which the browser hashes with a context string before passing it to the authenticator. The authenticator then combines the hashed salt with its internal key via HMAC-SHA-256 to produce a deterministic 32-byte string which is returned to the relying party [48]. The WebAuthn PRF process is described in Figure 2.2. A pseudo-random function (PRF) produces output that is deterministic for a given input but computationally indistinguishable from random, which makes the output string suitable for use as symmetric key material. The W3C specification directly names symmetric key encryption as the motivating example for the inclusion of the PRF extension [48]. The underlying protocol mechanism is the CTAP2 hmac-secret extension, which provides access to the hardware-backed HMAC-SHA-256 computation. The WebAuthn PRF extension acts as a standardized browser API for web applications to access this capability [51].

While standard WebAuthn operates as a challenge-response for user authentication, the PRF extension enables a deterministic output that can be used as a symmetric encryption key. The security benefits of this model include a unique key per user per website (each site has a unique salt), hardware-bound derivation (the internal key never leaves the authenticator’s secure element), tamper resistant (the authenticator is a trusted compute environment), non-custodial (the relying party never receives the authenticator’s secret), and phishing resistant (WebAuthn scopes credentials to the relying party’s origin) [52, 53].

To understand why PRF improves security beyond existing two-factor authentication, consider how a hardware security key functions differently in each model. When a YubiKey is used for traditional 2FA, it presents a second gate that must be passed through before the server shares encrypted data to the requesting user. If an attacker bypasses 2FA through a server-side compromise or session hijacking, the data’s

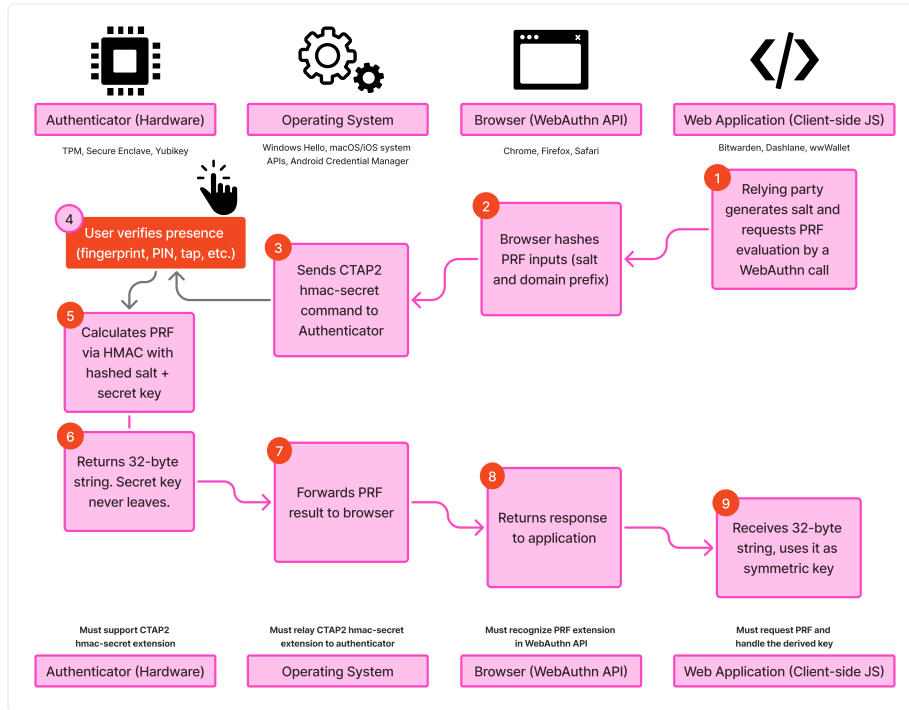


Figure 2.2: WebAuthn PRF extension flow across the four required layers (authenticator, operating system, browser, and web application) showing the process for deriving a symmetric key from the authenticator’s internal secret.

protection falls entirely to the password because the data encryption was based on the password and the 2FA served as an additional gate, not a part of the encryption derivation process itself. PRF fundamentally changes this model by making the passkey part of the encryption process itself rather than an access gate in front of it. The encryption key is derived directly from the authenticator’s hardware-bound secret combined with the relying party’s salt: no password is involved. This means that even if an attacker compromises the server, they obtain only encrypted ciphertext with no feasible path to the decryption key, because the decryption key exists only when the authenticator is physically present and the user completes the WebAuthn ceremony [52, 53]. In short, 2FA protects *access* to encrypted data; PRF protects the *encryption itself*.

The PRF extension has seen early implementation in use cases where security and a non-custodial model is of primary importance. Password managers including Bitwarden™ and 1Password™ use PRF to enable vault decryption without a master password [53]. Digital wallets like cryptocurrency wallets and digital identity wallets, such as the wwWallet project, use PRF to derive encryption keys for non-custodial credential storage [52]. These early adopters demonstrate PRF’s viability as a realistic solution for non-custodial encryption but focus on personal data vaults. To our knowledge no prior work applied the WebAuthn PRF scheme to file encryption with multi-party sharing as is needed for

secure document management.

Support for WebAuthn PRF requires orchestration across four layers: the hardware authenticator, the operating system, the browser, and the web application. A failure at any layer means the extension is non-operable (Figure 2.2). As of mid-2026 support is maturing rapidly but is not yet universal. Chromium-based browsers (Chrome™, Edge™) support PRF on all major desktop platforms. Windows Hello added hmac-secret support in February 2026 (via cumulative update KB5077181), resolving a longstanding gap on Windows [51]. Firefox™ 148+ supports PRF with Windows Hello on both credential creation and authentication [51]. Safari™ added PRF support for iCloud® Keychain passkeys (platform authenticators) in Safari 18, and extended support for roaming authenticators (security keys) in an April 2026 update.

In short, WebAuthn PRF enables secure symmetric encryption where the secret is tied to the hardware-based passwordless authenticator. This means a passkey can serve not only as a login credential but also as a source for enabling passwordless, non-custodial file encryption. This is the technical foundation for the system design presented in Chapter 5.

2.5.5 Passkeys: Synced vs. Device-Bound

While FIDO2 and its underlying CTAP2 protocol can operate with a variety of authenticators, one of the most common is a passkey which is a term FIDO2 presents as “the high level, end-user centric term for a FIDO2/WebAuthn Discoverable Credential” [54]. “Like ‘password’, ‘passkey’ is a common noun” which is “designed to be used without additional login challenges” [54]. Each passkey is created and stored by a passkey provider which is responsible to manage the passkey and is often called a password manager or credential manager. The passkey provider may be native to the operating system (first party, e.g. “Windows Hello” on Windows, “Apple Passwords” on macOS and iOS, and “Google Password Manager™” or “Samsung Pass™” on Android devices) or may be added via a browser extension or other tool that intercepts WebAuthn requests and negotiates with the platform authenticator (third party, e.g. “Bitwarden”, “1Password”, etc.).

There are two types of passkeys: synced and device-bound. There are important security-usability-deployability tradeoffs between synced and device-bound passkeys. A synced passkey is shared across a user’s devices typically through a backend cloud-sync by the passkey provider which enables the user to restore passkeys from a backup and have the passkeys available on different devices. For example, if a user created a synced passkey on their phone using Google Password Manager, Google would sync the passkey to the cloud so the user could access and login with the same passkey on their laptop computer if they had authenticated to Google Password Manager on the laptop. Synced passkeys provide usability benefits of easy recovery from loss, cross-platform sharing, and ease of use but have a security tradeoff as the passkey credential is not hardware-bound, can be used on multiple devices, and is stored

and synced by the passkey provider instead of fully non-custodial. A device-bound passkey is bound to a single authenticator such that the credential cannot leave the device. A FIDO2 security key like a YubiKey or a PRF-enabled passkey are examples. Device-bound passkeys are also called single-device passkeys. When considering portability—the ability to move between devices—it is important to understand the distinction between platform and roaming authenticators. A platform authenticator is built-in to a user’s device [54] while a roaming authenticator is a physically separate device attached by USB, NFC, or Bluetooth which can be used to sign into multiple devices. A roaming authenticator is often called a security key. Examples of roaming authenticators include a mobile smartphone, a YubiKey, and more. A roaming authenticator may create either a device-bound or a synced passkey depending on the configuration and the user’s choice. This means there are 2×2 form factor options for the creation of passkeys, as summarized in Table 2.4.

Table 2.4: Security and usability differences between FIDO2 Passkey form factors.

Authenticator	Synced	Device-bound
Platform	Created by the built-in platform authenticator. The credential can be discovered and used on multiple devices via cloud sync.	Created by a single device’s platform authenticator. Only usable on that specific hardware device.
Roaming	Created on a separately attached device, but the credential can be discovered and used on multiple devices.	Created on a separately attached device. The credential cannot leave the authenticator, but the physical authenticator can be moved to login on multiple devices.

Functionally speaking a synced-platform and synced-roaming passkey have similar security-usability-deployability characteristics as they both afford the ability to authenticate from multiple devices based on the syncing with the passkey provider. When the passkey is synced, the device where the credential was first created doesn’t change the security posture since any device with access to the passkey provider’s vault can access the credential. The security and usability tradeoffs between these FIDO2 form factors have been evaluated by researchers using the Bonneau et al. UDS framework and are discussed in the following section.

2.5.6 Security and Usability Evaluations of FIDO2 Authentication

Security-focused researchers have examined FIDO2, CTAP2, and WebAuthn in a variety of methods including formal security proofs, local attacks, and other novel attacks. For example, Barbosa et al. perform provable cryptographic security and privacy analysis of FIDO2's WebAuthn and CTAP2 protocols [55]. Guan et al. use ProVerif to formally verify security assumptions about FIDO2 [56]. Kuchhal et al. evaluate the security of FIDO2 deployments across 1,000 common websites and find that compromised clients (e.g., with malware) pose a practical threat to FIDO2 deployments [57]. Yadav and Seamons present novel local attacks against FIDO2 including malicious browser extension attacks which in some cases "present more risk than passwords alone" [58]. These works generally find FIDO2 has a strong security framework but needs some improvements and is dependent on a non-compromised local execution environment.

Usable security researchers have examined the benefits of passwords vs. FIDO2 hardware tokens and passwords vs. FIDO2 synced vs. FIDO2 device-bound passkeys. In their paper "Is FIDO2 the Kingslayer of User Authentication?" Lyastani et al. performed a large-scale user study of passwords vs. FIDO2 hardware tokens finding that lay users were generally "very satisfied" when replacing text-based passwords with single-factor security keys; however, users lacked mental models to understand how security keys worked and had concerns about the suitability for everyday use, authenticator revocation, account recovery, and overall trustworthiness of the FIDO2 system. The authors conclude that FIDO2 has the potential to be the kingslayer of passwords despite significant shortcomings [59]:

We find it astonishing that users accept [FIDO2 1FA] authentication with security keys so strongly despite these shortcomings. The main reason could be that the disadvantages and weaknesses of text-based passwords have become so obvious and overwhelming for users that they are looking for a technology that can free them from this burden. In summary, we find that there is still a gap between the users' concerns and what the current status-quo of FIDO2 1FA provides.

In terms of the Bonneau et al. U-D-S framework, Lyastani et al. find that FIDO2 hardware tokens provide nearly all the benefits with four and a half gaps: *Nothing-to-Carry*, *Easy-Recovery-from-Loss*, *Negligible-Cost-Per-User* (partial), *Server-Compatible*, and *Resilience-to-Theft*. They differentiate the benefits which are universal to FIDO2 and which are dependent on the authenticator device. This study focused specifically on hardware tokens which lack the benefits of *Nothing-to-Carry*, *Negligible-Cost-Per-User* (partial), and *Resilience-to-Theft* due to the physical hardware device. Platform FIDO2 authenticators (passkeys) offer the same passwordless FIDO2 protocols and benefits without a separate physical device that

must be carried, purchased, and could be stolen. As such, platform passkeys (both device-bound and synced) provide additional benefits when compared to FIDO2 hardware tokens (which are included in the device-bound roaming authenticator category).

Büttner and Gruschka performed a comparison of passwords, device-bound passkeys (both platform and roaming), and synced passkeys using the U-D-S framework presented by Bonneau et al. and found that “the security of synced passkeys is mainly concentrated in the passkey providers” [60]. Notably, Büttner and Gruschka evaluate device-bound passkeys as providing all security benefits in the framework while synced passkeys lack the *No-Trusted-Third-Party* security benefit as a breach of a passkey provider (e.g., iCloud Keychain, Google Password Manager, 1Password) could lead to account compromise thus making the passkey provider a “single point of failure” for synced-passkeys [60]. However, the same security benefit of device-bound passkeys being tied to specific hardware and thus not having a trusted third party is why device-bound passkeys lack the usability benefit of *Easy-Recovery-from-Loss*.

Würsching et al. conducted a lab study comparing user acceptance of FIDO2 platform and roaming authentication on smartphones by having users sign into a mock website through either Touch ID® or a YubiKey via NFC. Results showed SUS scores for both platform and roaming authenticators greater than 90 indicating excellent usability with acceptance scores for both methods also measuring very high. The authors note that “our participants want to use passwordless authentication on smartphones when possible” and that platform authentication had higher acceptance than roaming authentication on smartphones. They find that the account type (e.g. banking vs. email vs. streaming service) changes user adoption preferences based on the perceived sensitivity of the online account [61]. Similar to the other works discussed, users were hesitant to adopt FIDO2 due to concerns about account recovery, credential sharing, and confusion about how multi-device access works for platform authenticators. Notably a countertrend was observed of some users rejecting passwordless authentication for their most sensitive accounts trusting their memory over a passwordless process: “I consider the [YubiKey] to be secure. However, for important accounts, I would rather rely on my memory and that the login does not get into the wrong hands.” [61]. This finding correlates with the observation by Lyastani et al. that users lack a clear mental model of how FIDO2 operates so while users generally see FIDO2 as “secure” when faced with sensitive data they may fall back to trusting a password-based mechanism.

Recently, Kupris and Schreck [62] compared the usability and user acceptance of passkeys, one-time passwords (OTP), and security keys as multi-factor authentication options in a lab study with $N = 92$ university users, finding passkeys rated as most usable ($M = 87.10$ SUS, “Excellent”), fastest, and most accepted, outperforming OTP ($M = 75.81$ SUS) and security keys ($M = 71.58$ SUS).

Beyond controlled lab studies, field studies have uncovered practical barriers to FIDO2 adoption and deployment. Owens et al. compared

a smartphone as FIDO2 roaming authenticator to passwords for user login to a fictitious bank website over two weeks and found that while participants saw the FIDO2 method as more secure they found it less usable than passwords with concerns about the need for a physical device, account recovery, and setup challenges [63]. Ciolino et al. collected diary entries over a week and found users preferred SMS codes to FIDO2 security keys with users reporting uncertainty about the security benefits of security keys [64]. Lassak et al. interviewed 28 CISOs and authentication managers and found barriers to adoption of account recovery, friction, technical issues, regulatory requirements, and security culture [65]. These results suggest that the conceptual usability and security benefits identified through academic frameworks or lab studies may not fully translate to practical benefits in sustained real-world use.

Amer et al. investigated whether technical explanations about FIDO2's benefits would reduce users' reluctance to adopt FIDO2. They found that explicitly communicating security benefits did not influence participants' intention to adopt FIDO2 and did not overcome usability concerns. Notably they found participants' intention to adopt FIDO2 was correlated with factors like self-efficacy and risk perception [66]. This finding reinforces the self-efficacy literature discussed in Section 2.3 that user adoption may be driven more effectively by building users' confidence in their ability to use the security tool than emphasizing its security benefits. For example, Reitinger et al. found a significant increase in passkey adoption when applying digital nudges at appropriate touch-points during a randomized controlled trial with 3,680 participants on a commercial healthcare platform [67].

In summary, FIDO2 presents strong security and usability benefits, though notable concerns exist around account recovery, user mental models, and feasibility in practical day-to-day use. Platform authenticators generally show usability advantages over roaming authenticators; but account recovery and sustained user adoption remain open challenges across all FIDO2 form factors. Of these challenges, account recovery stands out as the most salient concern across the literature and is discussed in the following section.

2.5.7 FIDO2 Account Recovery and Sharing

Researchers consistently identify account recovery as “one of the most controversial aspects” of FIDO2 authentication [60]. Lyastani et al. found that recovery was “a predominant [user] concern. . . in line with prior user study results on 2FA with security keys” [59]. Würsching et al. and Kupris and Schreck [61, 62] observed similar results in their user studies. Farke et al., Kepkowski et al., and Lassak et al. showed the same concerns about account recovery held in corporate and enterprise contexts [65, 68, 69]. The primary reason given by studies by Das et al. [70] and Ciolino et al. [64] for users not using 2FA security keys are that users are afraid of losing their key and locking themselves out of the account or that users see no need to protect the account with an

extra security effort [68]. Kepkowski et al. in an applied usability study with 118 enterprise professionals found account recovery was selected by 60%+ of participants as a top concern with using FIDO2 in their enterprise setting [69].

A few approaches to device-bound FIDO2 credential recovery have been proposed and evaluated in research but have not been widely adopted as the FIDO Alliance generally presents synced passkeys or registering a second security token as the solution for account recovery [60, 71]. Büttner and Gruschka note that there are levels of access and sharing for passkeys from device-bound which is single-user, single-device to synced which is typically single-user but multi-device, shared which enables multiple users to access the same key, and exported where the credentials are bundled and removed from the passkey-provider [60] (see Figure 2.3). Each level of sharing increases the access level for account recovery and third-party risk. Various users and organizations may adjust their permitted access levels for passkey sharing based on their risk tolerance for third-party breaches and their needs for efficient account recovery.

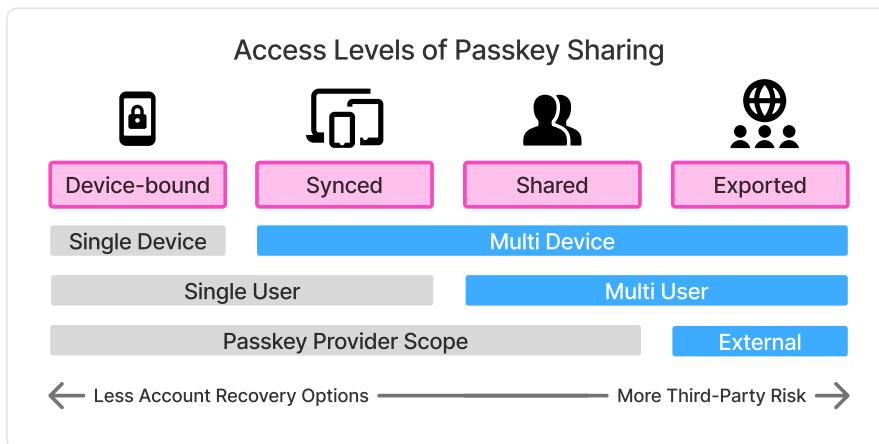


Figure 2.3: Access levels of passkey sharing, from device-bound to synced, shared, and exported. Adapted from Büttner and Gruschka (2025) [60].

Ultimately the choice to use a device-bound or synced passkey rests with the user as there are security vs. usability tradeoffs with both options. Synced passkeys introduce provider trust by shifting security to the passkey provider, but enable multi-device portability and account recovery while device-bound passkeys have no third party risk but lack easy recoverability. Thus the weaknesses of device-bound and synced passkeys are largely complementary. A system that supports both authenticator types—allowing users to choose based on their security needs—could approach the ideal balance of usability, deployability, and security. This possibility is explored in the system design presented in Chapter 5.

Methodology

The methodology of this research is organized into three phases: (1) development of an analytical framework from the literature to evaluate existing document protection methods, (2) design-based research to develop an artifact meeting the design criteria established in Phase 1, and (3) a within-subjects user study to measure the usability and user acceptance of the developed system.

First, we perform a systemization of knowledge for existing document protection methods by creating an analytical framework similar to those used to evaluate password alternatives [8] and secure email [9]. The categories and evaluation criteria we present in this work are consistent with how usability-security-deployability frameworks have been developed and applied in prior literature. We apply this framework to compare nine document protection methods across 15 design properties, identifying each method's benefits and limitations. Development of the document encryption framework involved review of related standardized evaluation frameworks, an analysis of technical specifications for each product, and expert consultation to validate decisions.

Second, from the analysis of existing methods, we derive design requirements for a system that is not password-based, not proprietary, does not require recipients to install special software, and encrypts documents individually. We then conduct design-based research to develop a novel passwordless document encryption system leveraging FIDO2 passkeys, the WebAuthn PRF extension, and open-source age encryption to provide end-to-end protection of digital documents without passwords. An iterative development process produced a proof-of-concept implementation, presented as an open-source codebase and web application, which was evaluated against the established design requirements. Benefits include no user memory burden, encryption keys derived from hardware-backed credentials, and no third-party vendor risk.

Third, we evaluate the system through an IRB-approved within-subjects user study (N=21) comparing the passwordless approach to traditional password-based encryption as provided by Adobe Acrobat. Participants completed encryption and sharing tasks with both systems in a lab setting, providing both quantitative and qualitative data. Usability was measured using the System Usability Scale (SUS) [72] and user acceptance using the Van der Laan scale [73], with the Affinity

for Technology Interaction (ATI) [74] and Privacy Concern [75] scales used to identify covariates. Internal consistency of each instrument was assessed using Cronbach's alpha. The Wilcoxon signed-rank test was used for between-condition comparisons due to the within-subjects design and small sample. Participants also answered ten open-ended interview questions covering their experience with each method, perceived advantages and disadvantages, trust and security perceptions, current document-handling practices, willingness to adopt the passwordless method, and suggestions for improvement. The full protocol is provided in Appendix C. These semi-structured interviews were analyzed through inductive thematic coding [76] to identify patterns, similarities, and differences in participant experiences across the two conditions. Chapter 6 describes the methodology of the user study in greater detail.

Framework for Analysis

This chapter is composed from a paper titled “Document Encryption in Practice: A Comparative Framework and Evaluation” published in the *Proceedings of the ACM Symposium on Document Engineering (DocEng '25)* [77]. I confirm that the use of this article’s contents is compliant with all publishing agreements.

In this chapter, an analytical framework for measuring document protection methods is presented consistent with approaches taken to evaluate authentication schemes in related domains [8, 9, 28, 78]. This framework provides a semi-structured evaluation methodology and benchmark for future document protection methods [8]. We aim to answer the first research question: *What usability, deployability, and security limitations exist in current document encryption methods?*

4.1 Usability-Deployability-Security Framework

The usability-deployability-security (“UDS”) framework was first presented by Bonneau et al. [8] to evaluate password replacement schemes and has subsequently been reused [28, 78], expanded [79], and adapted [9]. The methodology draws on usability evaluation methods such as feature inspection and Nielsen’s heuristic analysis [80] to identify common design properties and develop a taxonomy comparing the benefits offered by each method. The focus is on empirical and technical metrics, limiting subjectivity. Research studies have adapted the UDS framework to specific contexts such as web authentication [28], single sign-on [78], and encrypted email [9], tailoring the measured benefits to fit the unique needs of each domain.

The categories and evaluation criteria presented in this work are consistent with how UDS frameworks have been developed and applied in prior literature. The development of this document encryption framework involved a review of related standardized evaluation frameworks, an analysis of technical specifications for each product, and expert consultation—with three information security academic researchers and two cybersecurity professionals—to validate decisions.

Several caveats should be considered when interpreting the evaluation framework. First, the ordering does not imply importance or ranking. Second, the benefits chosen are not all of equal weight. Depending on the use case, different criteria may be more or less important (e.g., what matters for an enterprise may not matter for personal consumer

use). The framework does not produce precise quantitative scores but enables structured comparison and benchmarking of new methods against existing solutions. The framework is not set in stone; changes in user familiarity, novel security attacks, and other technological advances may require updates over time. As such, the taxonomy is designed to be adaptable and reusable.

Ultimately, the framework illuminates the benefits and limitations of current methods and establishes the design requirements for an ideal method that balances usability, deployability, and security.

4.2 Benefits

We define 15 benefits or desirable properties of document encryption systems, which highlight important evaluation dimensions in Table 4.1. We considered including additional benefits used in previous UDS frameworks, such as *Physically-Effortless*, *Efficient-to-Use*, and *Accessible*; however, as these benefits are consistently present across current methods and do not provide comparative value, they were omitted from the framework. When evaluating, we assess the benefits provided in typical “in-the-wild” use cases instead of the idealistic use case, as our focus is on the practical benefits provided. For example, we assume users may recycle passwords or choose simple passwords.

4.3 Groups

To structure the comparison, document encryption methods were grouped by authentication type. Three primary authentication types are used today for document encryption: **password-based** (a known secret is provided for authentication), **cloud-based** (authentication takes place between a client and server), and **passwordless** (a cryptographic key is provided for authentication). Each authentication type can be applied at various scopes: individual file level, full disk, or file share. These authentication methods and scopes, combined with the licensing model (open-source or proprietary), provide the structure for comparison. For this evaluation, password-based file encryption serves as the incumbent solution against which alternative methods are compared.

The nine methods evaluated are organized into four groups. Password-based file encryption includes the built-in encryption features of Microsoft Word and Adobe Acrobat, as well as full-disk encryption tools such as BitLocker® and VeraCrypt. Cloud-based encryption includes managed file transfer and cloud storage providers such as Box® and SharePoint®, as well as privacy-focused productivity suites such as CryptPad. Passwordless file encryption includes open-source tools such as age.

Table 4.1: Usability, Deployability, and Security Benefits.

Category	ID	Benefit	Description
Usability How easily the primary user can perform necessary tasks.	U1	Memorywise-Effortless	Users do not have to remember any secrets. Partially satisfies if users have to remember one secret for everything (as opposed to one per document).
	U2	Scalable-for-Users	Users' cognitive load does not increase when managing hundreds of documents.
	U3	Easy-to-Learn	Users unfamiliar with the method can learn and recall how to use it easily.
	U4	Easy-Recovery-from-Loss	Users can regain access if recovery is needed. This combines usability aspects such as: low latency before restored ability; low user inconvenience in recovery; and assurance that recovery is possible.
	U5	Seamless-Sharing	Users can easily share a document with others by a familiar method such as a shared link.
Deployability How easily a method can be adopted and used in real-world use cases.	D1	Negligible-Cost-per-User	Cost per user is negligible.
	D2	Negligible-IT-Support-Cost	Cost of IT support is negligible.
	D3	Compatible	The method works across major operating systems, browsers, and software, ensuring documents can be shared with external partners using systems outside direct control but reasonably up-to-date.
	D4	Mature	The method has been implemented and deployed on a large scale in real-world use cases outside of research simulations.
	D5	Non-Proprietary	The method used is published openly and not protected by patents or trade secrets. Anyone can implement or use the method for any purpose without paying a fee to anyone else.
	D6	Guest-Friendly	Third parties can access shared items using a link or other method without requiring provisioning or unique credentials.
Security How well the method protects against unauthorized access attempts.	S1	Resilient-to-Observation	Attacker cannot succeed by observation (e.g., shoulder surfing, recording keystrokes, keylogger malware).
	S2	Resilient-to-Guessing	Attacker cannot succeed by guessing including offline dictionary attacks.
	S3	Resilient-to-Third-Party-Leak	Attacker cannot succeed by gaining information from a third party.
	S4	Granular-Protection	Encryption of documents is performed at a granular level so that compromise of one document does not cause access or compromise of additional documents.

Table 4.2: Comparison of Document Encryption Methods by Usability, Deployability, and Security Benefits

Auth. Type	Scope	License	Examples	Usability					Deployability						Security			
				U1	U2	U3	U4	U5	D1	D2	D3	D4	D5	D6	S1	S2	S3	S4
Password-based	File level	Incumbent	PDF, Microsoft Word	○	○	●	○	○	●	●	●	●	●	●	○	○	●	●
		Proprietary	WinRAR, AxCrypt	○	○	●	●	○	○	●	○	●	○	○	○	○	●	●
		Open Source	7-zip, Picocrypt	○	○	●	○	○	●	●	●	●	●	○	○	○	●	●
Password-based	Full disk	Proprietary	BitLocker, FileVault	●	●	●	○	○	●	●	○	●	○	○	●	●	●	○
		Open Source	VeraCrypt, LUKS	●	●	○	○	○	●	●	○	●	●	○	○	○	●	○
		Proprietary	MFT, SharePoint, Box	●	●	●	●	●	○	●	●	●	○	●	●	●	○	○
Cloud-based	File share	Open Source	CryptPad, Nextcloud, SFTP	●	●	●	●	●	●	○	●	●	●	●	●	●	○	○
		Proprietary	PreVeil, Virtru	●	●	●	●	○	○	●	●	●	○	○	●	●	●	●
		Open Source	age, GPG	●	●	●	○	○	●	●	●	●	●	○	●	●	●	●

● Satisfies ● Partially Satisfies ○ Does Not Satisfy

4.4 Evaluation and Analysis of Solutions

The evaluation—summarized in Table 4.2—shows that no document encryption method today provides all benefits. As such, the choice of which method to use depends on the importance of each benefit and the tradeoffs associated with a particular use case. We summarize key findings by method below. The filled circle indicates the benefit is provided or satisfied by the method, the half circle indicates partially-satisfies and the empty circle indicates the method does not satisfy the benefit.

4.4.1 Password-based encryption

One of the most common forms of document encryption today is password-based file-level encryption, which is built into tools like Microsoft Word and Adobe Acrobat. Typically, AES 256-bit encryption is used to protect the entire document with a single password (up to 15 characters) used to derive the encryption key.

A major limitation of this method is that, unlike web-based authentication, a password cannot be changed or recovered if forgotten [21], violating *U4 Easy-Recovery-from-Loss*. This method also lacks *U1 Memorywise-Effortless* and *U2 Scalable-for-Users*, as users must remember unique passwords for each file. In practice, this leads to weak or reused passwords, undermining the potential *S4 Granular-Protection* benefit of file-level encryption.

Password-based encryption also often fails to provide *S2 Resilient-to-Guessing*. Unlike web authentication, which can throttle login attempts, encrypted files are vulnerable to unthrottled offline brute-force attacks. Researchers have studied how to crack the password of an encrypted PDF using GPUs [5] and tuned software [6]. This research found that nearly any password-based document encryption can be cracked with “little overhead” given enough time and the proper computational resources [5]. While some implementations use strong key derivation functions—such as PBKDF2 or Argon2—and high iterations, which make brute-force guessing nonfeasible, dictionary attacks remain effective due to users’ tendency to choose common, simple passwords.

Password-based encryption can also be applied at the full disk level, which does not provide *S4 Granular-Protection* or *U4 Easy-Recovery-from-Loss* and is typically used for personal device protection instead of sharing documents with others.

Given the usability and security limitations of password-based methods, one may wonder why they are still widely used. It is important to note that password-based encryption performs very well in the deployability category. Bonneau et al. [8] found that passwords remain a dominant web-based authentication scheme largely because no alternative method provides the same or better levels of deployability benefits. The same holds true in this evaluation of document encryption methods. The familiar password-based encryption of Microsoft Word and PDF

documents offers negligible costs (*D1*, *D2*), broad compatibility (*D3*), and wide adoption (*D4*).

Perhaps most importantly, it is one of the few methods that provides a level of the *D6 Guest-Friendly* benefit—the ability for a third party to access shared items without requiring provisioning or unique credentials. While the password must be shared, no user account is needed (thus it partially satisfies *D6*). An example illustrating the importance of this benefit is the United States Department of Justice’s instructions for submitting Claims Collection Litigation Reports. These instructions advise users to create a PDF document, encrypt it with a password, and then to “send the password. . . in a separate email for decryption. . . Never send the decryption password in the same email as the encrypted files” [81]. This guidance highlights the lack of usability inherent in password-based document encryption methods but also demonstrates the need for document protection and the reasoning why password-based file encryption remains widely used in this context: it’s free, it’s interoperable, and it’s simple to use for both the public and government agencies.

4.4.2 Cloud-based encryption

Cloud- or server-based encryption methods (such as MFTs and cloud storage applications) are a second popular document encryption method used today. There are several security and usability benefits that the software-as-a-service (SaaS) model provides. Many of the benefits come from the authentication process functioning at the identity level instead of the individual file level. Often SSO (single sign-on) is used, which can provide the benefit of *S1 Resilient-to-Observation* by enforcing MFA (multi-factor authentication). Access to documents is not confined to a single device, and account recovery provides effective *U4 Easy-Recovery-from-Loss*. Furthermore, cloud-based models typically provide familiar and effective methods for sharing files within or outside of an organization. Cloud-based encryption methods are the only schemes to provide both *U5 Seamless-Sharing* and *D6 Guest-Friendly*, which are frequently valued in enterprise and personal use cases.

A major limitation of cloud-based encryption methods is the lack of *S4 Granular-Protection* and *S3 Resilient-to-Third-Party-Leak*. These security limitations come because the cloud provider handles both encryption and authentication. Once a user’s session is authenticated, all documents they are authorized to access are effectively decrypted. While a vulnerability in any encryption method can lead to a confidentiality breach, managed cloud-based encryption introduces an additional risk: a breach can occur on the provider’s side even if the customer’s system has no vulnerability. Additionally, a supply chain incident affecting the provider can impact all customers using the managed service. This scenario occurred five times between 2021 and 2025 as cyber-criminal groups targeting managed file transfer (MFT) applications discovered vulnerabilities and exfiltrated millions of documents from thousands of customers using the same

platforms [1–3].

Similar to password-based encryption, while there are limitations of cloud-based encryption, there are other benefits that outweigh the limitations in certain use cases. Again, the importance of deployability and shareability is shown to outweigh security and usability benefits in many real-world scenarios.

4.4.3 Passwordless encryption

Passwordless file-level encryption offers strong security benefits relative to other methods, particularly in terms of *S2 Resilient-to-Guessing*, *S3 Resilient-to-Third-Party-Leak*, and *S4 Granular-Protection*, because it relies on cryptographic private keys rather than identity verification or user-generated passwords. However, these security benefits come with notable usability and deployability challenges. Sharing passwordless encrypted documents requires secure key exchange, and without integration into widely used platforms, this process often lacks *U5 Seamless-Sharing* and *D6 Guest-Friendly*. Additionally, recovery from lost keys is difficult or impossible, making *U4 Easy-Recovery-from-Loss* a significant limitation.

Today, using passwordless encryption to provide confidentiality of documents remains uncommon in both enterprise and personal domains due to complex deployment and limited interoperability. However, if barriers to adoption, especially around interoperability and sharing, are addressed, passwordless encryption could offer the strongest overall security of any method evaluated in this framework.

These findings align with evaluations of FIDO2 authentication using the original Bonneau et al. framework. As discussed in Section 2.5.6, Lyastani et al. [59] applied the Bonneau framework to FIDO2 with hardware security keys and found it scored nearly perfectly, with four remaining gaps: *Nothing-to-Carry*, *Easy-Recovery-from-Loss*, *Server-Compatible*, and *Resilience-to-Theft*. Büttner et al. [60] performed a similar comparison of synced versus device-bound passkeys, finding that synced passkeys address portability and recovery but shift security concentration to the passkey provider. Translating to the document encryption context, these gaps map to this framework’s *U4 Easy-Recovery-from-Loss*, *D3 Compatible*, and *D6 Guest-Friendly*. The weaknesses of hardware-bound and synced passkeys are largely complementary: hardware provides no trusted third party while synced provides portability and recovery. If a passwordless document encryption system could support both authenticator types, leveraging the strengths of each, it could address the primary barriers identified in this evaluation. This possibility is explored in Chapter 5.

4.5 Summary of Analysis

Since password-based encryption was introduced in standard document editing tools, innovation in protecting documents has lagged. While digital signatures are commonly used in PDF software to verify the owner or editor of a document (integrity and non-repudiation), protecting the content of a document (confidentiality) often still relies on a simple, fixed

password. The framework presented in this chapter provides a structured benchmark for comparing current and future document encryption methods. The 15 benefits identified serve as design requirements for an ideal system: one that is open-source, passwordless, and integrates with widely used identity providers. The design and implementation of such a system is presented in Chapter 5.

System Design

This chapter presents the design, implementation, and technical evaluation of a passwordless document encryption system. Section 5.1 establishes the design requirements. Sections 5.2 and 5.3 describe the technology selection and system architecture. Section 5.4 walks through the implementation, and Section 5.5 evaluates the system against the design requirements.

5.1 Design Requirements

Based on the analysis of currently available solutions for document encryption and the limitations and gaps identified in Chapter 4, and motivated by the repeated exploitation of systematic weaknesses in existing MFT platforms described in Section 2.1, this section presents the design requirements of an ideal system outlined in research question R2: *How can open-source protocols be used to design a document protection system that is passwordless, non-proprietary, and provides per-file encryption?* In this context, *passwordless* has the meaning of no password or memory aspect is needed for the scheme to work, *non-proprietary* has the meaning of being free, open-source and when files are shared, the receiver doesn't need custom software to view or interact with the file, and *per-file encryption* has the meaning of individual document files are encrypted uniquely and not all accessible at once.

The threat model presented in Section 2.1.4 identified four specific threats that the design must counter: (1) bulk server-side file access, requiring granular per-document encryption without a single shared key; (2) brute-force password cracking post-exfiltration, requiring passwordless key derivation; (3) unauthorized redistribution of exfiltrated files, requiring recipient-bound encryption; and (4) server compromise exposing keys, requiring non-custodial, client-side key derivation where the server never holds private keys. The evaluation framework presented in Chapter 4 produced 15 benefits across three categories—usability, security, and deployability—that an ideal document encryption system should satisfy (see Table 4.1). These 15 benefits encompass the properties necessary to counter the threats identified in Section 2.1.4 and serve as the formal design requirements for the system described in this chapter. One additional property, support for post-quantum cryptographic algorithms and cryptographic agility, is included as a design goal given the evolving threat landscape but was not part of the original evaluation framework.

D4 (Mature) is acknowledged as unachievable for a prototype system and is discussed as a limitation in Chapter 8.

5.2 Technology Selection

The passwordless document encryption system relies on three primary technologies: age encryption, specifically the `typage` TypeScript implementation, for file encryption; W3C's WebAuthn for the authentication ceremony; and FIDO2's CTAP for passkey or security key creation and communication. This section describes each technology and the rationale for its selection.

5.2.1 age Encryption and `typage`

Age is an open-source, modern file encryption tool and format. Initially developed as a Go library, the age specification has been implemented in several programming languages and supports plugins and integrations with several encryption management tools [36]. Age encrypts arbitrary files for one or multiple recipients, where each recipient can independently decrypt the file to access the original plaintext. An age file is essentially a bundle made of two parts: a header and an encrypted payload. The header carries a 128-bit symmetric file key, generated from a cryptographically secure random source and unique to each file, encrypted (or “wrapped”) independently for each designated recipient [82]. This wrapped file key is sent along with the encrypted payload so that it can be unwrapped by one or more of the corresponding identities.

Age was selected for this system for several reasons. First, it is open-source software licensed under BSD-3-Clause for free use, distribution, and modification [36] satisfying the non-proprietary requirement (D5) and ensuring no licensing fee compromises negligible cost per user (D1). The age project is fairly mature (D4) with over 22,000 stars on GitHub at the time of writing and an active community of contributors [36]. Second, age supports multi-recipient encryption natively: a file can be encrypted to multiple recipients, each of whom can decrypt independently using their own key material. This directly enables recipient-bound encryption (S4) and seamless sharing (U5). Third, age provides cryptographic agility through its support for multiple recipient types and its plugin architecture. As of version 1.3.0, age includes native support for hybrid post-quantum recipients using ML-KEM-768-X25519, providing resistance against future quantum computing attacks [36, 37]. Fourth, age's design keeps the encryption format simple and auditable compared to more complex formats such as PGP.

`Typage` is the official TypeScript implementation of age file encryption, available as an npm package or as a bundled JavaScript file [83]. `Typage` depends only on the noble cryptography libraries and uses the Web Crypto API when available. `Typage` was selected for the system implementation because TypeScript interfaces directly with the WebAuthn APIs available in the browser, and because a browser-based architecture satisfies several deployability requirements: users interact with a familiar

web interface (U3) rather than downloading standalone software (D3, D6), no client-side software installation or updates are required, and the system can be updated centrally in a SaaS model.

5.2.2 WebAuthn PRF Extension

As discussed in Section 2.5.4, the WebAuthn PRF extension enables a passkey to serve not only as a login credential but also as a source for deriving symmetric encryption keys without passwords or server-stored secrets. In the designed system, the PRF extension is the critical bridge between FIDO2 authentication and age file encryption, enabling the system to derive encryption keys directly from a WebAuthn ceremony rather than from a user-supplied password.

Typage supports this model by interfacing with the WebAuthn API. When a user encrypts a file, typage triggers a WebAuthn ceremony in the browser. The browser prompts the user to select a passkey associated with the relying party ID (the website). During that WebAuthn ceremony, the PRF extension takes the authenticator's secret and the relying party ID and derives a deterministic symmetric key. That derived key is then used as the age file key to encrypt the file. To decrypt, the same process runs in reverse: the same passkey produces the same PRF output, yielding the same key, and the file decrypts. The identity string returned by the credential creation function can be provided at encryption or decryption time to ensure the user selects the correct passkey [83].

This architecture delivers several of the design requirements identified in Section 5.1. The system is passwordless: the user never types or remembers a password but instead approves a biometric or passkey prompt (U1). It is non-custodial: the key is derived locally during the WebAuthn ceremony and no server sees it (S3). It is phishing-resistant: the derived key is scoped to the relying party ID, so a different domain produces a different key (S1). It supports both synced and hardware-bound authenticators: users can use synced passkeys through a passkey provider like iCloud Keychain, Google Password Manager, or 1Password for portability and recovery, or can choose hardware-bound keys such as a YubiKey for stronger security guarantees. This flexibility directly addresses the complementary strengths identified by Lyastani et al. [59] and Büttner et al. [60] as discussed in Sections 2.5.6 and 4.4.3: hardware-bound credentials provide strong security without a trusted third party while synced credentials provide portability and recovery (U4). By supporting both form factors, the system offers the strengths of each and enables each user to choose which mode is better for their specific use case.

5.2.3 OpenTDF

The system incorporates elements of the Open Trusted Data Format (OpenTDF) specification as scaffolding for future attribute-based access control (ABAC) capabilities. OpenTDF defines a structure consisting of a metadata manifest and an encrypted payload, where the manifest holds

instructions for decryption and access control [39]. This architecture resembles the age header and encrypted payload model but expands it by including access control policies aligned with the NIST model for ABAC [84].

The designed system's encrypted bundle format combines the age header with an OpenTDF-style manifest field, both preceding the encrypted data payload. The age header carries the wrapped file key for each recipient as described in Section 5.2.1, while the manifest provides a structural placeholder for access control metadata such as recipient policies and expiration rules which would enable more advanced granular protection (S4). In the current implementation, the OpenTDF integration is limited to this structural scaffolding; a more complete ABAC implementation where the policy travels with the file is discussed as future work in Chapter 8.

5.3 System Architecture

The system architecture is presented through four diagrams that progress from foundational to extended. The first presents the offline, client-only model (Figure E.1): the basic building blocks of two users exchanging an encrypted file. The second shows the cloud/server-based model (Figure 5.1), which extends the offline architecture to include a server that hosts the encrypted bundle and enables updating contents, permissions, and sharing. The third and fourth diagrams (Figures E.2 and E.3) depict two additional user actions within the cloud/server-based model: requesting access to a file (as recipient) and sharing access via a link (as sender).

Of these four, the cloud/server-based model was fully implemented and served as the basis for the user study described in Chapter 6. The offline model represents the foundational building blocks and is feasible but was not implemented as a standalone mode (Figure E.1). The request access and share access link flows are presented as theoretical extensions to illustrate how the architecture could support these interactions; structural scaffolding for them exists in the codebase (e.g., a share link button) but they were not fully implemented (Figures E.2 and E.3). The user study focused on the core process of encrypting, decrypting, and sharing documents from the perspective of the sender rather than the full breadth of access management features and the receiving perspective. This was chosen in order to evaluate user acceptance and usability of the most fundamental interactions first.

The architecture diagrams build on the fundamentals of symmetric and asymmetric (public-private key) encryption. Each participant—Alice, Bob, and any other approved recipient—holds their own public-private key pair: the public key is shared freely so others can encrypt to them and identify them as an approved recipient, while the corresponding private key is kept secret and is used to prove ownership and to decrypt. The following terms are used throughout:

Alice: The first user who has the file to encrypt and transmit.

Bob: The second user who does not begin with the file but will receive or request access to it.

Private owner key: Alice's private key, used to establish ownership of the file and to authorize permission changes. It is distinct from the private keys of other users who will access the file but did not perform the encryption.

Public key(s): The public keys shared by Bob and Alice's other approved recipients. Each recipient holds a public-private key pair; the public key is shared so the file key can be wrapped to them, and they later prove access by demonstrating control of the corresponding private key.

Encrypted bundle: The encrypted file containing the encryption informational header and the ciphertext. Called a bundle because the single file contains both the header metadata about the encryption and the actual encrypted data, drawing from the Open Trusted Data Format structure described in Section 5.2.3.

5.3.1 Offline/Client-Only Model

The simplest expression of the architecture is the offline, client-only model (Figure E.1) in which two users exchange an encrypted file with no server involved. While this model primarily serves as the foundation for the cloud/server-based implementation, it has standalone applications in airgapped or self-hosted environments where system constraints may require deploying passwordless document encryption independent of any server or cloud access. This architecture also lends itself to containerization or microservice deployment. In the offline model, Alice creates a private owner key via WebAuthn PRF, specifies which public keys are valid recipients, bundles the encrypted file with the owner key reference and approved public key list, and transmits the bundle to Bob through any file transfer mechanism. Bob then verifies his identity by demonstrating he holds a private key matching one of the approved public keys, and decryption proceeds. The primary limitation is that once the bundle is sent, the owner cannot update permissions: the approved keys at the time of encryption are fixed.

5.3.2 Cloud/Server-Based Model

The cloud/server-based model (Figure 5.1) extends the offline architecture by introducing a server that hosts the latest encrypted bundle, enabling the owner to update permissions and file contents without redistributing the bundle.

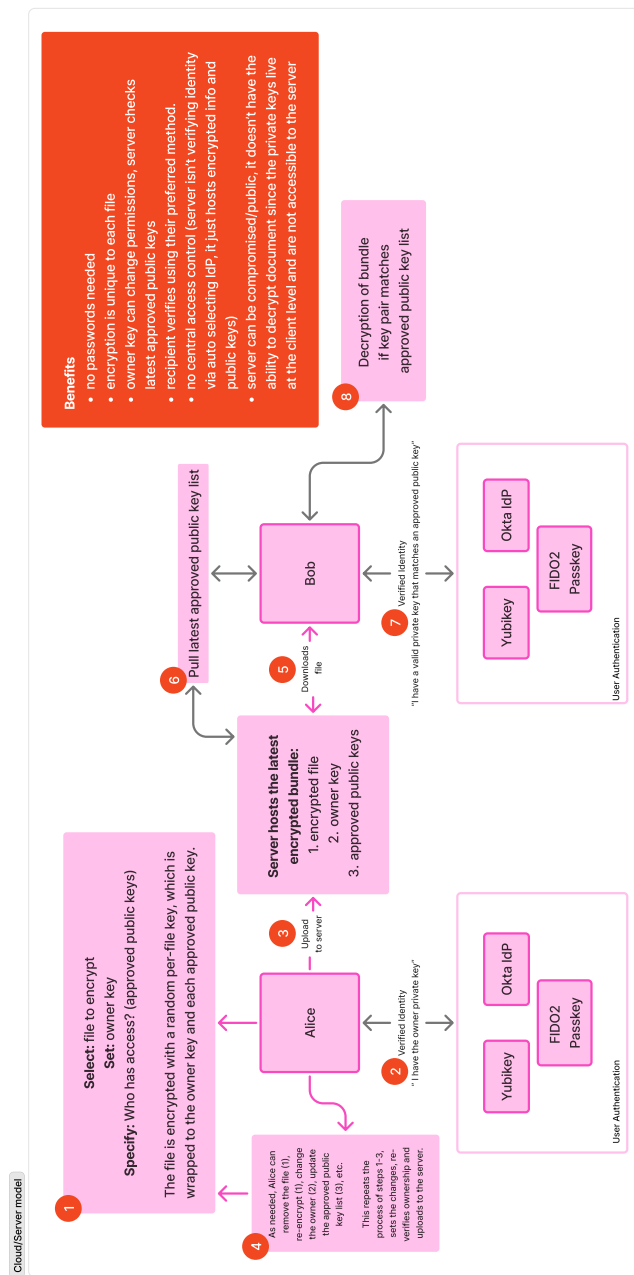


Figure 5.1: Cloud/server-based architecture. Alice generates the private owner key and uploads the encrypted bundle to the server, then can update permissions or contents at any time. Bob downloads the bundle, pulls the latest approved public key list, and verifies his identity to decrypt.

The flow begins with Alice setting the private owner key and specifying which public keys have access to the file (step 1). The private owner key is generated through WebAuthn PRF via a FIDO2 passkey or other authenticator, which could be managed through a password manager, identity provider, or hardware token such as a YubiKey. By specifying who has access, Alice determines which public keys will be

valid to decrypt the file. In step 2, Alice verifies her identity to demonstrate ownership of the private owner key. This may coincide with key creation—for example, a new passkey is created to serve as the owner key, or a YubiKey is tapped—or it may involve presenting an existing credential. In step 3, the encrypted bundle is uploaded to the server. Critically, the server only ever holds already-encrypted ciphertext and cannot decrypt the document because private keys remain at the client level and are not transmitted to or accessible by the server.

Step 4 introduces the key advantage of the server-based model over the offline architecture: Alice can update the approved public key list, remove the file, re-encrypt with a new owner key, or change other permissions at any time by repeating the process of steps 1–3 and uploading the updated bundle. In step 5, Bob downloads the encrypted bundle from the server. In step 6, Bob pulls the latest approved public key list. In step 7, Bob verifies his identity by demonstrating he holds a valid private key matching an approved public key. In step 8, decryption of the bundle proceeds if Bob's key pair matches an entry in the current approved public key list.

This model retains the core benefits of the offline architecture—no passwords, per-file encryption, recipient verification using the recipient's preferred authenticator—while adding the ability for the owner to modify permissions after sharing. The server hosts encrypted data and public key lists but has no ability to decrypt documents, preserving the non-custodial property. Even if the server is compromised, the attacker obtains only ciphertext and public keys, not the private keys needed for decryption.

5.3.3 Request Access and Share Access Link Flows

Two additional flows extend the cloud/server-based model to support common document sharing interactions: requesting access as a recipient and sharing access via a link as a sender. These flows are presented as architectural extensions (Figures E.2 and E.3).

The request access flow (Figure E.2) addresses the scenario where Bob wants to access a file Alice has already uploaded. Bob navigates to the server, requests access to a specific file, and provides his public key. The server forwards the request to Alice, who reviews and approves or denies it after verifying her identity as the owner. If granted, the server updates the approved key list and Bob can proceed to download and decrypt the file.

The share access link flow (Figure E.3) addresses the scenario where Alice proactively shares a file with Bob via a copied link, an interaction pattern familiar from cloud file sharing systems such as Dropbox®, Google Drive, SharePoint, and Box. Alice generates a share link which is sent to Bob by email or another communication channel. When Bob opens the link, the server prompts him to provide a public key to associate with his identity, after which Alice can approve the association and Bob gains access.

5.4 System Implementation Walkthrough

The system is implemented as a Next.js™ web application using React™ 19 and TypeScript, with age encryption provided by the typage library, credential storage in IndexedDB, and an optional Supabase™ backend for link sharing. The complete source code is available as an open-source repository [85]. This section walks through the implementation organized by user-facing workflow steps, corresponding to the guided workflow presented in the application interface.

File Upload.

The application presents a single interface for both encryption and decryption (Figure 5.2). The user uploads any file to encrypt it, or uploads a .rico file to decrypt it. The system detects the file type automatically and adjusts the workflow accordingly: encryption proceeds through a five-step flow (Upload, Identity, Recipients, Share, Done) while decryption uses a shortened three-step flow (Upload, Identity, Done).

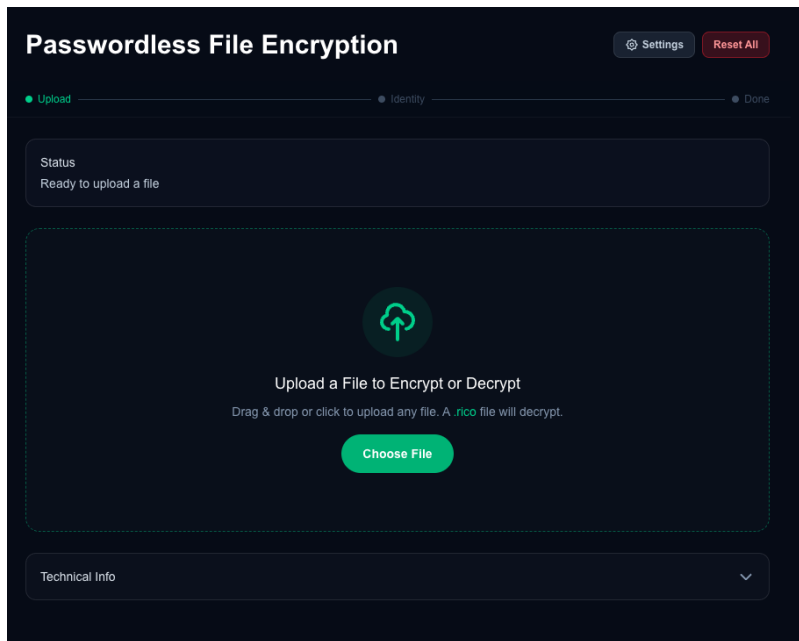


Figure 5.2: File upload interface of the application.

Identity Verification (Encryption).

For encryption, the user verifies their identity by creating or selecting a passkey credential (Figure 5.3). The primary path presents a “New Passkey” option where the user sets a name for the credential (defaulted to the uploaded file’s filename) and clicks “Create & Encrypt,” which triggers a WebAuthn ceremony in the browser to create a credential (passkey or security key). Upon completion a second WebAuthn ceremony is immediately begun which uses the newly created credential to encrypt the file.

The screenshot displays the 'Passwordless File Encryption' application interface. At the top, there's a title bar with 'Settings' and 'Reset All' buttons. Below it, a progress bar shows five steps: 'Upload', 'Identity' (current), 'Recipients', 'Share', and 'Done'. The main content area is divided into sections. The first section, 'Status', shows 'Ready to encrypt' and a file icon labeled 'appenB.txt'. The second section, 'Verify Your Identity', contains three options: 1. 'New Passkey' with a text input field containing 'appenB.txt' and a green 'Create & Encrypt' button. 2. 'Use existing' which is expanded to show an 'Existing Credential' section with a card for 'Code_Generated_Image (1)' (Passkey · May 18, 01:41 PM) and a 'Use Password Manager' section with a dropdown menu showing 'Google, iCloud, Bitwarden...'. At the bottom left, there's a 'Back to File Upload' link, and at the bottom right, a 'Technical Info' dropdown menu.

Figure 5.3: Identity verification step with new passkey option and create and encrypt action.

The credential creation prompt comes from the user's default platform or third-party passkey provider (Figure 5.4). The credential creation flow, including PRF detection and fallback handling, is detailed in the sequence diagram (Figure E.4).

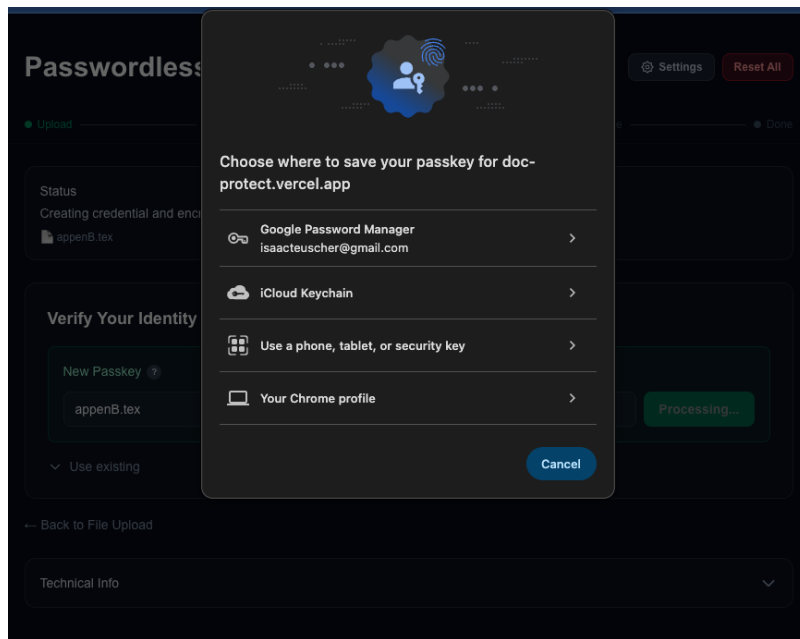


Figure 5.4: Save passkey prompts presented by the user's passkey provider during credential creation.

Existing Credential.

An expandable “Use existing” section (Figure 5.5) provides two additional paths: selecting a previously created credential stored in IndexedDB, or using a passkey from an external password manager such as iCloud Keychain, Google Password Manager, or Bitwarden. Each stored credential displays its name and creation date, and can be deleted from IndexedDB.

The screenshot shows a web application titled "Passwordless File Encryption". At the top right are "Settings" and "Reset All" buttons. A progress bar below the title has five steps: "Upload", "Identity", "Recipients", "Share", and "Done", with "Identity" currently selected. The main content area is divided into sections. The first section, "Status", shows a message "Will use credential from password manager during decryption" and a file icon labeled "Renters Insurance Quote _ USAA.pdf". The second section, "Verify Your Identity", contains three options: 1. "New Passkey" with a text input field containing "appenB.tex" and a "Create & Encrypt" button. 2. "Use existing" (expanded), which shows an "Existing Credential" list with one item: "appenB.tex" (Passkey, May 20, 11:17 PM) with a delete icon. 3. "Use Password Manager" with a text input field containing "Google, iCloud, Bitwarden...". At the bottom of the "Verify Your Identity" section is a large green "Encrypt File →" button. A "← Back to File Upload" link is at the very bottom left.

Figure 5.5: Use existing panel for selecting a previously created or third-party credential.

Recipients.

After encryption, the user can optionally add recipients by email address (Figure 5.6). Recipients can be added individually or as a comma-separated list. This step can also be skipped entirely for single-user encryption.

The screenshot shows a web interface for 'Passwordless File Encryption'. At the top, there's a title bar with 'Settings' and 'Reset All' buttons. Below it is a progress bar with five steps: 'Upload', 'Identity', 'Recipients' (the current step, highlighted in green), 'Share', and 'Done'. The main content area has a 'Status' box stating 'File encrypted. Add recipients or proceed to sharing.' Below this is a section titled 'Add Recipients (Optional)' with the question 'Who should be able to decrypt this file?'. It features a text input field containing 'recipient@example.com, another@example.com' and a green 'Add' button. A 'Skip Recipients' button is also present. At the bottom, there's a 'Technical Info' section with a downward arrow.

Figure 5.6: Add recipients step of the encryption workflow.

Sharing.

The sharing step (Figure 5.7) presents three options for distributing the encrypted file: downloading the bundle directly for manual sharing via email or messaging, uploading to cloud storage (Google Drive), or generating a shareable link via the Supabase backend. The download option produces a `.rico` file, which is a ZIP archive containing a `manifest.json` (metadata, policy, and recipient list) and a `0.payload` file (the age-encrypted data). The cloud storage and shareable link options create realistic-looking links but do not actually integrate with those file storage services to upload the bundle as the focus for this system was to develop a proof-of-concept that is realistic enough for user acceptance and usability testing of the core steps.



Figure 5.7: Share options presented after encryption.

Decryption.

When a .rico file is uploaded, the interface presents the decryption path (Figure 5.8). The user selects a stored credential or uses their password manager's passkey picker, then clicks "Decrypt File." The system parses the bundle, extracts the manifest and encrypted payload, triggers a WebAuthn ceremony to derive the decryption key via PRF, and presents the decrypted file for download.

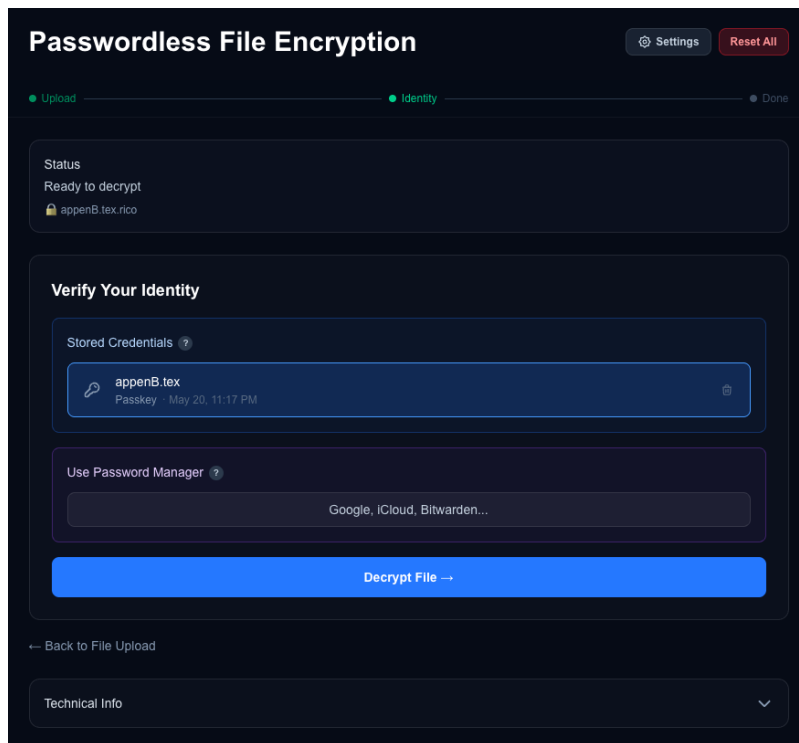


Figure 5.8: Decryption identity step with decrypt file action.

Settings.

A settings panel (Figure 5.9) allows the user to select between three encryption algorithms: WebAuthn Passkey (PRF) as the default, Post-Quantum Hybrid (ML-KEM-768 + X25519), or Classic (X25519). This panel is collapsed by default.

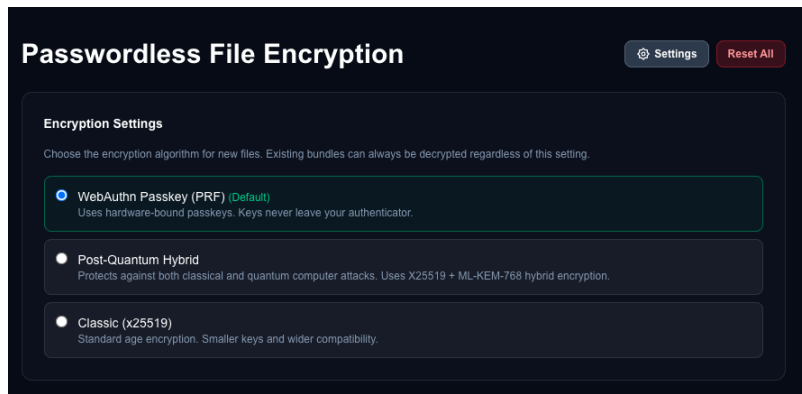


Figure 5.9: Settings panel with encryption algorithm selection.

Technical Information.

An expandable “Technical Info” panel (Figure 5.10) displays the current encryption algorithm setting, PRF support status for the platform, stored credentials with their type and PRF capability, and the current workflow state. This panel was included for transparency during the user study and for debugging during development.



Figure 5.10: Technical info panel for transparency and debugging.

Bundle Format. The `.rico` bundle format is a ZIP archive containing two files: `manifest.json`, which stores file metadata, encryption algorithm, recipient list, and an OpenTDF-inspired policy object with ABAC scaffolding (see Section 5.2.3); and `0.payload`, which contains the age-encrypted binary data. The manifest tracks the encryption algorithm used (age, age-pq, age-x25519, or age-fallback), enabling the system to select the correct decryption path automatically.

Technology Stack. The implementation uses Next.js 16 as the application framework, the age-encryption npm package (typage) for all encryption operations, IndexedDB via localForage for local credential storage, JSZip for bundle creation and parsing, and Playwright™ for end-to-end testing. The application requires a modern browser with WebAuthn support. PRF is supported on macOS, iOS, Android, and Chrome OS platform authenticators, as well as YubiKey 5+ hardware tokens; Windows Hello added hmac-secret support in February 2026. A PBKDF2 fallback mode is provided for platforms without PRF support. The code was developed with assistance from Claude Code (Opus 4.6 AI model).

Table 5.1: Evaluation of Implemented System Against Design Requirements

	Benefit	Rating	Justification
U1	Memorywise-Effortless	● Full	Users authenticate via passkey or security key (biometric or hardware tap). No passwords or secrets to remember.
U2	Scalable-for-Users	● Full	Users' cognitive load does not increase with additional documents as individual secrets do not need to be remembered.
U3	Easy-to-Learn	● Full	The guided step-by-step workflow mirrors familiar web interactions. Evaluated empirically in Chapter 6.
U4	Easy-Recovery-from-Loss	● Partial	Synced passkeys (e.g. iCloud, Google, 1Password) provide recovery through cloud backup. Hardware-bound credentials have no recovery path. Supporting both authenticator types gives users a choice based on their risk tolerance.
U5	Seamless-Sharing	● Partial	Direct download is implemented. Link sharing and the full recipient-initiated access request flow is scaffolded but not fully implemented.
D1	Negligible-Cost-per-User	● Full	All components are open-source and free. No per-user licensing fees.
D2	Negligible-IT-Support-Cost	● Full	Browser-based SaaS model requires no client installation, updates, or IT provisioning.
D3	Compatible	● Partial	Runs in any modern browser (Chrome 108+, Edge 108+, Safari 16.4+). PRF support depends on both the platform authenticator and operating system; Windows Hello added support in February 2026 and a PBKDF2 fallback is provided for unsupported platforms.
D4	Mature	○ Not satisfied	The current system is a research prototype (v0.1). Maturity can only come as real-world deployment scale over time. Acknowledged as a limitation.
D5	Non-Proprietary	● Full	age is BSD-3-Clause licensed. WebAuthn and FIDO2 are open W3C/FIDO Alliance standards. The codebase is open-source.
D6	Guest-Friendly	● Partial	Recipients can decrypt via their own passkey without provisioned accounts. The share link flow enabling access without prior credentials is scaffolded but not fully implemented.
S1	Resilient-to-Observation	● Full	No passwords to observe. The PRF-derived key exists only during the WebAuthn ceremony and is not displayed or typed. Phishing resistant through relying party bound credentials.
S2	Resilient-to-Guessing	● Full	The encryption key is derived from the authenticator's internal secret via PRF, not from a user-chosen password. Offline brute-force and dictionary attacks are not feasible.
S3	Resilient-to-Third-Party-Leak	● Full	Encryption keys are derived client-side and never leave the browser. The server only sees already-encrypted ciphertext. Server compromise yields no plaintext or key material.
S4	Granular-Protection	● Full	Each document is encrypted with a unique file key. Compromise of one document does not grant access to others.

5.5 Evaluation Against Requirements

This section evaluates the implemented system against the 15 design requirements derived from the Chapter 4 evaluation framework. Table 5.1 summarizes the evaluation, rating each benefit as fully satisfied, partially satisfied, or not satisfied, with justification.

The system in its current state fully satisfies 10 of the 15 benefits, partially satisfies 4, and does not satisfy 1 (*D4 Mature*). The four partial ratings reflect current state constraints rather than architectural limitations. Two partial ratings (*U5 Seamless-Sharing* and *D6 Guest-Friendly*) come from the proof-of-concept nature of the research reflecting the scoping decision to prioritize the core encryption workflow over the full access management feature set. These benefits could be fully satisfied with additional development. *D3 Compatible* reflects the current state of PRF platform support which is maturing rapidly. *U4 Easy-Recovery-from-Loss* depends on the user's choice of authenticator type and is rated as partial since it maintains the tradeoff decision between device-bound and synced passkeys.

Addressing the FIDO2 Gaps. As discussed in Sections 2.5.6 and 4.4.3, Lyastani et al. [59] identified four remaining gaps when applying FIDO2 hardware tokens to the Bonneau framework: Nothing-to-Carry, Easy-Recovery-from-Loss, Server-Compatible, and Resilience-to-Theft. Büttner et al. [60] found that synced passkeys address portability and recovery but introduce third-party trust in the passkey provider. The designed system addresses these gaps by supporting both authenticator types. Synced passkeys provide Nothing-to-Carry (the credential is available on any device with the passkey provider), Easy-Recovery-from-Loss (backup and restore through the provider), and broader compatibility. Hardware-bound credentials provide no trusted third party (Resilient-to-Third-Party-Leak) and tamper resistance. By not mandating a single authenticator type, the system allows users to select the tradeoff appropriate to their threat model.

Threat Model Coverage. Evaluating against the adversary threat model from Section 2.1.4, the system counters each identified threat. Bulk server-side file access yields only encrypted bundles, each with a unique key (*S4 Granular-Protection*). Brute-force cracking post-exfiltration is not feasible because keys are derived from authenticator secrets, not passwords (*S2 Resilient-to-Guessing*). Unauthorized redistribution is constrained by recipient-bound encryption where only designated identities can unwrap the file key (*S3 Resilient-to-Third-Party-Leak*). Server compromise exposes no key material because all key derivation occurs client-side (*S3 Resilient-to-Third-Party-Leak*).

In short, the designed and implemented system presents a near-ideal document encryption system with a few benefits limited by the prototype's current scope and maturity. The system presented would render exfiltrated data unreadable in the MFT mass-exfiltration scenarios

described in Section 2.1. The implemented system is passwordless and non-custodial, performs all encryption locally in the browser, derives phishing-resistant keys that can be anchored in hardware, and supports post-quantum cryptographic algorithms.

User Study Methods

6.1 Hypothesis

This chapter addresses the final research question: *R3: What is the user acceptance and usability of a passwordless document encryption system?* In order to assess the usability and user acceptance of the passwordless document encryption system we developed, we conducted an IRB-approved human subjects research study. We hypothesized that using the passwordless approach to encrypt and share documents would result in an easier and more enjoyable experience for participants when compared to using a traditional password-based encryption approach (such as is used by Adobe Acrobat or Microsoft Word) for protecting sensitive documents. Specifically, our research study hypothesis was as follows:

- Passwordless document encryption using modern authentication (passkeys, biometrics, YubiKeys) will provide a superior sense of security, greater usability, and a perceived better level of deployability compared to traditional password-based encryption.
- Improved usability of document encryption tools will lead to increased adoption and a sense of stronger security practices.
- Users will trust and prefer passwordless encryption methods over traditional password-based approaches.

In short, our objective was to assess user acceptance and usability through comparative testing of the passwordless and password-based document encryption process.

6.2 Procedure

The study design was modeled after two similar FIDO2 usability studies [59, 61]. The IRB-approved study was a within-subjects lab experiment where users performed the tasks of encryption, decryption, and sharing on two similar online platforms: one password-based document encryption tool and one passwordless document encryption tool. Participants responded to the System Usability Scale (SUS) and Van der Laan User Acceptance Scale after using each system and then gave comments about their experience in response to semi-structured interview questions. An overview of the study procedure is shown in Figure 6.1.

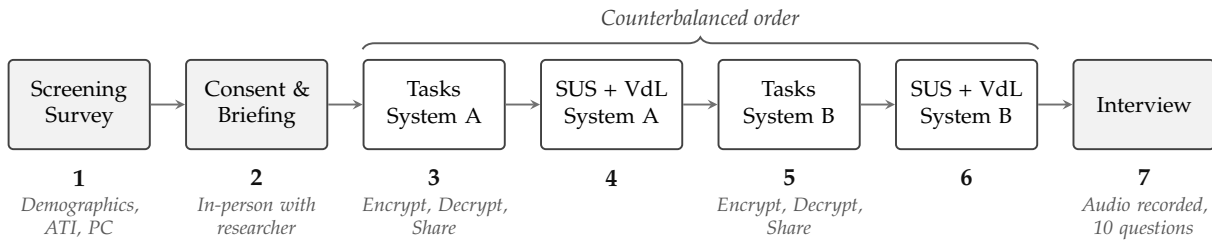


Figure 6.1: Overview of the study procedure.

Participants first completed a screening survey, consent acknowledgement, and responded to background questions to understand their basic demographics, familiarity with sensitive documents, and experience with passwordless authentication (What is your age?, What is your job/industry?, How often do you work with electronic documents that contain sensitive or controlled information?, Have you had experience with passwordless authentication?).

Additionally, participants completed the Affinity for Technology Interaction (ATI) Scale and the Privacy Concerns (PC) Scale (described in Sections 6.4.1 and 6.4.2). These factors—technical background, affinity for technology, and privacy concerns—have been shown to influence user perceptions of new technologies [59, 61].

After completing the screening, consent, and background questions, participants then met in-person with a researcher who asked them to imagine themselves in a corporate environment with sensitive information. Using scenario-based storytelling and a controlled lab environment gave narrative context and helped subjects be in the mindset of “work” without introducing the risk of using real sensitive files of the participant. Participants used their own laptop computer and/or mobile phone (bring-your-own-device, BYOD) so their browser, password managers, browser extensions, and operating system settings would feel accurate to their typical tools and configurations.

Users often struggle with FIDO2 because they don’t understand it. As part of the study procedures we asked about the participant’s experience with multi-factor authentication and included an optional short video explaining how passkeys work. This aimed to help reduce the possibility of measuring the lack of knowledge about passwordless methods rather than the usability of the passwordless system which would be present if users did not understand the foundational concepts or were confused about it. The researcher answered basic clarifying questions prior to beginning the system evaluations.

The study was a counterbalanced within-subjects lab experiment where each participant used and evaluated both systems. The two systems were the Adobe Acrobat Online Document Encryption website (available at: www.adobe.com/acrobat/online/password-protect-pdf.html; see Figure E.5 in Appendix E) and the passwordless document encryption tool designed and developed during this research which was described in Chapter 5 (available at: <https://doc-protect.vercel.app>).

Both systems were accessed by the participants through their web browser on their laptop computer or mobile device. All sessions were conducted in-person either individually with a researcher or in small group sessions (2–5 participants together). Each participant was randomly assigned an order for which platform to evaluate first. This was done in an effort to reduce learning bias.

The set of tasks was nearly identical for both systems and consisted of three steps: encrypt a file, decrypt the file, share the file. The files were shared with the researcher conducting the study session so that the password could be communicated directly as needed. The complete task instructions provided to participants for each system are included in Appendix C.

After completing each task set on a system, the participant would fill out the SUS and Van der Laan scales to measure usability and user acceptance of the system. These were presented as multiple choice questions in a Qualtrics™ survey. Once the scales were completed for the first system participants would then continue to the next system where they would complete the tasks and then respond to the same scales for the second system they used.

Once each participant completed the tasks on both systems and responded to the SUS and VdL scales for each system, the researcher would confirm consent to begin audio-recording and then record the participant's responses to semi-structured interview questions. The 10 interview questions used are included in Appendix C. In total, each participant spent 35–45 minutes, consisting of 5–10 minutes on the screening, consent, and background, 20–25 minutes using and evaluating the two systems, and 5–10 minutes responding to the interview questions.

The research study was presented to the University Institutional Review Board (IRB) which reviewed the study plan and concluded that the study was exempt from full review as subjects were de-identified, data protected, and the study posed minimal to no risk to subjects.^a

^aBYU IRB number 2026-028.

6.3 Participants

A sample of 21 participants was selected as appropriate for an initial exploratory study combining quantitative scales with qualitative interviews. A within-subjects design was chosen to maximize statistical power given the sample size ($N=21$), as each participant evaluated both systems and served as their own control. While a between-subjects design (where participants only see one method, not both) would help avoid contrast effects (where users judge a new technology by comparing it to a familiar one rather than on its own merits) this was not feasible with this sample size. To mitigate ordering and learning effects, the study used counterbalanced assignment: participants were randomly assigned to complete the password-based tasks first or the passwordless tasks first, so that any learning or fatigue effects were distributed evenly across conditions. This meant each user had a random chance of first seeing the passwordless system or first seeing the password-based method.

Participants were recruited through personal contact, word of mouth, classroom announcements (including digital announcements), social media (e.g., LinkedIn®, Facebook), and flyers. The recruitment materials are attached in Appendix B.

Participants were screened to identify adults over 18 who were able to meet in-person for the study, with a variety of ages, education status, and computer science backgrounds. In the Qualtrics screening survey one question asked about age (How old (in years) are you?) and automatically screened out individuals who were under 18. Another question in the Qualtrics survey asked if participants were able and willing to meet in person for the research study. No vulnerable populations were involved in the research study. No compensation was provided. All research activities were performed in English.

Table 6.1: Participant Demographics

Variable	Sample (N = 21)
Gender	
Male	76.2% (16)
Female	23.8% (5)
Age	$M = 29.2, SD = 11.7$
18–24	38.1% (8)
25–34	47.6% (10)
35–44	0.0% (0)
45–54	4.8% (1)
55–64	9.5% (2)
Education	
High school graduate	4.8% (1)
Some college	19.0% (4)
Bachelor's degree	66.7% (14)
Master's degree	4.8% (1)
Doctorate	4.8% (1)
Technical background	
Yes	71.4% (15)
No	28.6% (6)
ATI (1–6; $\alpha = .893$)	$M = 4.11, SD = 0.91$
Privacy Concerns (1–7; $\alpha = .803$)	$M = 5.58, SD = 1.01$

Note: ATI = Affinity for Technology Interaction (Franke et al., 2019); higher scores indicate greater technology affinity. Privacy Concerns Scale (Langer, König & Fitili, 2018); higher scores indicate greater concern about data privacy. Technical background = self-reported computer science or cybersecurity education or professional experience.

The demographic profile of the participants (N=21) is summarized in Table 6.1. The sample skewed heavily male (76.2%) and was relatively

young ($M = 29.2$, $SD = 11.7$). A large majority of the participants (71.4%) possessed a formal technical background (e.g., university study or professional experience in Computer Science or Cybersecurity).

Each participant was assigned a unique ID (e.g., P01, P02) which was not derived from any personal information. This unique ID was used in place of any personally identifying information for data storage and analysis. Participant IDs are non-sequential due to the exclusion of pilot testers and incomplete responses during data collection.

6.4 Instruments

A mixed-methods process combining quantitative scales and qualitative interview questions was used to assess the factors in this study. Prior to the usability session, each participant completed the Privacy Concerns (PC) Scale and Affinity for Technology Interaction (ATI) Scale. During the session, each participant completed the System Usability Scale (SUS) and the Van der Laan System Acceptance Scale (VdL) for each of the two encryption methods. These instruments were used to determine scores for the usability and acceptance of the two systems and understand which factors impacted user perceptions. At the conclusion of the session, qualitative responses were gathered by an audio-recorded semi-structured interview (5–10 minutes, 10 questions). Together, these instruments captured quantitative and qualitative data during the experiment.

6.4.1 Privacy Concerns Scale (PC)

The Privacy Concerns Scale [75] is a four-item instrument that measures an individual's general concerns about whether novel technologies threaten personal privacy. Because document encryption is a domain where privacy sensitivity may influence user perceptions, this scale was included to measure and observe the potential impact of privacy concern as a covariate. The scale was developed by Langer et al. [75] in a study examining reactions to novel technology and has since been used in multiple passwordless authentication usability studies, including Lyastani et al. [59], Würsching et al. [61], and Kupris and Schreck [62]. Each participant completed the scale once prior to the study session.

6.4.2 Affinity for Technology Interaction Scale (ATI)

The Affinity for Technology Interaction (ATI) Scale [74] is a nine-item instrument that measures how much an individual likes to engage with technical systems. Because an interest in technology can bias user perceptions and usability ratings of novel systems, the ATI was included to measure and account for this factor in the analysis. The scale has been independently validated with excellent reliability ($\omega = .90$) and construct validity [86]. ATI is established in FIDO2 usability research; Kupris and Schreck [62] found it to be a significant predictor of usability in their lab study on passkeys. Each participant completed the ATI once prior to the study session.

6.4.3 System Usability Scale (SUS)

The System Usability Scale (SUS) is an industry-standard, validated instrument used to measure the perceived usability of a system [72]. It consists of 10 items and produces a single overall unit of measure on a 0–100 scale, enabling comparison against established benchmarks (see Figure 6.2).

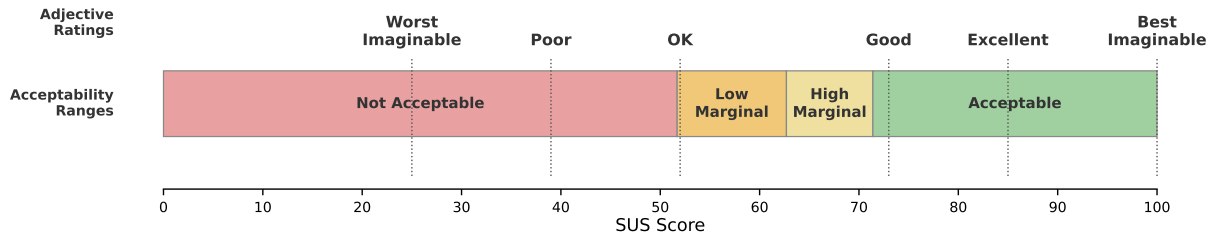


Figure 6.2: SUS score interpretation framework showing adjective ratings and acceptability ranges. Adapted from Bangor, Kortum, and Miller [87].

The scores of individual questions within the SUS are not meant to be considered or evaluated individually as the SUS calculations work together to produce a single composite score of the overall system usability [72]. The SUS was selected for its simplicity, broad adoption, and well-established validity. Reliability analyses have consistently reported coefficient alphas at or above .90 [88–90], and the scale has been widely adopted across both industry and academic research [88]. In this study, each participant completed the SUS once for the password-based method and once for the passwordless method, allowing a within-subjects comparison of perceived usability.

6.4.4 Van der Laan System Acceptance Scale (VdL)

The Van der Laan System Acceptance Scale [73] is a nine-item instrument that measures user acceptance of new technologies. Each item is rated on a five-point scale. The scale has traditionally been described as comprising two subscales—usefulness and satisfaction—though subsequent factor analyses have debated this structure; for example, Schmid [91] found evidence for a one-factor solution using Bayesian exploratory factor analysis. While most commonly used in transportation research, the scale has been applied in technology usability studies as a simple and efficient measure of acceptance. In this study, participants completed the Van der Laan scale for each encryption method to compare acceptance between the password-based and passwordless approaches.

6.4.5 Semi-Structured Interviews

At the conclusion of each study session, participants responded to semi-structured interview questions. Ten open-ended questions were used to gather feedback on their experience using each of the encryption methods, their current practices with sensitive documents, their willingness to adopt the passwordless method, as well as suggestions for improvement.

and the advantages or disadvantages they perceived in each method. The full interview protocol is included in Appendix C. Interviews were conducted individually or in small groups (two to five participants) depending on the session.

6.5 Data Processing

Responses were collected through Qualtrics, which recorded each participant's raw Likert-scale responses for both systems. The survey was structured with two blocks: the first block captured SUS (10 items, 1–5 scale) and VdL (9 items, 1–5 semantic differential) responses for whichever system the participant used first, and the second block captured the same instruments for the second system. A data field recorded the counterbalanced presentation order, enabling the responses to be correctly assigned to the password-based or passwordless condition regardless of which was administered first.

SUS scores were computed following Brooke's (1996) standard procedure: for odd-numbered items, the score contribution is the scale position minus 1; for even-numbered items, the contribution is 5 minus the scale position. The sum of the 10 item contributions is multiplied by 2.5 to produce a score on a 0–100 scale. Van der Laan scores were converted from the raw 1–5 Likert responses to the standard –2 to +2 scale, with polarity reversals applied to items where the positive pole appeared first in the semantic differential pair. The five usefulness items (1, 3, 5, 7, 9) and four satisfaction items (2, 4, 6, 8) were then averaged into their respective subscale scores. All scoring and statistical analysis was performed using a Python processing script. The complete per-participant scored data is provided in Appendix D.

User Study Results

This chapter presents the results of the user study described in Chapter 6. Section 7.1 reports the quantitative findings from the SUS and Van der Laan scales, including internal consistency and covariate analysis. Section 7.2 presents the qualitative findings from the semi-structured interviews by themes. A discussion of the key findings and their implications is provided in Chapter 8.

7.1 Quantitative Results

Quantitative analysis was conducted using the System Usability Scale (SUS) and Van der Laan Acceptance Scale (VdL), described in Sections 6.4.3 and 6.4.4. Because the data consists of paired observations from a within-subjects design with a small sample ($N=21$), the Wilcoxon signed-rank test was used for between-condition comparisons rather than parametric alternatives. Spearman rank correlations were used to examine relationships between individual difference measures (ATI, PC) and the dependent variables. Internal consistency was assessed using Cronbach's alpha. Effect sizes are reported as rank-biserial correlations (r) for the Wilcoxon tests. The complete per-participant scored data, including SUS scores, VdL subscale scores, ATI, and PC for all 21 participants, are provided in Appendix D.

7.1.1 System Usability Scale

Both systems scored within the “Acceptable” range of system usability defined by Bangor et al. [87]: the password-based system at $M = 73.3$ ($SD = 15.7$) and the passwordless system at $M = 72.0$ ($SD = 20.3$).

A Wilcoxon signed-rank test found no significant difference between conditions ($W = 113.5$, $p = .944$, $r = .017$), indicating usability parity between the passwordless system and the password-based system (Figure 7.1).

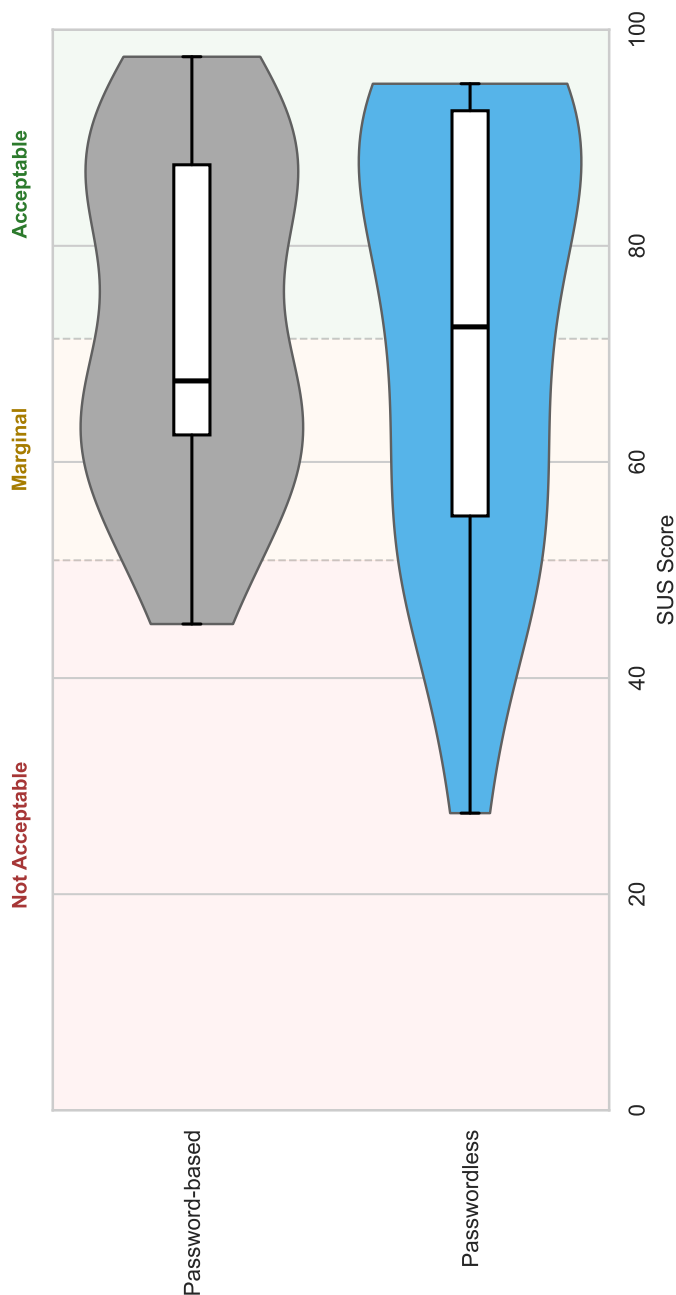


Figure 7.1: Distribution of System Usability Scale (SUS) scores for the password-based system (gray) and the passwordless system (blue), $N = 21$. Violin widths reflect density estimates. Overlaid boxes show the interquartile range (IQR) with a line at the median; whiskers extend to $1.5 \times \text{IQR}$. Background shading indicates acceptability ranges from Bangor et al. [87]. A Wilcoxon signed-rank test found no significant difference between conditions ($W = 113.5$, $p = .944$).

That the novel passwordless prototype achieved statistical parity with a mature, widely deployed commercial tool on first use is itself a meaningful result. Neither system reached the “above average” SUS benchmark of 80 [92], but this is unsurprising for encryption software.

Kortum and Bangor [93] demonstrated that SUS scores vary markedly across product types, with utilitarian tools consistently scoring lower than consumer-facing applications.

Despite near-identical group means, per-participant SUS differences ranged from -40.0 to $+40.0$ points, and the passwordless system exhibited higher variance ($SD = 20.3$ vs. 15.7). These results suggest that while the passwordless approach was usable for some users on first exposure, others found the unfamiliar workflow challenging. This is explored further in the covariate analysis (Section 7.1.3) and qualitative results (Section 7.2).

7.1.2 Van der Laan Acceptance Scale

On the Van der Laan acceptance scale, the passwordless system was rated significantly higher on the Usefulness subscale ($M = +1.19$, $SD = 0.77$) compared to the password-based system ($M = +0.73$, $SD = 0.65$), with a large effect size ($W = 39.0$, $p = .014$, $r = .629$). The Satisfaction subscale showed a similar directional trend favoring the passwordless system ($M = +0.93$, $SD = 0.85$ vs. $M = +0.52$, $SD = 1.00$), though this difference did not reach statistical significance at the .05 level ($W = 34.0$, $p = .078$, $r = .500$) (Table 7.1).

Van der Laan Usefulness and Satisfaction scores for both systems are shown in Figure 7.2.

Table 7.1: Van der Laan Acceptance Scale Results

Subscale	Password-based ($M \pm SD$)	Passwordless ($M \pm SD$)	W	p	r
Usefulness	$+0.73 \pm 0.65$	$+1.19 \pm 0.77$	39.0	.014*	.629
Satisfaction	$+0.52 \pm 1.00$	$+0.93 \pm 0.85$	34.0	.078 [†]	.500

Note: Wilcoxon signed-rank test ($N = 21$). r = rank-biserial effect size.

* $p < .05$, [†] $p < .10$.

Both systems received positive ratings on both subscales, indicating that participants found both approaches acceptable. However, the significant usefulness difference suggests that participants perceived the passwordless system as meaningfully more useful than the password-based system, even though the two systems were rated comparably on overall usability as measured by the SUS (see Section 7.1.1). One outlier is visible in the Passwordless Usefulness results, reflecting a single participant (P24) who rated the passwordless system's usefulness negatively at -1.20 .

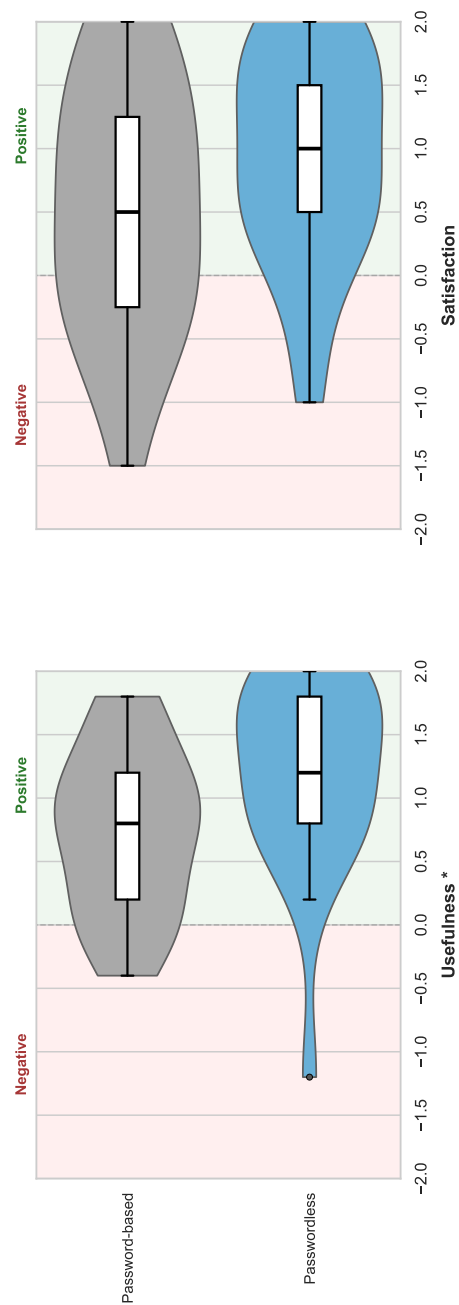


Figure 7.2: Distribution of Van der Laan Usefulness (left) and Satisfaction (right) scores for the password-based system (gray) and the passwordless system (blue), $N = 21$. Overlaid boxes show the IQR with a line at the median; whiskers extend to $1.5 \times \text{IQR}$. Background shading distinguishes negative (< 0) from positive (> 0) regions of the scale. * indicates significant difference on the Usefulness subscale (Wilcoxon signed-rank test, $p = .014$).

7.1.3 Covariate Analysis

Spearman rank correlations were computed to examine whether individual differences in technology affinity (ATI) and privacy concern (PC) were associated with the dependent variables of password-based vs. passwordless (Table 7.2).

Affinity for technology interaction (ATI; $M = 4.11$, $SD = 0.91$) was found to be a significant positive predictor of passwordless SUS scores ($\rho = +.578$, $p = .006$), indicating that participants with higher technology affinity tended to rate the passwordless system as more usable. In contrast, ATI was not significantly associated with password-based SUS scores ($\rho = +.192$, $p = .405$) (Figure 7.3).

Table 7.2: Spearman Correlations Between Control and Dependent Variables

Pair	ρ	p
ATI vs. Passwordless SUS	+.578	.006**
ATI vs. Password-based SUS	+.192	.405
ATI vs. Δ SUS	+.304	.180
ATI vs. Δ VdL Usefulness	+.367	.102
ATI vs. Δ VdL Satisfaction	+.168	.467
PC vs. Passwordless SUS	+.062	.788
PC vs. Δ VdL Usefulness	-.097	.676
ATI vs. PC	+.395	.077

Note: $N = 21$. $\Delta = \text{Passwordless} - \text{Password-based}$. * $p < .05$, ** $p < .01$.

This suggests that the novel passwordless system's perceived usability is more sensitive to an individual's technology interest and ability than the widely familiar password-based approach.

Notably, ATI was not significantly correlated with the VdL usefulness difference ($\rho = +.367$, $p = .102$) or satisfaction difference ($\rho = +.168$, $p = .467$), suggesting that the acceptance advantage of the passwordless system was not driven primarily by technology-savvy participants, though the small sample size makes it possible that an association went undetected.

Privacy concern scores exhibited a ceiling effect ($M = 5.58$, $SD = 1.01$ on a 7-point scale), with insufficient variance to detect meaningful associations with the dependent variables. No significant correlations were observed between PC and any outcome measure. This likely reflects the homogeneous, technically educated sample rather than a true absence of relationship between privacy concern and encryption tool preference.

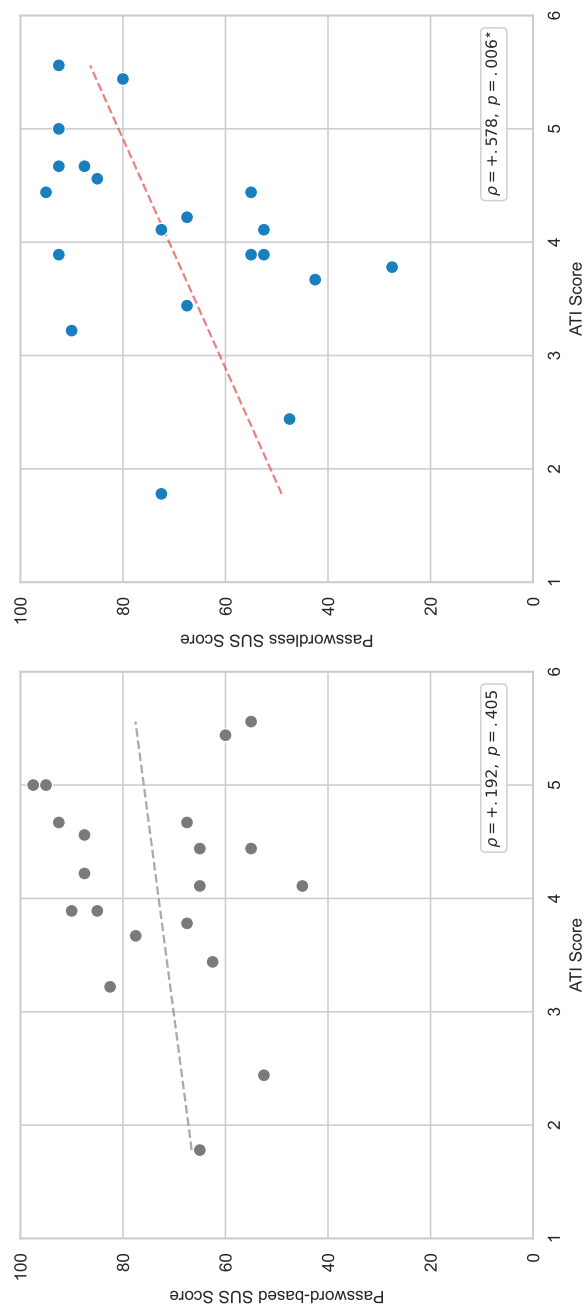


Figure 7.3: Scatterplots of Affinity for Technology Interaction (ATI) scores against SUS scores for the password-based system (left, gray) and the passwordless system (right, blue), $N = 21$. Dashed lines show ordinary least-squares linear fits as visual aids. Statistics are Spearman rank correlations. ATI was not significantly associated with password-based usability ($\rho = +.192, p = .405$) but was a significant positive predictor of passwordless usability ($\rho = +.578, p = .006^*$).

7.1.4 Internal Consistency

Cronbach's alpha was used to measure the internal consistency of the instruments used (Table 7.3). The ATI ($\alpha = .893$) and PC ($\alpha = .803$) scales demonstrated good to excellent internal consistency, confirming that these instruments performed reliably in this sample. The SUS showed good internal consistency for both the password-based ($\alpha = .807$) and passwordless ($\alpha = .887$) conditions, consistent with the established reliability of .90 reported in the literature [88]. The VdL scale showed excellent internal consistency for both the password-based ($\alpha = .884$) and passwordless ($\alpha = .890$) systems. The VdL Satisfaction subscale also showed excellent internal consistency (PB $\alpha = .902$, PL $\alpha = .813$). However, the VdL Usefulness subscale showed only acceptable consistency for the password-based system ($\alpha = .646$, slightly below the conventional .70 threshold), while demonstrating good consistency for the passwordless system ($\alpha = .834$).

Table 7.3: Internal Consistency (Cronbach's α)

Instrument	Password-based	Passwordless
SUS (10 items)	.807	.887
VdL (9 items)	.884	.890
<i>Usefulness</i>	.646	.834
<i>Satisfaction</i>	.902	.813
ATI (9 items)	.893	
PC (4 items)	.803	

Note: ATI and PC were administered once per participant (not per condition).

While all the measures generally showed acceptable internal reliability, the lower consistency observed in the password-based VdL Usefulness subscale may reflect varied prior experience with Adobe Acrobat. Unlike the passwordless system, which was equally novel to all participants, familiarity with the password-based tool varied widely, potentially producing inconsistent responses that undermined scale coherence. The inconsistency may also be attributable to participants' varied attitudes toward passwords in general rather than an objective assessment of the specific password-based encryption system tested.

7.2 Qualitative Results

Qualitative responses to the semi-structured interview questions were analyzed using thematic analysis [76]. Transcripts were coded by the primary researcher and the resulting themes were reviewed and confirmed by a second researcher. Thematic saturation was observed at $N = 18$; three additional participants were included to confirm no new themes emerged. Five themes were identified: (1) willingness to adopt,

(2) password sharing challenges, (3) trust and security perceptions, (4) usability friction points, and (5) adoption concerns.

7.2.1 Willingness to Adopt

Overall, participants found both encryption methods functional and usable. The password-based method was generally seen as simpler to start, as it was a more familiar interface with a clear, single path, while the passwordless method was seen as easier for sharing and more practical long-term. P13 noted “[The password-based] one [was] easier. . . for me to start. The [passwordless] one took more time, but I think it’s more useful function-wise.” P24 described the passwordless experience as “clean” and noted “both websites were simple to start. . . I can see long term the passkeys are better to use because it’s more organized.” P8 said “the password one was very simple. . . the passwordless one was a little confusing at first, but I think it’s useful. You do it once and you get it.” P18 said “[the password-based] one was more simple. . . but sharing the file was way easier with the [passwordless] one. . . Both were pretty good.” Generally, these qualitative impressions are consistent with the SUS scores, which show comparable levels of usability for both systems at a level considered acceptable and “good” for most users.

Two interview questions lent themselves to direct coding: “Would you use the passwordless encryption method for your own sensitive documents if it were available today?” and “If you had to send 10 encrypted documents a day to different clients, which method would you prefer?” Responses to these questions provide a framing for the qualitative findings that follow.

When asked whether they would use the passwordless method for their own sensitive documents, all 21 participants responded positively to some degree and none expressed active refusal or distrust. Twelve participants (N=12/21) gave enthusiastic, unconditional positive responses. Eight participants (N=8/21) expressed conditional willingness, citing considerations such as whether recipients would also need the software or hesitancy based on a lack of understanding the system’s details. One participant (P11) said they would likely not use it for personal document storage but would use it when sending sensitive documents to others, noting that the hassle of decrypting files for personal access was not worth it but that the security benefit for sharing was clear.

Table 7.4: Participant willingness to adopt the passwordless method for personal use.

Interview Question: “Would you use the passwordless method for your own sensitive documents if it were available today?”

Response Category	Count	Participants
Yes, enthusiastic	12/21	P7, P8, P9, P12, P13, P18, P23, P24, P25, P26, P27, P30
Yes, but/depends	8/21	P16, P17, P19, P20, P21, P22, P28, P29
Personal no / sending yes	1/21	P11
No / active distrust	0/21	None

When asked which method they would prefer if they had to send ten encrypted documents a day to different clients, the response was near-unanimous in favor of the passwordless method (N=19/21). One participant (P8) preferred the password-based method, citing its simplicity, and one participant (P9) was torn between the two. The “why” behind the consistent preference for the passwordless method at scale is rooted in challenges with password management and sharing burdens which are explored in the next section.

7.2.2 Password Sharing Challenges

A. The password sharing burden

A majority of participants identified sharing the password securely as the hardest part of the password-based method (N=11/21). P29 said “The biggest problem to me is the means of sharing the password.” P25 noted “it was kind of a pain to have to figure out a way to send the password once I encrypted the document.” Similarly, P16 said “The biggest hiccup with the [password-based] one was saying, all right, how do I share this password securely?”. Most participants shared the password for the password-encrypted document with the researcher by a second email, verbally in-person, or by text message. Two participants used online one-time secret sharing websites they were already familiar with (<https://onetimesecret.com> and <https://password.link>). Participants frequently cited the password sharing step as a security weakness and a source of frustration. P7 said, “I’m confident that I put a password on it, but then I was not confident in sending the password. . . if I send it on [Microsoft] Teams, is that secure? If I send it on email, then what’s the point of encrypting the thing?” P20 added “If you don’t have a secure way to transfer that password, which is a whole other step, then it’s not gonna be as secure. So I feel like that’s where the fallacy really is.” P25 who used a one time secret website noted “I always feel like [it] has a risk of [the website] stealing the password.” P21 said “no matter

which way you do it, I feel like sharing a password just has risks that go with it.” Nearly all participants that discussed the password sharing burden saw the passwordless method as a solution to the problem. P30 described “In the password system, you actually have to contact each person, make sure you connect with them, and find a secure way to share your password. With the passkey system, once you’re done, you’re done. You don’t have a follow-up.”

B. Human error with passwords

Several participants acknowledged that creating and sharing a password is an error-prone activity. This was demonstrated clearly by three participants (N=3/21) who had to redo or correct the password step during the session. P11 forgot their password and had to restart: “I was like, oh, I should make this password good. And then I didn’t write it down, so I immediately forgot it.” P17 used a common personal password, then realized at the share step they’d have to reveal it and restarted with a unique password: “My initial instinct was to just use a default password that I use for other things. . . I’m like, wait, I have to share this password with someone.” P23 sent the password by text message but the messaging app’s autocorrect changed it. “When I was literally sending you the text with the password, I sent it incorrectly because of autocorrect. That’s super awkward and potentially could lead to someone not signing a deal because they couldn’t get access to the document.”

C. Password creation

Participants (N=7/21) often noted that they didn’t want to create their own passwords and didn’t feel confident in their ability to create or remember passwords. P12 said “The [password-based] one was less helpful in my mind because I didn’t want to have to remember what the password was. If the device could just manage that, that would be great. . . I trust myself less to remember the password in a year when my taxes are up again.” P9 shared a similar view “I don’t trust my password-making abilities, so the fact that [the passwordless method] could just generate whatever it needed to was good.” P29 added that passwords are easily forgotten “What if you don’t send the email right away? Then you’ve forgotten the password for your document and now it’s pointless.”

D. Password reuse tendencies

Several participants (N=6/21) commented on their likelihood to reuse passwords at scale, which they recognized would reduce security benefits. P7 said “If I had to set a password every single time, I would just use the same exact one, and I feel like that would kind of defeat the purpose.” P24 likewise shared, “If I were using passwords, I would [use] the same password for everyone, probably, which would obviously not be good.” One participant, P9, described their workplace environment where they use sensitive files on a daily basis and have a single office-wide password

“It’s a shared drive, so you have to be logged in to use it. But then there’s some password-protected documents even inside of that, and everyone just knows the password. Everyone just has the same password for all of them. . . .” The tendency to reuse passwords was frequently repeated as a security weakness that participants raised as a drawback to using the password-based encryption model.

E. Passwordless sharing scales better

As noted in Section 7.2.1, nearly all participants (N=19/21) chose the passwordless method when asked which they would prefer if they sent 10 documents a day to different clients. P25 responded “Definitely the passkeys. Rather than type out 10 different passwords.” P20 said “I would 100% do the passwordless one. . . it just makes it so much easier to just upload it, get it encrypted, you’ve got the single file, then send it, move on.” P16 preferred passwordless to the “overhead of now I have to share a password to each person.” P12 said “I’d prefer the passwordless, absolutely, because I’m not trying to remember or even have a vault with hundreds and hundreds of passwords.” P21 mentioned that scale is what makes the password-sharing burden painful, “[Using passkeys] I miss the whole headache of having to remember passwords. . . for one document it’s not a big deal, but if you’re sending out lots. . . of these documents. . . then security best practice would be to have a different password for each one, and that’d be a lot to keep track of.” One participant, P8, preferred the password-based method saying it “seems more easy and straightforward,” while others like P23 gave similar reasoning in favor of the passwordless “I’m trying to think of your average client. They’re just opening it on their computer. I think passwordless would be the easiest method.”

7.2.3 Trust and Security Perceptions

Three major themes surfaced when participants responded to questions about their trust in the security of the passwordless method: (A) participants lack a clear mental model of how passkeys work, (B) participants have high satisfaction and high trust when using biometric authentication methods, and (C) participants’ trust in the brand of the tool provider impacts their trust in the overall system.

A. Lack of Understanding (Mental Model)

Approximately half (N=10/21) mentioned they did not understand how the passkey encryption and decryption worked technically. For some this caused a lack of trust while others felt the lack of understanding didn’t impact their trust in the system’s security. P20 described their mental reasoning, “When you opened the Adobe one, you saw, ‘hey, put in the password’ you could tell, okay, this is encrypted. . . [I] don’t know how passkeys work with encryption. . . Like, I have no idea how putting in just your email keeps it secure from everyone else. . . that’s the hole. . . where I [say] I’m just taking your word for it that this is secure.” P21 noted “It’s kind of hard to notice what’s actually protecting it.” P17

said “the [passwordless] one. . . kind of abstracts away a little bit of how the other person’s going to gain access to it. So I’m just really trusting that this product actually works, because I know how passwords work. It’s a little more abstracted for how this encryption is going.” P19 gave a similar perspective “I would just assume it’ll work. But I’m not sure how it works. I put in your email, but what does that do though? I mean, I’m not really sure. Since I don’t know how the technology works, I’m kind of skeptical about it as well. . . It feels secure, but I just don’t know how. I just need to take your word for it.”

However the lack of understanding was generally not a hindrance for trusting the security of the system. When asked which method they trusted more, the participants still chose passwordless. P19 said “Well, for sure the [passwordless] one.” P16 said “But I don’t know if I would be so untrusting of [the] passwordless. . . that I wouldn’t use it though. I don’t think that would stop me personally.” Some participants with less technical backgrounds felt if they could trust someone’s opinion who said the passkey was secure, that would be sufficient for them to feel okay using the system. P22 said “If somebody that I trusted said it’s a trustworthy way, I would trust it. But just opening it up, not having used it before and not being aware, I don’t know that I would know that it was secure.”

P7 provided a unique perspective: trusting the passwordless method conceptually but not trusting that they used it correctly, in part because the process felt too easy to be secure: “I trusted it, but I didn’t trust that I made it work. . . It felt secure, I just wasn’t confident that I did it correctly, because it was almost too easy.” This suggests that for some users, the ease of the passwordless process may actually undermine confidence when paired with limited understanding of the underlying mechanism. Providing more direct confirmation of successful encryption—such as a visible file state change or explicit success message—may help alleviate this concern.

B. Trust in Biometrics

Generally, participants liked the use of their fingerprint or other biometric authentication as part of the passwordless process. P19 said “it just asked me to scan my fingerprint for passkeys. It was really nice.” P26 commented “My phone just automatically was like, oh, just use your Face ID. And it just did all that for me, which was kind of nice.”

Multiple participants (N=8/21) used the phrase “feels more secure” to describe the biometric-based passkey approach compared to the password-based method. P24 said “I did Face ID on my phone. . . my face feels more secure than any password that could just get hacked from a list of strings in a database somewhere.” Likewise, P25 said “The passkey one just felt more secure.” P23 said “my Touch ID is way more unique than my password that could probably be guessed. . . so in that sense I felt like [passwordless] was more secure.” Some participants noted that they weren’t fully sure of how to set up and use passkeys but that they trusted using their fingerprint. P16 said “I just used the built-in. . . I don’t

know if it's through Chrome or Apple itself, but one of them. I just used my fingerprint." We observed that participants associated the passkey uniqueness with biometric uniqueness and felt a strong sense of security and trust in the biometric uniqueness.

Some participants specifically mentioned that they use biometric authentication for other secure verifications like digital wallets or online payments which contributed to their trust in using the same biometric feature during the passwordless document encryption. P27 said "I know it's used for other things like Apple Wallet® and Apple Pay® and things that I want to keep secure, that I trusted enough to use for that." P11 added, "I feel like it's pretty secure. I use passwordless stuff for other stuff and I feel like I trust it."

C. Platform and Brand Trust

Some participants (N=5/21) noted that their trust in the encryption system was based somewhat on their trust in the brand of the tool provider. P17 said "I feel like when not using a password, I would trust [the system] as much as I trust the platform that I'm using. . . If Adobe had a passwordless one, I trust Adobe, it's a big company [so I'd have] a lot of confidence in their solution." P29 said "I [don't] fully understand how the passkey stuff works, but I'm like, look, if Google does it, it's fine. . . They're not going to release something with bad security. That's just kind of my concept when it comes to security stuff." Talking about the passkey provider options, P13 commented "When I think of a big company like Google. . . I do trust them because they're big, but also I don't trust them too much with handling my data as well." P16 similarly said "With [the passwordless method], it's only stored in one place. . . they're the ones that are kind of managing that authentication platform." P22 noted, "If somebody that I trusted said it's a trustworthy way, I would trust it."

7.2.4 Usability Friction Points

Participants brought up several different aspects of the user experience as confusing primarily with the passwordless encryption process. These findings are notable as improvements which should be made to the passwordless encryption system and as general areas of concern for passkey-based systems. Many of these friction points may be attributable to the proof-of-concept state of the passwordless encryption system which was designed and built for this research study and is not a fully polished product rather than inherent limitations of the passwordless approach.

A. Passkey OS pop-up confusion

Two participants (P17, P18) initially hit cancel when the operating system's authenticator prompt appeared during passkey creation. The pop-up prompt is rendered by the operating-system rather than the web application, and the styling difference caused users to hesitate and question whether they were supposed to interact with it. P17 described the

experience, “When that pop-up shows for creating a passkey, it’s styled differently than the web page. . . . So I’m like, whoa, is that something I’m supposed to be interacting with? It asks for. . . my Touch ID. . . not knowing to expect that pop-up. . . brought a little pause. . . I actually hit cancel.” P18 also hit cancel on the passkey pop-up initially. P17 provided a suggestion for improvement “It [can say] this will pop up, you choose Chrome or your iCloud Keychain. Having a little understanding of where that’s [going to] end up, I’d feel more comfortable.” We observed that this is a general passkey UX challenge across all WebAuthn implementations as the passkey creation pop-up look and feel is outside the control of the website that begins the WebAuthn ceremony. Providing context in the application’s user interface about what to expect before triggering the ceremony may reduce user hesitation.

B. Double biometric interaction

The passwordless encryption process required the user to interact with their biometric authenticator (e.g., a fingerprint press or facial scan) twice. First to create the passkey and immediately after a second time to use the passkey to encrypt the file. Some participants (N=4/21) noted that this repeated biometric prompt felt redundant and confusing, but did not prevent task completion. P25 said, “I had to put in my fingerprint to do the passkey twice. I’m not sure why, but I did put it in twice. That was the only thing that would confuse me a little bit.” P24 likewise noted “doing it twice felt weird.” and P8 asked the researcher to confirm that it was working properly during the process due to the double biometric interaction. While the repetition felt strange and confusing to participants, it did not prevent them from succeeding in encrypting a file with the created passkey. This finding suggests a need to make changes so that the passkey pop-up and biometric interaction only occurs once if at all possible for the smoothest user experience.

C. Passkey creation failure

Three participants (N=3/21) ran into errors during the passkey creation process. P28 experienced repeated biometric failures: “I tried to use the fingerprint ID and it didn’t work, and so I had to do it like three times. And then I tried to use the phone and it didn’t work the first time, so I had to do it twice. Once it worked it was fine, but it was frustrating. . . whereas the password one, you just type it in. It’s easy.” P29 experienced an unclear flow after creating a passkey: “I created the key the first time and then I don’t know if it just didn’t save or what, but then it tried to have me make another one. There was something weird that happened in the flow that I didn’t quite understand.” The researcher observed that P22’s passkey provider produced errors during the creation process, requiring multiple attempts. P29 suggested that developers “go through it with somebody who’s never used it before. . . because you’re gonna run into random weird things that crop up.”

Despite these frustrations, none of the three participants dismissed the value of the passwordless approach. P28 said “despite my little

hiccups with it working, both of them were actually quite easy to use. They weren't cumbersome or anything." P29 similarly noted "it didn't feel too bad. The UI could be a little more intuitive, but overall it's pretty good."

D. File differentiation

Two participants (N=2/21) mentioned their desire for clearer differentiation between the non-encrypted and the encrypted file. The password-based method produced a visibly renamed file (e.g. XXXX-protected.pdf) while the passwordless output added a unique file ending (e.g. XXXX.pdf.secure). Depending on the device and file explorer, the filename or file type ending may be more or less apparent. P7 said "I really liked that it was 'protected.pdf.' I could see that the file had changed. . . whereas I don't feel like the file really changed on the passwordless one." P23 had a similar but inverse preference, noting "the protected PDF from Adobe looks the exact same as the normal PDF because it's the same file type. . . if I wasn't actually looking at it, I wouldn't have noticed that the protected one moved above the unprotected one in my file explorer. And I probably would have sent the non-encrypted one." A best practice may be to use both a distinct file extension and a modified filename to clearly differentiate the encrypted from the non-encrypted file across all operating systems and devices.

E. Simple user interfaces

Participants provided various suggestions for improving both methods by simplifying the user interfaces. P16 said "It felt like a lot of click-throughs." P11 wanted clearer button labeling "[make] it easier to tell what the buttons do and where I need to go to do what I'm trying to do." P11 noted "the [passwordless system] feels like it has the potential to be a lot easier to use, but the interface was not super user-friendly." P8 suggested "[having] a suggested option" for less technical users. P23 likewise said "for the least techy person, being able to see, oh, all I need to do is upload a document, attach the person's email, send it. Just keep the UI really simple."

F. File opening

Participants appreciated that the password-based PDF file could easily be viewed and opened using their device's native PDF viewer while the custom-encrypted passwordless document had to be manually uploaded to the website in order to decrypt or view. P27 described "With the passkey, I had to upload the document to the website again just to open it. But with the password one, I just had it in my files and I could just click on it. . . I didn't have to go through the process of going to a website, uploading it, and everything just to view it." P26 agreed, noting "having to re-upload it just adds an extra step, whereas the password one you just click on the document and can see it there." Adding a default application that would open passwordless encrypted files would improve the user experience.

G. Multi-Factor Authentication

Two participants (N=2/21) suggested the ability to add multi-factor authentication as an improvement to both systems. P13 said “It would be nice to have a function like multi-factor authentication. Not just passwords but also another layer of security.” P18 also suggested a multi-factor capability, and P19 suggested adding password policy enforcement for the password-based system.

7.2.5 Adoption Concerns

A. Recipient Onboarding

One of the most common concerns participants (N=7/21) raised about the passwordless system was whether the recipient would also need the software or a passkey set up; a friction that is not present with password-based methods. P21 described a desire to “make sure that other people are also on board with it, because it seems like they would also have to have it running for it to work between the two parties.” P22 likewise wanted to know “if it’s something that people have to purchase or have in order to access, or if it’s just a website.” P11 expressed uncertainty about the receiving experience, saying “I’m curious what the passwordless one looks like [from the receiver side]. . . I don’t really know what that looks like,” and added that “you would have to explain to the person you’re sending [the file] to how to use it. But if everyone could use it successfully, I think it would be smoother.” P21 articulated the tradeoff directly, noting that with the password-based method “you don’t need to worry about someone else really being able to decrypt it or have their program set up to receive it. You can just give them the file. They just need to know the password, and they can use it, they’re ready to go.” However, P21 also acknowledged the inverse: “the big disadvantage is that you have to figure out how to get that password to them in a secure way. So if they just have a passkey set up on their computer already. . . then it’ll be pretty seamless to send it over.” P23 added “I feel like if [the passkey prompt] came up on my mom’s computer, she’d be like, what’s happening?” P23 attributed this to a platform-level UI issue rather than a flaw in the passwordless method itself.

B. Data Privacy

Some participants (N=3/21) expressed hesitancy about uploading files to a website or cloud-based encryption software, preferring their sensitive files to remain locally stored on their device. P19 stated “I’m skeptical of [both systems]. . . because I am uploading my file and I don’t know if this software that’s supposed to encrypt and decrypt my files, if they are storing my files. . . I would avoid using these, unless they are really known for security. . . I’m trying to store only locally.” P23 expressed a similar preference for local storage “I try to store locally if possible, if I don’t need it on the cloud.” P11 added “if it’s just on my computer. . . I’m not super worried about somebody getting access to the hard drive on my computer. . . I think it’s just a hassle to have to decrypt

it.” These comments seem to reflect a broader desire for privacy from cloud-based tools rather than a specific critique of the password-based or passwordless system. While in principle a device-bound passkey provides local hardware based protection, in practice users who are privacy-sensitive to cloud-based storage will likely view any system that they interact with through a web browser with skepticism.

C. First-time passkey experience

A few participants (N=3/21) set up passkeys for the first time during the study. The experiences were generally positive. P20 said “It was pretty straightforward to get my first one set up, and I was using [a third-party password manager], so I just saved it right there in my browser and then I was able to use that again when I opened it. It was very fluid. It was very easy to just figure out.” P24 described the passkey setup as “clean” and noted “they seem [a] lot easier than remembering a ton of passwords”.

Discussion and Conclusion

8.1 Discussion

Overall the results show that users are accepting of the passwordless system as they generally find it usable, secure, and preferred to a password-based system especially when sharing many files or sharing files with individuals external to a controlled environment. Of the hypotheses stated in Section 6.1, we find that users perceived greater security, comparable usability, and better deployability in the passwordless system compared to the password-based approach. Both systems scored within the “Acceptable” range of usability on the SUS (passwordless: 72.0 vs. password-based: 73.3, $p = .944$), and the passwordless system was rated significantly more useful on the Van der Laan acceptance scale ($p = .014$), with a similar trend toward higher satisfaction ($p = .078$). That a novel prototype achieved usability parity with a mature commercial tool on first use is itself notable, as refinements to the user interface and increased familiarity would likely improve the passwordless system’s scores further. Qualitatively, users identified unique benefits of the passwordless system more often than they shared a preference for the password-based system. However, some users did note a preference for the password-based system, typically citing its simplicity, familiarity, and ease of use on the receiving side. Nearly all participants (20 of 21, see Table 7.4) expressed willingness to use the passwordless system for their own documents if it were available today, and when asked which method they would prefer for sharing multiple documents at scale, 19 of 21 chose the passwordless approach. Participants frequently perceived the passwordless method as more trustworthy and secure than traditional password-based approaches, citing frustration with password sharing and trust in biometric authentication as key factors.

A key finding from the qualitative results is that participants widely disliked and distrusted passwords while expressing strong preference for biometric authentication. Participants frequently noted frustration with creating and sharing passwords in the password-based process, while the biometric interaction in the passwordless process was met with immediate comfort: participants would tap their fingerprint without hesitation, often before fully reading the on-screen instructions.

Users intuitively associated passkey uniqueness with biometric uniqueness. Although the passkey is not derived from the user’s biometric information, both share a uniqueness property that users naturally

grasp. Users know “I am the only one with my fingerprint and face” but “anyone could guess my password”. As one participant said, “my face feels more secure than any password” (P24). The biometric interaction in passkey creation thus serves as a tangible proxy for security that participants can understand without needing to understand the underlying cryptography. This mental model—“my fingerprint is unique, therefore my encryption is unique”—may be technically imprecise, but it maps onto the actual security properties closely enough to support accurate trust judgments. While the concept of a passkey is abstract and unfamiliar to most users, the biometric interaction is familiar, simple, and trusted. Several participants (10 of 21) mentioned a lack of understanding about how passkeys work technically with some citing it as a reason for hesitation in trusting the passwordless system. However, most participants, including many who felt the passkey process was abstracted, reiterated that the passwordless method, anchored on their biometric action, felt more secure.

Several factors may contribute to the perceived security of the passwordless method. Some participants’ trust appeared rooted in the biometric interaction itself: the intuitive uniqueness of a fingerprint or face. Others grounded their trust in the platform provider’s brand (P17: “If Adobe had a passwordless one, I trust Adobe”; P29: “if Google does it, it’s fine”). Still others may associate the novelty or sophistication of the interaction with stronger security. Disentangling these factors is difficult with the current data, but the consistency of the “feels more secure” sentiment across participants with different reasoning suggests that the biometric interaction serves as a unifying trust signal regardless of the underlying rationale.

These findings align with recent work by Reitinger et al. [67], who found a significant increase in passkey adoption when applying digital nudges that emphasized biometric framing. For example, they described passkeys as “secure keys that use your fingerprint, face, or screen lock to simplify access” [67]. Our participants’ behavior confirms this approach: the biometric interaction served as an implicit nudge, making the security action feel familiar and trustworthy without requiring users to understand the underlying passkey mechanism. These findings suggest that passwordless adoption is most likely to succeed when the system emphasizes the biometric interaction and focuses on simplicity, ease of use, and uniqueness rather than the technical specifics of FIDO2 and WebAuthn.

The biometric interaction also connects to the self-efficacy literature discussed in Section 2.3. Biometric interaction provides the high coping appraisal identified as the strongest predictor of security behavior adoption: users feel capable of performing the security action—a fingerprint tap is something they already do daily—and believe it effectively protects their data because the uniqueness of their biometric maps intuitively onto the uniqueness of the encryption key. This combination of self-efficacy and response efficacy—“I can do this, and it works”—stands in contrast to the password-based method, where participants expressed low confi-

dence in their ability to create strong passwords, remember them, and share them securely. Security tools that make users feel confident in performing the secure action are more likely to drive adoption than tools that emphasize the severity of threats. While the series of MFT breaches described in Chapter 2 provides strong motivation for change in document protection methods, users are more likely to respond to improved tools than to threat awareness alone. Insecure behavior—in this case using simple, repeated passwords or sharing the password through an insecure method—is mostly driven by the security process being too effortful or complex. Users are often rational when balancing risk against effort and understand that worst-case harm is not the same as actual harm [94]. Human effort and attention is a precious resource primarily dedicated to productivity, so security tools need to fit into work processes without adding extra friction [33]. In the case of document encryption and sharing, the incumbent password-based encryption method already presents exactly this kind of friction, and participants in this study were eager to adopt methods that reduce the time, effort, and attention needed to share a file securely.

Usability challenges remain with the passwordless system presented in this work, which is in a proof-of-concept state and was not tested across every browser and device operating system due to the BYOD nature of the study. However, even in its early iteration, the passwordless system's usability friction was comparable to that of the established password-based method: three of 21 participants encountered problems creating or using passkeys, while three of 21 participants encountered problems sharing the password. The types of friction differ: passkey issues were platform-specific and likely to improve as WebAuthn support matures, while password sharing challenges are inherent to the password-based model itself. This parity of usability issues observed in real participant behavior aligns with the parity of usability ratings at the SUS "Acceptable" level. The significant correlation between technology affinity and passwordless usability ($\rho = +.578, p = .006$) suggests that this parity was achieved with a technically literate sample; broader adoption among less technical populations will likely require additional onboarding support and interface simplification. This relationship is not unique to our study: Kupris and Schreck [62] similarly found ATI to be a significant predictor of usability ($b = 3.887, p = .004$) in their $N = 92$ passkey study. Improving the user experience of the encryption flow and allowing FIDO2 protocols to gain more familiarity and compatibility offer room for the passwordless method to surpass password-based encryption in the near future. One notable tension emerged: P7 observed that the passwordless process felt "almost too easy to be secure," suggesting that high ease of use can paradoxically undermine confidence when perceived effort does not match users' mental model of what security should feel like. Providing visible confirmation that the encryption succeeded—such as a clear file state change or explicit success message—may help bridge this gap between ease and trust.

As discussed in Chapter 4, deployability concerns are a common

reason novel security architectures fail to gain traction and widespread use. While deployability was examined as part of this study's evaluation framework, this work is primarily an early design and prototyping effort aimed at discovering whether passwordless document encryption is feasible and acceptable from a user perspective.

The adoption of SSL/TLS offers an instructive parallel when considering how novel security mechanisms can gain widespread adoption. Reflecting on the success of SSL/TLS adoption which is used today to encrypt web traffic by default, Garfinkel et al. identify three theories of disuse: (1) that users lack the software, (2) that it is too difficult to use, and (3) that users simply do not want to use it, are addressed through (1) distribution with operating systems, (2) making it automatic, and (3) user education [32]. These theories of disuse informed the design requirements of the passwordless document encryption system: it runs in a standard web browser requiring no software installation, automates key management through WebAuthn PRF rather than requiring manual password creation, and provides a familiar file-based workflow. While these design choices address the theories of disuse at the prototype level, whether they hold at scale in production environments remains an open question explored further in Section 8.3.

The three research questions which guided this work build from problem identification to system design and solution validation. The comparative framework (R1) identified the limitations of existing document encryption methods and derived design requirements for an improved system. Key limitations included a perimeter defense model, the cognitive burden of creating and sharing secrets, vulnerability to brute-force attacks, inability to recover from a forgotten password, and the requirement for recipients to install specific software. The system design (R2) addressed those requirements through browser-based age encryption with WebAuthn PRF key derivation, providing strong modern encryption with cryptographic agility, keeping all plaintext data and encryption keys local to the browser, and requiring no passwords or software installation by either sender or recipient. These properties directly address the architectural vulnerabilities exposed by the series of MFT breaches described in Chapter 2, where compromised server sessions exposed every document on the platform. The user study (R3) provides initial empirical evidence that this approach is viable with participants finding the passwordless system usable and broadly preferring it to password-based encryption. While this work represents an early design and prototyping effort, it demonstrates that passwordless document encryption is both technically feasible and acceptable to users.

8.2 Limitations

The study has several limitations primarily related to sample size, demographic diversity, and the experimental system design.

The participant pool ($N=21$) was relatively small and demographically homogeneous, skewing heavily male (76.2%), relatively young ($M = 29.2$, $SD = 11.7$), and technically educated, with 71.4% possessing a formal Computer Science or Cybersecurity background. While this provides valuable initial insights into usability among early adopters and tech-literate users, it limits the generalizability of the findings to the broader, non-technical public. Several participants explicitly noted that users without their technical background might not feel as confident with the passwordless system, underscoring this constraint.

The within-subjects design, where each participant evaluated both systems, introduces the possibility of order and contrast effects. This is a well-known limitation of within-subjects user studies where participants' experience with the first system influences their evaluation of the second. To mitigate this, the presentation order was counterbalanced: 11 participants evaluated the password-based Adobe system first, and 10 evaluated the prototype passwordless system first. This counterbalancing helps average out learning and order bias across the sample, but cannot eliminate contrast effects at the individual level, where participants may still anchor their assessment of one system against the other.

Additionally, with usability sessions lasting 30–35 minutes, learning fatigue may have influenced response quality in later portions of the study. To reduce fatigue, we intentionally placed the Privacy Concerns (PC) Scale, Affinity for Technology Interaction (ATI) Scale, demographics, and other background questions in the pre-session survey to reduce the time answering survey questions during the usability session. Despite these measures, non-negligible learning fatigue may have influenced the quality of the results.

Finally, as with any prototype evaluation, the implemented system has not reached the maturity level of a production tool like Adobe Acrobat. The design builds on established standards—FIDO2, WebAuthn, and age encryption—and runs within a standard web browser, which partially mitigates the maturity gap compared to a fully novel prototype. However, there remains a likelihood that participants evaluated the prototype negatively based on its lack of polish rather than on the merits of the passwordless flow itself.

8.3 Future Research Directions

Future work should address the methodological limitations identified in Section 8.2. A between-subjects design, in which participants evaluate only one encryption method, would eliminate contrast and order effects but would require a substantially larger sample size to achieve comparable statistical power. Recruitment should target a more demographically diverse population, including non-technical users, to assess whether the usability findings generalize beyond early adopters. Additionally, a future study could be conducted asynchronously, with participants evaluating the system on their own devices and reporting feedback through a survey instrument rather than an in-person interview, enabling

broader geographic and demographic reach. Such a study could also target participants in regulated environments such as healthcare or finance, where document encryption is an operational requirement rather than an abstract task.

Beyond the user study, translating the prototype system into a production-ready implementation remains an open challenge. Future work could explore how passwordless document encryption might be distributed within operating systems and integrated with platform authenticators to perform per-file encryption automatically. As discussed in Section 8.1, automating the encryption process and embedding it within the operating system may remediate common reasons for user avoidance and—similar to SSL/TLS—help an improved security architecture become a default across many users and devices. Several directions to extend the technical architecture described in Chapter 5 are described in the remainder of this section.

While `typage` was selected for this implementation because TypeScript interfaces directly with the WebAuthn and FIDO2 browser APIs, a WebAssembly (Wasm) build of the age encryption engine would offer additional security benefits through sandboxed execution, isolating the encryption process from the broader JavaScript runtime. Projects have demonstrated age encryption running as a Go build within Wasm [95]. A Wasm build of the current system would require bridging between the sandboxed encryption environment and the browser’s credential APIs. A Wasm approach also opens the door to implementing the encryption process in a memory-safe language such as Rust or Go, which would reduce the attack surface associated with npm supply chain risks and JavaScript/TypeScript runtime vulnerabilities. This would further strengthen the system’s security posture while still enabling the usability and deployability benefits of the system running in a web browser session.

Recent advances in quantum computing have compressed expert timelines for cryptographically-relevant quantum computers significantly, with Google targeting 2029 [96] and the Department of Defense aiming to fully implement post-quantum encryption by 2030 [97]. This urgency is acute for file encryption systems, which are vulnerable to store-now-decrypt-later attacks that motivate a move to post-quantum encryption before attacks materialize. As of version 1.3.0, age natively supports hybrid post-quantum recipients using ML-KEM-768 combined with X25519. The prototype system exposes this as a selectable encryption mode (see Figure 5.9), but it cannot yet be combined with the WebAuthn PRF hardware-binding flow. Users must choose between passwordless hardware-bound encryption and post-quantum protection today. While the system’s architecture was designed and built for cryptographic agility where the encryption method can be changed without lengthy system rebuilds, work remains to unify the WebAuthn PRF authentication ceremony with age’s post-quantum recipients feature to ensure hardware-bound encryption that is also quantum-resistant. Specifically, the ECDSA signature in the WebAuthn authentication ceremony (usually

ES256) should be replaced with a post-quantum secure implementation (although it is partially mitigated by the interactive, online nature of the ceremony) and the resulting age recipient processes should integrate the hybrid ML-KEM-768 and X25519 method to wrap the file based on the WebAuthn value returned.

More complete attribute-based access control through OpenTDF would enable policies to travel with the encrypted file itself, supporting fine-grained rules such as time-based expiration, role-based access, and attribute-level restrictions beyond the current recipient-list model. The OpenTDF-style manifest included in the current system provides a foundation that could be expanded to provide more robust access control supporting the use of the system in zero-trust networks. This future research direction could also address how recipient identities are associated with contact identifiers such as email addresses, and whether that association should be global or per-document (as discussed in Section 5.3.3).

Additionally, integrating the system with cloud identity federation (e.g., AWS IAM/STS with OIDC) would enable the system to work with cloud storage services such as Box, Google Drive, or AWS S3. This approach would provide audit logging, short-term scoped credentials, and ABAC-governed access to cloud-hosted encrypted bundles. Access sharing would be administered through the cloud service's native access controls rather than standalone share links. The current system includes scaffolded share-link functionality to demonstrate the architectural pattern, but an improved implementation would integrate with established cloud storage providers.

8.4 Conclusion

Encrypted documents are used every day in finance, legal, healthcare, and other professions to protect sensitive information that must be shared with external partners. However, current document encryption methods do not adequately protect data confidentiality as demonstrated by the series of MFT breaches affecting millions of individuals described in Chapter 2. Password-based encryption remains the most widely available option, but it is vulnerable to brute-force attacks, unauthorized sharing, and the inherent challenge of securely communicating passwords to recipients.

This work presents an alternative approach. Through a structured comparative framework, we identified the usability, deployability, and security limitations of nine existing document encryption methods. From this analysis, we derived 15 design requirements and performed an iterative system design which resulted in a novel system built on FIDO2 passkeys, the WebAuthn PRF extension, and open-source age encryption. The system provides non-custodial end-to-end document protection without passwords removing the third-party vendor risk which caused the MFT breaches. We create a proof-of-concept implementation of our design as an open-source codebase and website. The system requires

no software installation, derives encryption keys from hardware-bound authenticator secrets rather than user-chosen passwords, and performs all encryption locally in the browser.

We evaluated this system through a counterbalanced within-subjects user study ($N=21$) comparing the passwordless approach to traditional password-based encryption via Adobe Acrobat. We utilize the System Usability Scale (SUS) and Van der Laan Acceptance Scale as metrics for empirical analysis. The passwordless prototype achieved comparable usability on first use (SUS passwordless: 72.0 vs. password-based: 73.3, $p = .944$) while being rated significantly more useful (VdL usefulness $p = .014$). Nineteen of 21 participants preferred the passwordless method for sharing documents at scale. Qualitative results show that users felt frustration with password sharing and felt a strong sense of security and trust in the biometric authentication used in the passwordless system. Together these factors contributed to a strong preference for using the passwordless approach.

To our knowledge, this is the first study to apply FIDO2 and WebAuthn PRF to end-to-end document encryption rather than user authentication, and one of the first human-subjects usability evaluations of the PRF extension in any context. This work offers several implications for practitioners and researchers.

For industry, the findings suggest that passwordless document encryption is both technically feasible and acceptable to users. Practitioners designing such systems should prioritize biometric-framed authentication flows, as users associate the uniqueness of fingerprint and facial recognition with security even without understanding the underlying cryptography. The password sharing burden—identified by a majority of participants as the weakest link in the traditional approach—should be eliminated. Systems that remove this step gain an immediate usability and security advantage.

For researchers, this study demonstrates that the WebAuthn PRF extension is a viable foundation for encryption applications beyond user authentication, opening a design space that has received little academic attention. The structured comparative framework presented in Chapter 4 provides a reusable tool for evaluating future document encryption methods. The significant correlation between ATI and passwordless usability ($p = .006$) suggests that future studies should recruit more demographically diverse samples and investigate onboarding interventions for less technical users.

Sensitive documents deserve the same level of cryptographic protection that has become standard for web traffic and instant messaging. This work provides initial evidence that passwordless, per-document encryption is a viable path toward that goal.

References

- [1] Kondruss, B., *MOVEit hack victim list*, en, December 2023.URL: <https://konbriefing.com/en-topics/cyber-attacks-moveit-victim-list.html>. cited on pp. 1, 4, 34
- [2] CISA, *CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability*, en, June 2023.URL: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>. cited on pp. 1, 5, 6, 34
- [3] Simas, Z., *Unpacking the MOVEit Breach: Statistics and Analysis*, en-US, July 2023.URL: <https://www.emsisoft.com/en/blog/44123/unpacking-the-moveit-breach-statistics-and-analysis/>. cited on pp. 1, 4, 6, 34
- [4] Adobe, *History of the PDF Timeline*, <https://www.adobe.com/acrobat/resources/pdf-timeline.html>, 2024. cited on pp. 2, 8
- [5] Danczul, B., Fuß, J., Gradinger, S., Greslehner, B., Kastl, W., and Wex, F., “Cuteforce Analyzer: A Distributed Brute-force Attack on PDF Encryption with GPUs and FPGAs,” *2013 International Conference on Availability, Reliability and Security*, September 2013, pp. 720–725. DOI: 10.1109/ares.2013.94 cited on pp. 2, 10, 32
- [6] Hranický, R., Matoušek, P., Ryšavý, O., and Veselý, V., “Experimental Evaluation of Password Recovery in Encrypted Documents,” November 2024, pp. 299–306. DOI: 10.5220/0005685802990306 cited on pp. 2, 10, 32
- [7] FIDO Alliance, *The State of Passkeys 2026: Global Consumer and Workforce Report*, <https://fidoalliance.org/wp-content/uploads/2026/05/The-State-of-Passkeys-Global-Consumer-and-Workforce-Report-1.pdf>, 2026. cited on pp. 2, 17
- [8] Bonneau, J., Herley, C., Oorschot, P. C. v., and Stajano, F., “The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes,” *2012 IEEE Symposium on Security and Privacy*, ISSN: 2375-1207, May 2012, pp. 553–567. DOI: 10.1109/sp.2012.44 cited on pp. 2, 9, 11, 12, 14, 26, 28, 32
- [9] Clark, J., Van Oorschot, P. C., Ruoti, S., Seamons, K., and Zappala, D., *Sok: Securing Email—A Stakeholder-Based Analysis*, en, *Financial Cryptography and Data Security*, Borisov, N. and Diaz, C., Eds., vol. 12674, Series Title: Lecture Notes in Computer Science, Berlin, Heidelberg: Springer Berlin Heidelberg, 2021, pp. 360–390. DOI: 10.1007/978-3-662-64322-8_18 cited on pp. 2, 9, 11, 13, 26, 28
- [10] Joyce, S., *Cloud CISO Perspectives: Late June 2023*, en, Vice President, Mandiant at Google Cloud, June 2023.URL: <https://cloud.google.com/blog/products/identity-security/cloud-ciso-perspectives-late-june-2023>. cited on p. 4

- [11] CISA, *Exploitation of Accellion File Transfer Appliance*, <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-055a>, 2021. cited on p. 5
- [12] MSSP Alert, *Accellion Vulnerabilities: Victim List*, <https://www.msspalert.com/news/accellion-vulnerabilities-victim-list>, 2021. cited on p. 5
- [13] The Lyon Firm, *MOVEit Data Breach Class Action Lawsuit*, <https://thelyonfirm.com/blog/moveit-data-breach-clop-ransomware/>, 2023. cited on p. 6
- [14] U.S. Census Bureau, *Happy New Year 2023*, <https://www.census.gov/library/stories/2022/12/happy-new-year-2023.html>, 2022. cited on p. 6
- [15] HIPAA Journal, *Welltok Data Breach*, <https://www.hipaajournal.com/welltok-data-breach/>, 2023. cited on p. 6
- [16] BitSight, *New Research Reveals Rapid Remediation of MOVEit Transfer Vulnerabilities*, <https://www.bitsight.com/blog/new-research-reveals-rapid-remediation-moveit-transfer-vulnerabilities>, 2023. cited on p. 7
- [17] IBM X-Force Security Research Team, *X-Force Releases Detection & Response Framework for Managed File Transfer Software*, <https://www.ibm.com/think/x-force/x-force-releases-detection-response-framework-managed-file-transfer-software>, August 2023. cited on p. 7
- [18] Kahn, D., *The Codebreakers: The Comprehensive History of Secret Communication from Ancient Times to the Internet*, Rev. ed. Scribner, 1996. cited on p. 8
- [19] Microsoft, *Add or remove protection in your document, workbook, or presentation*, Microsoft Support, 2026.URL: <https://support.microsoft.com/en-us/office/add-or-remove-protection-in-your-document-workbook-or-presentation-05084cc3-300d-4c1a-84e5-8e50a80fdf43>. cited on p. 9
- [20] Adobe, *Securing PDFs with passwords*, Adobe Acrobat User Guide, 2026.URL: <https://helpx.adobe.com/acrobat/using/securing-pdfs-passwords.html>. cited on p. 9
- [21] Microsoft, *You cannot recover a document that is protected with a password if the password is lost*, <https://support.microsoft.com/en-us/topic/you-cannot-recover-a-document-that-is-protected-with-a-password-if-the-password-is-lost-in-word-65a1f34b-fa3f-665a-4913-7ecbb8e01f5f>. cited on pp. 9, 32
- [22] Müller, J., Ising, F., Mladenov, V., Mainka, C., Schinzel, S., and Schwenk, J., “Practical Decryption exFiltration: Breaking PDF Encryption,” *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS ’19, New York, NY, USA: Association for Computing Machinery, November 2019, pp. 15–29. DOI: 10.1145/3319535.3354214 cited on pp. 9, 10
- [23] Rohlmann, S., Mladenov, V., Mainka, C., and Schwenk, J., “Breaking the Specification: PDF Certification,” *2021 IEEE Symposium on Security and Privacy (SP)*, ISSN: 2375-1207, May 2021, pp. 1485–1501. DOI: 10.1109/sp40001.2021.00110 cited on p. 10
- [24] Grothe, M., Mainka, C., Rösler, P., and Schwenk, J., “How to break Microsoft Rights Management Services,” *Proceedings of the 10th USENIX Conference on Offensive Technologies (WOOT ’16)*, USENIX Association, August 2016, pp. 26–39. cited on p. 11

- [25] Tullsen, M., Harris, W., and Wyatt, P., "Research report: Strengthening weak links in the PDF trust chain," *2022 IEEE Security and Privacy Workshops (SPW)*, 2022, pp. 152–167. DOI: 10.1109 / spw54247.2022.9833889 cited on p. 11
- [26] Dubin, R., "Content disarm and reconstruction of PDF files," *IEEE Access*, vol. 11, 2023, pp. 38 399–38 416. DOI: 10.1109/access.2023.3267717 cited on p. 11
- [27] Shatnawi, A., Munson, E. V., and Thao, C., "Maintaining Integrity and Non-Repudiation in Secure Offline Documents," *Proceedings of the 2017 ACM Symposium on Document Engineering*, ser. DocEng '17, New York, NY, USA: Association for Computing Machinery, August 2017, pp. 59–62. DOI: 10.1145/3103010.3121038 cited on p. 11
- [28] Alaca, F., Abdou, A., and Van Oorschot, P. C., "Comparative Analysis and Framework Evaluating Mimicry-Resistant and Invisible Web Authentication Schemes," en, *IEEE Transactions on Dependable and Secure Computing*, vol. 18, no. 2, March 2021, pp. 534–549. DOI: 10.1109/tdsc.2019.2908907 cited on pp. 11, 28
- [29] Whitten, A. and Tygar, J. D., "Why Johnny can't encrypt: A usability evaluation of PGP 5.0," *Proceedings of the 8th USENIX Security Symposium*, San Antonio, TX: USENIX Association, 1999, pp. 169–184. cited on p. 12
- [30] Herley, C. and Oorschot, P. C. van, "A research agenda acknowledging the persistence of passwords," *IEEE Security & Privacy*, vol. 10, no. 1, January 2012, pp. 28–36. DOI: 10.1109/msp.2011.150 cited on p. 13
- [31] U.S. Department of Education, *Encryption Procedures for Files Containing PII*, https://pdp.ed.gov/OSEP/Content/pdf/Security_Encryption_OSEP.pdf, 2023. cited on p. 13
- [32] Garfinkel, S. L., Margrave, D., Schiller, J. I., Nordlander, E., and Miller, R. C., "How to make secure email easier to use," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, New York, NY, USA: Association for Computing Machinery, April 2005, pp. 701–710. DOI: 10.1145/1054972.1055069 cited on pp. 13, 83
- [33] European Union Agency for Cybersecurity (ENISA), *Cybersecurity Culture Guidelines: Behavioural Aspects of Cybersecurity*, <https://op.europa.eu/en/publication-detail/-/publication/4c762564-5f59-11e9-9c52-01aa75ed71a1>, 2019. cited on pp. 14, 82
- [34] Borgert, N., Renaud, K., and Coventry, L., "A systematic review of cybersecurity behaviour research: 25 years of progress," *Proceedings of the CHI Conference on Human Factors in Computing Systems*, 2024. DOI: 10.1145/3613904.3642432 cited on p. 14
- [35] Zhang, X., Han, X., Dang, Y., Meng, F., Guo, X., and Lin, J., "User acceptance of mobile health services from users' perspectives: The role of self-efficacy and response-efficacy in technology acceptance," *Informatics for Health and Social Care*, vol. 42, no. 2, 2017, pp. 194–206. DOI: 10.1080/17538157.2016.1200053 cited on p. 14
- [36] Valsorda, F., *Age: A simple, modern and secure file encryption tool, format, and Go library*, <https://github.com/FiloSottile/age>, 2026. cited on pp. 14, 37

- [37] Community Cryptography Specification Project, *C2sp.org/age: The age specification*, <https://c2sp.org/age>, 2026. cited on pp. 14, 37
- [38] Picocrypt, *Picocrypt: A small, secure, and audited file encryption tool*, <https://github.com/Picocrypt/Picocrypt>, 2026. cited on p. 15
- [39] OpenTDF Project, *OpenTDF Specification*, <https://github.com/opentdf/spec>, 2026. cited on pp. 15, 39
- [40] U.S. Office of the Director of National Intelligence, *Trusted Data Format (TDF)*, <https://www.dni.gov/index.php/who-we-are/organizations/ic-cio/ic-cio-related-menus/ic-cio-related-links/ic-technical-specifications/trusted-data-format>, 2026. cited on p. 15
- [41] Shiraishi, M. and Shinagawa, T., “Hardware authenticator binding: A secure alternative to passkeys,” *2025 IEEE 49th Annual Computers, Software, and Applications Conference (COMPSAC)*, 2025, pp. 1095–1100. DOI: 10.1109/compsac65507.2025.00141 cited on p. 16
- [42] Stajano, F., “Pico: No more passwords!” *20th USENIX Security Symposium (USENIX Security 11)*, USENIX Association, 2011. cited on p. 16
- [43] Conners, J. S. and Zappala, D., “Let’s authenticate: Automated cryptographic authentication for the web with simple account recovery,” *Who Are You?! Adventures in Authentication Workshop (WAY ’19)*, Santa Clara, CA, 2019, pp. 1–6. cited on p. 16
- [44] Conners, J., Devenport, C., Derbidge, S., Farnsworth, N., Gates, K., Lambert, S., McClain, C., Nichols, P., and Zappala, D., “Let’s authenticate: Automated certificates for user authentication,” *Network and Distributed System Security Symposium (NDSS)*, 2022. DOI: 10.14722/ndss.2022.24272 cited on p. 16
- [45] Adida, B., *Federated Browser-Based Identity using Email Addresses*, W3C Identity in the Browser Workshop, 2011. URL: https://www.w3.org/2011/identity-ws/papers/idbrowser2011_submission_25.pdf. cited on p. 16
- [46] Sethuraman, S. C., Mitra, A., Ghosh, A., and Babu, R. T. S., “Tushkey: Transferable user secrets on hardware key,” *30th IEEE International Conference on Parallel and Distributed Systems (ICPADS)*, IEEE, 2024, pp. 176–185. cited on p. 16
- [47] FIDO Alliance, *Client to Authenticator Protocol (CTAP) Version 2.3 – Proposed Standard*, <https://fidoalliance.org/specs/fido-v2.3-ps-20260226/fido-client-to-authenticator-protocol-v2.3-ps-20260226.html>, February 2026. cited on p. 17
- [48] W3C, *Web Authentication: An API for accessing Public Key Credentials Level 3*, W3C Recommendation. <https://www.w3.org/TR/webauthn-3>, 2023. cited on pp. 17, 18
- [49] Ramat, B., Kartchner, D., and Seamons, K., “A Systematic Analysis of the Passkey User Experience,” *Symposium on Usable Privacy and Security (SOUPS 2025) — Poster*, Seattle, WA: USENIX Association, August 2025. cited on p. 18
- [50] Jannett, L., Mayer, A., Westers, M., Mladenov, V., Mainka, C., and Schwenk, J., “The state of passkeys: Studying the adoption and security of passkeys on the web,” *35th USENIX Security Symposium (USENIX Security 26)*, USENIX Association, 2026. cited on p. 18

- [51] Corbado, *Passkeys + PRF + WebAuthn: Understanding PRF Support Across the Stack*, <https://www.corbado.com/blog/passkeys-prf-webauthn>, March 2026. cited on pp. 18, 20
- [52] Yubico, *Security Deep Dive into CTAP2 hmac-secret*, https://developers.yubico.com/WebAuthn/Concepts/PRF_Extension/CTAP2_HMAC_Secret_Deep_Dive.html. cited on pp. 18, 19
- [53] Bitwarden, *Bitwarden announces support for passkey-based encryption via WebAuthn PRF*, Bitwarden Blog, October 2024. URL: <https://bitwarden.com/blog/bitwarden-announces-support-for-passkey-based-encryption-via-webauthn-prf/>. cited on pp. 18, 19
- [54] passkeys.dev, *Reference: Terms*, <https://passkeys.dev/docs/reference/terms/>, 2026. cited on pp. 20, 21
- [55] Barbosa, M., Boldyreva, A., Chen, S., and Warinschi, B., “Provable security analysis of FIDO2,” *Advances in Cryptology – CRYPTO 2021*, 2021. DOI: 10.1007/978-3-030-84252-9_5 cited on p. 22
- [56] Guan, J., Li, H., Ye, H., and Zhao, Z., “A formal analysis of the FIDO2 protocols,” *ESORICS 2022*, 2022. DOI: 10.1007/978-3-031-17143-7_1 cited on p. 22
- [57] Kuchhal, D., Saad, M., Oest, A., and Li, F., “Evaluating the security posture of real-world FIDO2 deployments,” *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2023. DOI: 10.1145/3576915.3623063 cited on p. 22
- [58] Yadav, T. K. and Seamons, K., “A security and usability analysis of local attacks against FIDO2,” *Network and Distributed System Security (NDSS) Symposium 2024*, 2024. cited on p. 22
- [59] Lyastani, S. G., Schilling, M., Neumayr, M., Backes, M., and Bugiel, S., “Is FIDO2 the Kingslayer of User Authentication? A Comparative Usability Study of FIDO2 Passwordless Authentication,” *2020 IEEE Symposium on Security and Privacy (SP)*, IEEE Computer Society, May 2020, pp. 268–285. DOI: 10.1109/sp40000.2020.00047 cited on pp. 22, 24, 34, 38, 54, 56, 57, 60
- [60] Büttner, A. and Gruschka, N., “Device-bound vs. Synced credentials: A comparative evaluation of passkey authentication,” *Proceedings of the 11th International Conference on Information Systems Security and Privacy (ICISSP 2025)*, vol. 2, SciTePress, 2025, pp. 651–659. DOI: 10.5220/0013380600003899 cited on pp. 23–25, 34, 38, 54
- [61] Würsching, L., Putz, F., Haesler, S., and Hollick, M., “FIDO2 the rescue? Platform vs. Roaming authentication on smartphones,” *Proceedings of the 2023 CHI Conference on Human Factors in Computing Systems*, ACM, April 2023. DOI: 10.1145/3544548.3580993 cited on pp. 23, 24, 56, 57, 60
- [62] Kupris, E. and Schreck, T., “The passkey promise: A comparative usability study of MFA methods,” *2026 IEEE Symposium on Security and Privacy (SP)*, San Francisco, CA, USA: IEEE Computer Society, 2026, pp. 3650–3666. cited on pp. 23, 24, 60, 82

- [63] Owens, K., Anise, O., Krauss, A., and Ur, B., “User perceptions of the usability and security of smartphones as FIDO2 roaming authenticators,” *Seventeenth Symposium on Usable Privacy and Security (SOUPS 2021)*, USENIX Association, August 2021, pp. 57–76. cited on p. 24
- [64] Ciolino, S., Parkin, S., and Dunphy, P., “Of two minds about two-factor: Understanding everyday FIDO U2F usability through device comparison and experience sampling,” *Fifteenth Symposium on Usable Privacy and Security (SOUPS 2019)*, Santa Clara, CA: USENIX Association, August 2019, pp. 339–356. cited on p. 24
- [65] Lassak, L., Pan, E., Ur, B., and Golla, M., “Why aren’t we using passkeys? obstacles companies face deploying FIDO2 passwordless authentication,” *33rd USENIX Security Symposium (USENIX Security 24)*, Philadelphia, PA: USENIX Association, August 2024, pp. 7231–7248. cited on p. 24
- [66] Amer, Y., Haque, E. U., Rong, Z., and Khan, M. M. H., “Understandability of the technology and benefit may not be enough to nudge users: An exploratory study in the context of FIDO2 adoption behavior,” *2025 IEEE 49th Annual Computers, Software, and Applications Conference (COMPSAC)*, 2025, pp. 607–618. DOI: 10.1109/compsac65507.2025.00083 cited on p. 24
- [67] Reitinger, T., Glas, M., and Pernul, G., “Moving beyond passwords: Investigating the effect of digital nudges on passkey adoption,” *Proceedings of the 2026 CHI Conference on Human Factors in Computing Systems (CHI ’26)*, ACM, April 2026, pp. 1–17. DOI: 10.1145/3772318.3791425 cited on pp. 24, 81
- [68] Farke, F. M., Lorenz, L., Schnitzler, T., Markert, P., and Dürmuth, M., ““you still use the password after all”—exploring FIDO2 security keys in a small company,” *Sixteenth Symposium on Usable Privacy and Security (SOUPS 2020)*, USENIX Association, August 2020, pp. 19–35. cited on pp. 24, 25
- [69] Kepkowski, M., Machulak, M., Wood, I., and Kaafar, D., “Challenges with passwordless FIDO2 in an enterprise setting: A usability study,” *2023 IEEE Secure Development Conference (SecDev)*, 2023, pp. 37–48. DOI: 10.1109/secdev56634.2023.00017 cited on pp. 24, 25
- [70] Das, S., Dingman, A., and Camp, L. J., “Why johnny doesn’t use two factor: A two-phase usability study of the FIDO U2F security key,” *Financial Cryptography and Data Security (FC 2018)*, vol. 10957, ser. Lecture Notes in Computer Science, Springer, 2018, pp. 160–179. DOI: 10.1007/978-3-662-58387-6_9 cited on p. 24
- [71] Kunke, J., Wiefeling, S., Ullmann, M., and Lo Iacono, L., “Evaluation of account recovery strategies with FIDO2-based passwordless authentication,” *ArXiv preprint arXiv:2105.12477*, 2021. cited on p. 25
- [72] Brooke, J., “Sus: A quick and dirty usability scale,” *Usability evaluation in industry*, vol. 189, no. 194, 1996, pp. 4–7. cited on pp. 26, 61, 107, 108
- [73] Van Der Laan, J. D., Heino, A., and De Waard, D., “A simple procedure for the assessment of acceptance of advanced transport telematics,” *Transportation Research Part C: Emerging Technologies*, vol. 5, no. 1, 1997, pp. 1–10. cited on pp. 26, 61, 107, 108

- [74] Franke, T., Attig, C., and Wessel, D., “A personal resource for technology interaction: Development and validation of the affinity for technology interaction (ATI) scale,” *International Journal of Human-Computer Interaction*, vol. 35, no. 6, 2019, pp. 456–467. DOI: 10.1080/10447318.2018.1456150 cited on pp. 27, 60, 103
- [75] Langer, M., König, C. J., and Fitali, A., “Information as a double-edged sword: The role of computer experience and information on applicant reactions towards novel technologies for personnel selection,” *Computers in Human Behavior*, vol. 81, 2018, pp. 19–30. DOI: 10.1016/j.chb.2017.11.036 cited on pp. 27, 60, 103
- [76] Braun, V. and Clarke, V., “Using thematic analysis in psychology,” *Qualitative Research in Psychology*, vol. 3, no. 2, 2006, pp. 77–101. DOI: 10.1191/1478088706qp063oa cited on pp. 27, 69
- [77] Teuscher, I. H. and Schooley, B., “Document encryption in practice: A comparative framework and evaluation,” *Proceedings of the ACM Symposium on Document Engineering (DocEng '25)*, Nottingham, United Kingdom: ACM, 2025. DOI: 10.1145/3704268.3748682 cited on p. 28
- [78] Alaca, F. and Oorschot, P. C. V., “Comparative Analysis and Framework Evaluating Web Single Sign-on Systems,” en, *ACM Computing Surveys*, vol. 53, no. 5, September 2021, pp. 1–34. DOI: 10.1145/3409452 cited on p. 28
- [79] Zimmermann, V., Gerber, N., Kleboth, M., Schmidt, K., and Mayer, P., “The Quest to Replace Passwords Revisited – Rating Authentication Schemes,” en, *Proceedings of the Twelfth International Symposium on Human Aspects of Information Security & Assurance (HAISA 2018)*, 2018, pp. 38–48. cited on p. 28
- [80] Nielsen, J., *Heuristic evaluation, Usability Inspection Methods*, Nielsen, J. and Mack, R. L., Eds., New York, NY: John Wiley & Sons, 1994, pp. 25–62. cited on p. 28
- [81] U.S. Department of Justice, *CCLR Submission Instructions*, <https://www.justice.gov/jmd/file/789256/dl>, 2024. cited on p. 33
- [82] Stäuble, M., *Actually Good Encryption? Confusing Users by Changing Nonces*, Semester project, Applied Cryptography Group, ETH Zürich, Supervisor: Kenny Paterson, 2022. URL: https://ethz.ch/content/dam/ethz/special-interest/infk/inst-infsec/appliedcrypto/education/theses/semester-project_mirco-stauble.pdf. cited on p. 37
- [83] Valsorda, F., *Typage: A TypeScript implementation of age file encryption*, <https://github.com/FiloSottile/typage>, 2026. cited on pp. 37, 38
- [84] NIST, *Attribute-Based Access Control*, <https://csrc.nist.gov/projects/attribute-based-access-control>, 2026. cited on p. 39
- [85] Teuscher, I. H., *Doc-protect: Passwordless document encryption prototype*, <https://github.com/iteuscher/doc-protect>, 2026. cited on p. 43
- [86] Lezhnina, O. and Kismihók, G., “A multi-method psychometric assessment of the affinity for technology interaction (ATI) scale,” *Computers in Human Behavior Reports*, vol. 1, 2020, p. 100 004. DOI: 10.1016/j.chbr.2020.100004 cited on p. 60
- [87] Bangor, A., Kortum, P., and Miller, J., “Determining what individual SUS scores mean: Adding an adjective rating scale,” *Journal of Usability Studies*, vol. 4, no. 3, 2009, pp. 114–123. cited on pp. 61, 63, 64

- [88] Lewis, J. R. and Sauro, J., "Item benchmarks for the system usability scale," *Journal of Usability Studies*, vol. 13, no. 3, 2018, pp. 158–167. cited on pp. 61, 69
- [89] Bangor, A., Kortum, P. T., and Miller, J. T., "An empirical evaluation of the system usability scale," *International Journal of Human-Computer Interaction*, vol. 24, no. 6, 2008, pp. 574–594. DOI: 10.1080/10447310802205776 cited on p. 61
- [90] Sauro, J. and Lewis, J. R., "Correlations among prototypical usability metrics: Evidence for the construct of usability," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems (CHI '09)*, 2009, pp. 1609–1618. DOI: 10.1145/1518701.1518947 cited on p. 61
- [91] Schmid, D., "The technology acceptance scale: Its Bayesian psychometrics assessed in a factor analysis via Markov chain Monte Carlo models," *Human Factors and Ergonomics in Manufacturing & Service Industries*, vol. 32, 2022, pp. 66–88. DOI: 10.1002/hfm.20896 cited on p. 61
- [92] Sauro, J. and Lewis, J. R., *Quantifying the User Experience: Practical Statistics for User Research*, 2016. cited on p. 64
- [93] Kortum, P. T. and Bangor, A., "Usability ratings for everyday products measured with the System Usability Scale," *International Journal of Human-Computer Interaction*, vol. 29, no. 2, 2013, pp. 67–76. DOI: 10.1080/10447318.2012.704215 cited on p. 65
- [94] Herley, C., "So long, and no thanks for the externalities: The rational rejection of security advice by users," *Proceedings of the 2009 New Security Paradigms Workshop (NSPW '09)*, 2009, pp. 133–144. DOI: 10.1145/1719030.1719050 cited on p. 82
- [95] Basic, M., *Age WASM: Age encryption in the browser*, <https://agewasm.marin-basic.com/>, 2024. cited on p. 85
- [96] Google, *Cryptography Migration Timeline*, <https://blog.google/innovation-and-ai/technology/safety-security/cryptography-migration-timeline/>, 2026. cited on p. 85
- [97] U.S. Department of Defense, *Preparing for the Migration to Post-Quantum Cryptography*, <https://dowcio.war.gov/Portals/0/Documents/Library/PreparingForMigrationPQC.pdf>, 2026. cited on p. 85

Appendices



Glossary of Terms

Age: An open-source, modern file encryption tool and format.

Authenticator: A tool used to validate one's identity, such as a phone's fingerprint scanner, facial recognition system, a hardware security key, or a laptop's built-in security chip.

Client: The software that runs on a user's device and communicates with remote servers (*Relying Parties*) on behalf of the user. In the context of this work, the *client* is typically a web browser.

Client Device: The physical hardware (e.g., a laptop or smartphone) on which the *client* software operates.

Client Platform: The integrated system comprising the *Client* software (e.g., browser) and the *Client Device* it runs on.

Client-side: A term referring to the user's local computing environment, encompassing the *Client Platform*, the attached *Authenticators*, and the secure connections between them.

CTAP (Client to Authenticator Protocol): A standard from the *FIDO Alliance* for connecting an external *authenticator* device (e.g., fingerprint scanner or hardware security key) to a web browser-based *client*.

Device-bound Passkey (Single-device Passkey): A *passkey* tied to a single *authenticator's* hardware, meaning the credential cannot be synced or leave the device where it was created.

End-to-End Encryption (E2E): A system of communication where only the communicating users can read the messages or files, preventing third parties (including the server) from accessing the cryptographic keys needed to decrypt the data.

FIDO Alliance (Fast IDentity Online): An industry group (including Apple, Google, Microsoft) working to standardize passwordless authentication protocols for interoperability and consistency across the internet.

FIDO2: A standard for passwordless authentication developed, maintained, and promoted by the *FIDO Alliance*. At the core, FIDO2 is made up of *WebAuthn* and *CTAP*.

Hash / Hashing: A one-way mathematical function that turns data into a string of text that cannot be reversed or decoded. In cybersecurity, it is used to keep sensitive information secure by rendering the resulting value unreadable to humans and extremely difficult to decrypt.

HMAC (Hash-based Message Authentication Code): Detailed in RFC 2104, this is the process of combining a secret key with a *salt* and returning a shareable value. This is used as part of the *PRF* performed to generate a secret used for encryption (e.g., HMAC-SHA-256).

MFT (Managed File Transfer): A type of software application or service used by organizations to securely store, manage, and share sensitive files. Typically accessed through the internet or an intranet.

Non-custodial: An architecture where the server neither stores nor has access to encryption secrets; users alone control secret data through their *authenticators*.

Passkey: A passwordless login method where a strong secret is created and stored on a user's device and unlocked when identity is confirmed (e.g., via fingerprint or PIN), avoiding the need to remember passwords and the need for a physical *authenticator* beyond the user's standard device.

Passkey Provider: The software service or operating system process that creates, stores, and manages a user's *passkeys* (e.g., Apple iCloud Keychain, Google Password Manager, or third-party managers like 1Password).

Phishing-resistant: An authentication mechanism where the credential or key is bound to the specific *relying party* (website), preventing users from being tricked into providing their credentials to a malicious, spoofed site.

Platform Authenticator: An *authenticator* built directly into a user's device (e.g., Windows Hello, Apple Face ID).

PRF (Pseudo-Random Function): A function that generates a deterministic value that is computationally indistinguishable from random, which can be used to perform encryption, including *end-to-end encryption*.

Relying Party: A website or application where users log in or authenticate.

Roaming Authenticator: A physically separate, portable *authenticator* device attached via USB, NFC, or Bluetooth that can be used to sign into multiple devices (e.g., a YubiKey).

Salt: A random string of numbers and letters added to a secret before it is *hashed*, ensuring unique outputs even for identical initial secrets.

Secure Hardware Enclave: A dedicated hardware component for calculating and storing cryptographic secrets, isolated from the rest of the device's processing. It is a primary example of *tamper-resistant hardware*.

Synced Passkey: A *passkey* that is shared across a user's devices, typically through a backend cloud-sync operated by a *passkey provider* (e.g., Apple iCloud Keychain, Google Password Manager), allowing for cross-platform availability and recovery.

Tamper-resistant hardware: Hardware designed to prevent the cloning, extraction, or viewing of cryptographic keys by malware or physical access (e.g., TPM 2.0 or YubiKeys).

W3C (World Wide Web Consortium): An international standards body for web-based communication standards.

WebAuthn: A web authentication specification developed and maintained by the W3C, widely used to perform authentication between a user's web browser (*client*) and a remote server.

WebAuthn PRF Extension: An optional feature described in the *WebAuthn* standard where the *Relying Party* sends a pseudo-random *salt* to the user's *authenticator* (e.g., via CTAP) and receives back a derived secret that can be used for *end-to-end encryption*, while the internal encryption key stays secured on the user's *authenticator*.

Zero-Knowledge Encryption: An architecture where zero secret knowledge is given to the server. It is a specific application of a *non-custodial* architecture.

B

Study Recruitment Materials

This appendix contains the recruitment materials used to recruit participants for the user study described in Chapter 6.

B.1 Recruitment Flyer

B.2 Participant Instructions

The following instructions were provided to participants during the in-person study session. The instructions describe the tasks for both the password-based system (Adobe Acrobat Online Document Encryption) and the passwordless system (the prototype developed during this research) and the order in which tasks were to be completed for each counterbalanced condition.

A recruitment flyer for a study at Brigham Young University. The flyer has a light gray background with blue decorative wavy lines. In the top right corner is the BYU logo. The main title is in large, bold, blue letters. Below the title is a paragraph of text. Then, a section titled 'You may qualify if you:' is followed by a bulleted list of three criteria. To the left of the QR code is the contact information. The QR code is in a white circle. At the bottom right, a dark blue button contains the text '5-10 minute Screening Survey'.

PASSWORDLESS DOCUMENT ENCRYPTION RESEARCH STUDY

You are invited to a 30-35 minute usability research study on the passkey encryption process. No compensation provided.

You may qualify if you:

- are 18+
- are English speaking
- able to meet in-person on BYU campus or via Zoom for 35 mins

Contact Info

Isaac Teuscher
<email>
<phone number>

PI: Dr. Ben Schooley
BYU IRB-2026-028

**5-10 minute
Screening Survey**

Figure B.1: Recruitment Flyer for User Study.

Table B.1: Task Instructions by Condition

	Password-based (Adobe Acrobat)	Passwordless (DocProtect)
Context	For this set of tasks you will use Adobe Acrobat Online to encrypt a file with a password. This means the password you choose will be the key to access the file contents and only those who know the password can read the file contents.	For this set of tasks you will use a passkey tool to encrypt a file with a passkey. This means your device will create a strong secret instead of a password which will be the key to access the file contents. Only those who have the passkey or are added as recipients will be able to read the file contents. If you are not familiar with passkeys, please watch this 30 second video explaining passkeys: <i>[Link to Understanding passkeys in 4 minutes, Chrome for Developers on YouTube].</i>
Task 1 (Encryption)	You have a contract with sensitive information that needs to stay secure. You want to encrypt the document before sending it to an external company. Use Adobe Acrobat Online (https://www.adobe.com/acrobat/online/password-protect-pdf.html) to encrypt the document with a password.	You have a contract with sensitive information that needs to stay secure. You want to encrypt the document before sending it to an external company. Use DocProtect (https://doc-protect.vercel.app/) to encrypt the document with a passkey. You do not need to create a password; instead, authorize the file so [the researcher's] identity ([researcher's email address]) can decrypt it.
Task 2 (Decryption)	Now you want to download the encrypted file, open it, and decrypt it to ensure the data is protected and everything looks correct.	Now you want to download the encrypted file, open it, and decrypt it to ensure the data is protected and everything looks correct.
Task 3 (Sharing)	Now you want to share the encrypted file with the external company. Please email the encrypted file to [researcher's email address]. Note: You must ensure the researcher has the password to open it. Please communicate the password using a method you would consider secure in a real office environment.	Email the encrypted file to [researcher's email address]. You do not need to send a password, but ensure the file is attached correctly.

Study Instruments

This appendix contains the survey instruments and interview questions used in the user study described in Chapter 6. The Qualtrics screening survey captured demographic information, validated scale responses (PC and ATI), informed consent, and scheduling. The Qualtrics in-session survey captured the SUS and VdL responses for each system after task completion. The semi-structured interview was used to gather qualitative feedback after participants completed the tasks on both systems.

C.1 Qualtrics Screening Survey

The Qualtrics screening survey captured demographic and background information, the Affinity for Technology Interaction (ATI) Scale [74], the Privacy Concerns Scale [75], the informed consent statement, and scheduling preferences. The full screening survey is reproduced below.

Demographics & Background

1. How old (in years) are you?
2. What is your gender?
 - Male, Female, Other, Prefer not to say
3. What is your highest educational degree?
 - Less than High school, High school graduate, Some college, Bachelor's degree, Master's degree, Ph.D, Other
4. Do you have a background or degree in Computer Science, Cyber-security, or a related technical field?
 - Yes, No
5. What is your area of study or work?
6. How often do you work with electronic documents that contain sensitive or controlled information?
 - Often (every day or every few days)
 - Sometimes / occasionally (every month)
 - Rarely / Not at all (I can't remember the last time)

7. What types of passwordless authentication have you used? (mark all that you have used)
- Push notifications on a smartphone, Confirmation codes via SMS / email, Confirmation codes via authentication app (e.g., Duo, Google Authenticator), Biometric methods (e.g., fingerprint, Face ID), Passkeys, Hardware security key (e.g., YubiKey), None of the above

Affinity for Technology Interaction (ATI) Scale

In the following section, we will ask you about your interaction with technical systems. The term “technical systems” refers to apps and other software applications, as well as entire digital devices (e.g., mobile phone, computer, TV, car navigation).

Participants were asked to rate their agreement with the following statements on a 6-point Likert scale ranging from 1 (*Completely disagree*) to 6 (*Completely agree*). They were instructed that there are no right or wrong answers.

1. I like to occupy myself in greater detail with technical systems.
2. I like testing the functions of new technical systems.
3. I predominantly deal with technical systems because I have to.
4. When I have a new technical system in front of me, I try it out intensively.
5. I enjoy spending time becoming acquainted with a new technical system.
6. It is enough for me that a technical system works; I don't care how or why.
7. I try to understand how a technical system exactly works.
8. It is enough for me to know the basic functions of a technical system.
9. I try to make full use of the capabilities of a technical system.

Privacy Concerns Scale

Participants were asked to rate their agreement with the following statements on a 7-point Likert scale ranging from 1 (*Strongly disagree*) to 7 (*Strongly agree*). They were instructed that there are no right or wrong answers.

1. I am concerned that companies are collecting too much information about me.
2. I am concerned about my privacy.

3. To me it is important to keep my privacy intact.
4. Novel technologies are threatening privacy increasingly.

Informed Consent

Title of the Research Study: Passwordless Document Encryption

Principal Investigator: Ben Schooley

Introduction

This research study is being conducted by Isaac Teuscher under the supervision of Dr. Ben Schooley at Brigham Young University to determine the usability and user acceptance of passwordless document encryption. You were invited to participate because you are eligible to participate and willing to assist.

Procedures

If you agree to participate in this research study, you will schedule a time to meet with the research staff at a time and place that works for you. At the scheduled appointment the following will occur:

- You will imagine yourself working in a business context.
- You will perform two sets of tasks on a provided computer to encrypt and share a file (20 minutes).
- You will answer a set of multiple choice and free response questions about your experience (5 minutes).
- The investigator will ask you concluding questions and record your responses (5 minutes).
- The concluding interview will be audio-recorded to make sure the investigator remembers what you said correctly.
- You'll spend 40–45 minutes in total between the initial survey (10 mins) and research session (30–35 mins).

Risks/Discomforts

This research study is not expected to cause any harm. If you feel uncomfortable for any reason you may stop being in the study at any time.

Benefits

There are no direct benefits to the participant, but the potential benefits to society are:

1. Learning about encryption methods that may improve security and usability of data protection software.
2. Enabling protection of sensitive information in electronic documents.

3. Understanding how to design passwordless software systems to be easy to use.

Confidentiality

Each research subject will be assigned a unique ID number for each data source and personal identifiers such as name and email which are used to coordinate the appointment will be deleted after the session is completed. The research data (survey responses, transcripts of interviews, and time on tasks) will be kept in a secure Google Drive folder during analysis and only the investigators will have access to the data. At the end of the study, all your information that could directly identify you will be deleted, and your responses will be kept anonymized in a secure Google spreadsheet. Data will be retained for three years after study completion as is required by federal regulations for research. Any publications or presentations that result from the research will only reference ID numbers or aggregated data.

Data Sharing

We may share your data with other researchers or institutions to help with this study or related research. If this occurs, we will remove your name and any direct identifiers before sharing—this means the data cannot easily be linked back to you. Audio data and interview question responses will be shared with a third-party service for transcription and analysis, your name and direct identifiers will be removed before sharing with the third-party service.

Compensation

There is no compensation or payment for participating in this study.

Participation

Participation in this research study is voluntary. You have the right to withdraw at any time or refuse to participate entirely, and it will not affect your standing with the university.

Questions about the Research

If you have questions, concerns, or complaints, you can contact the Principal Investigator Dr. Ben Schooley at <email> and Co-Investigator Isaac Teuscher at <email> or <phone>.

Questions about Your Rights as a Research Subject

If you have questions regarding your rights as a research subject, contact the Human Research Protection Program by phone at (801) 422-1461; or by email: BYU.HRPP@byu.edu.

Statement of Consent

I have read, understood, and have been offered a copy of the above consent and desire of my own free will to participate in this study.

Signature: _____ Date: _____

Scheduling

1. Please provide your name.
2. Please provide an email address to receive confirmation and details about the research session.
3. Please specify what days and locations you are available to meet with a researcher from the following options. A researcher will contact you by email to confirm the date, time, and location.

C.2 In-Session Usability Study

The in-session usability study presented participants with a study scenario, two task sets (one per system), the System Usability Scale (SUS) [72], and the Van der Laan System Acceptance Scale (VdL) [73] after each system was used. The presentation order of the two systems was counter-balanced and recorded as a data field so the SUS and VdL responses could be correctly assigned to the password-based or passwordless condition during analysis. The full in-session study instrument is reproduced below.

Study Scenario

Imagine you are a contractor handling sensitive financial and HR data. You need to encrypt a sensitive contract and send it to your business partner who works remotely. You must ensure that if your email is intercepted, a thief cannot read the file.

Tasks: Password-Based Method

Context: For this set of tasks you will use Adobe Acrobat Online to encrypt a file with a password.

1. **Task 1 (Encryption):** You have a contract with sensitive information that needs to stay secure. You want to encrypt the document before sending it to an external company. Use Adobe Acrobat Online to encrypt the document with a password.
2. **Task 2 (Open encrypted file):** Now you want to download the encrypted file, open it, and decrypt it to ensure the data is protected and everything looks correct.
3. **Task 3 (Sharing):** Now you want to share the encrypted file with the external business partner. Please email the encrypted file to the researcher. You must ensure your business partner has the password to open the file. Please communicate the password in a method you would consider secure in a real office environment.

Tasks: Passwordless Method

Context: For this set of tasks you will use a Passwordless system to encrypt a file with a passkey.

1. **Task 1 (Encryption):** You have a contract with sensitive information that needs to stay secure. You want to encrypt the document before sending it to an external company. Use the Passwordless Document Encryption tool to encrypt the document with a passkey. You do not need to create a password; instead, authorize the file so your business partner can decrypt it.
2. **Task 2 (Open encrypted file):** Now you want to download the encrypted file, open it, and decrypt it to ensure the data is protected and everything looks correct.
3. **Task 3 (Sharing):** Now you want to share the encrypted .rico file with the external business partner. Please email the encrypted file to the researcher. You do not need to send a password, but ensure the file is attached correctly.

System Usability Scale (SUS)

The System Usability Scale (Figure C.1) is a 10-item instrument where participants rate their immediate reaction to each tool on a 5-point Likert scale ranging from *Strongly disagree* to *Strongly agree* [72].

Scoring. For odd-numbered items, the score contribution is the scale position minus 1; for even-numbered items, the contribution is 5 minus the scale position. The sum of the 10 item contributions is multiplied by 2.5 to produce a final SUS score on a 0–100 scale [72].

Van der Laan Acceptance Scale

The Van der Laan Acceptance Scale (Figure C.2) is a 9-item semantic-differential instrument where participants rate their immediate reaction to each tool by selecting the position on a 5-point scale between each pair of opposing adjectives (“I find such a system. . .”) [73].

Scoring. Responses were converted from the raw 1–5 Likert scale to the standard –2 to +2 scale, with polarity reversals applied to items where the positive pole appeared first in the semantic-differential pair. The five usefulness items (1, 3, 5, 7, 9) and four satisfaction items (2, 4, 6, 8) were then averaged into their respective subscale scores.

System Usability Scale

© Digital Equipment Corporation, 1986.

	Strongly disagree				Strongly agree
1. I think that I would like to use this system frequently	☐	☐	☐	☐	☐
	1	2	3	4	5
2. I found the system unnecessarily complex	☐	☐	☐	☐	☐
	1	2	3	4	5
3. I thought the system was easy to use	☐	☐	☐	☐	☐
	1	2	3	4	5
4. I think that I would need the support of a technical person to be able to use this system	☐	☐	☐	☐	☐
	1	2	3	4	5
5. I found the various functions in this system were well integrated	☐	☐	☐	☐	☐
	1	2	3	4	5
6. I thought there was too much inconsistency in this system	☐	☐	☐	☐	☐
	1	2	3	4	5
7. I would imagine that most people would learn to use this system very quickly	☐	☐	☐	☐	☐
	1	2	3	4	5
8. I found the system very cumbersome to use	☐	☐	☐	☐	☐
	1	2	3	4	5
9. I felt very confident using the system	☐	☐	☐	☐	☐
	1	2	3	4	5
10. I needed to learn a lot of things before I could get going with this system	☐	☐	☐	☐	☐
	1	2	3	4	5

Figure C.1: System Usability Scale (SUS) instrument as administered in the in-session Qualtrics survey.

Please tick a box on every line.

I find such a system...

1. Useful ☐ ☐ ☐ ☐ ☐ ☐ Useless
2. Pleasant ☐ ☐ ☐ ☐ ☐ ☐ Unpleasant
3. Bad ☐ ☐ ☐ ☐ ☐ ☐ Good
4. Nice ☐ ☐ ☐ ☐ ☐ ☐ Annoying
5. Effective ☐ ☐ ☐ ☐ ☐ ☐ Superfluous
6. Irritating ☐ ☐ ☐ ☐ ☐ ☐ Likeable
7. Assisting ☐ ☐ ☐ ☐ ☐ ☐ Worthless
8. Undesirable ☐ ☐ ☐ ☐ ☐ ☐ Desirable
9. Raising Alertness ☐ ☐ ☐ ☐ ☐ ☐ Sleep-inducing

Van der Laan, J.D., Heino, A., & De Waard, D. (1997). A simple procedure for the assessment of acceptance of advanced transport telematics. *Transportation Research - Part C: Emerging Technologies*, 5, 1-10.

Figure C.2: Van der Laan Acceptance Scale instrument (English version) as administered in the in-session Qualtrics survey.

C.3 Post-Session Interview Questions

The following semi-structured interview questions were used at the conclusion of each study session to gather qualitative feedback from the participants. Participants were informed of audio recording prior to the questions and reminded that responses would be stored anonymously (pseudonymized).

I will now ask you a few open-ended questions to get your feedback and thoughts. If it is still okay with you, I will start an audio recording to capture your responses; your answers will be stored anonymously (pseudonymized).

1. How would you describe your user experience with each of the encryption methods you used?
2. Which method did you trust more to keep the document secure, and why?
3. What advantages do you see in using each method?
4. What disadvantages do you see in using each method?
5. What did you like?
6. How would you improve it?
7. How do you typically work with electronic documents that contain sensitive or controlled information?
8. Would you want to use the tested passwordless encryption method for your own sensitive documents if it were available today?
9. If you had to send 10 encrypted documents a day to different clients, which method would you prefer? Please explain your reasoning.
10. Did the passwordless method feel “secure” to you, or did the lack of a password make it feel less safe?

Data and Analysis

This appendix presents the complete codebook used for qualitative analysis and the per-participant scored data from the quantitative analysis described in Chapter 7.

D.1 Codebook

The codebook used for the qualitative thematic analysis of the semi-structured interview transcripts (Section 7.2) consists of the five themes presented in Chapter 7 (willingness to adopt, password sharing challenges, trust and security perceptions, usability friction points, and adoption concerns), with sub-codes documented in Sections 7.2.2 through 7.2.5. The complete coded transcripts and codebook spreadsheet are available from the author upon request.

D.2 Per-Participant Scored Data

The complete per-participant scored data for all $N = 21$ participants is provided in Table D.1. This includes the Affinity for Technology Interaction (ATI) score, Privacy Concerns (PC) score, the System Usability Scale (SUS) scores for the password-based and passwordless systems, the Van der Laan Usefulness (VU) and Satisfaction (VS) subscale scores for each system, the difference in SUS scores between conditions (Δ SUS), and the counterbalanced presentation order assigned to each participant.

Table D.1: Per-Participant Scored Data

ID	Order	ATI	PC	SUS _{PB}	SUS _{PL}	Δ SUS	VU _{PB}	VU _{PL}	VS _{PB}	VS _{PL}
P7	PB→PL	3.89	6.00	90.0	92.5	+2.5	+1.20	+2.00	+2.00	+2.00
P8	PB→PL	3.67	5.25	77.5	42.5	-35.0	+0.80	+0.60	+0.75	-0.50
P9	PL→PB	1.78	4.00	65.0	72.5	+7.5	+1.80	+2.00	+1.00	+2.00
P11	PB→PL	2.44	4.50	52.5	47.5	-5.0	+0.00	+0.80	-1.50	+0.50
P12	PB→PL	4.44	6.00	65.0	55.0	-10.0	-0.20	+1.20	-0.75	+0.50
P13	PL→PB	4.44	5.75	55.0	95.0	+40.0	+0.80	+2.00	+0.50	+1.50
P16	PL→PB	4.67	7.00	92.5	87.5	-5.0	+1.60	+1.80	+2.00	+2.00
P17	PB→PL	3.44	6.00	62.5	67.5	+5.0	+0.60	+1.00	+0.00	+0.75
P18	PL→PB	3.89	4.50	85.0	55.0	-30.0	+1.80	+1.20	+2.00	+0.25
P19	PL→PB	5.00	6.25	97.5	92.5	-5.0	+1.20	+0.80	+1.50	+1.50
P20	PB→PL	4.56	7.00	87.5	85.0	-2.5	+1.00	+1.60	+1.00	+1.50
P21	PL→PB	5.00	4.75	95.0	92.5	-2.5	+1.00	+1.60	+1.25	+1.00
P22	PB→PL	4.11	6.00	45.0	52.5	+7.5	+1.00	+1.00	-0.25	+0.50
P23	PL→PB	5.44	6.75	60.0	80.0	+20.0	+0.40	+2.00	+1.00	+2.00
P24	PB→PL	3.89	7.00	85.0	52.5	-32.5	+0.00	-1.20	+0.25	+0.25
P25	PB→PL	5.56	4.75	55.0	92.5	+37.5	+0.80	+1.80	+0.25	+1.50
P26	PL→PB	3.22	4.75	82.5	90.0	+7.5	+0.20	+0.80	+0.00	+0.00
P27	PB→PL	4.22	5.50	87.5	67.5	-20.0	+1.40	+1.60	+1.50	+1.00
P28	PB→PL	3.78	6.00	67.5	27.5	-40.0	+0.40	+0.20	-0.25	-1.00
P29	PL→PB	4.11	3.50	65.0	72.5	+7.5	-0.40	+0.60	-0.50	+0.75
P30	PL→PB	4.67	6.00	67.5	92.5	+25.0	+0.00	+1.60	-0.75	+1.50
Mean		4.11	5.58	73.3	72.0	-1.3	+0.73	+1.19	+0.52	+0.93
SD		0.91	1.01	15.7	20.3	21.9	0.65	0.77	1.00	0.85

Note: PB = Password-based; PL = Passwordless. Order indicates which method was used first: PB→PL = Password-based first, PL→PB = Passwordless first. Δ SUS = SUS_{PL} - SUS_{PB}. VU = Van der Laan Usefulness; VS = Van der Laan Satisfaction. ATI = Affinity for Technology Interaction; PC = Privacy Concerns.

Supplementary System Diagrams

This appendix contains supplementary architectural diagrams that complement the system design discussion in Chapter 5, and screenshots of the Adobe Acrobat online password-protection flow used as the password-based comparison condition in the user study (Chapter 6).

E.1 Basic Offline Architecture

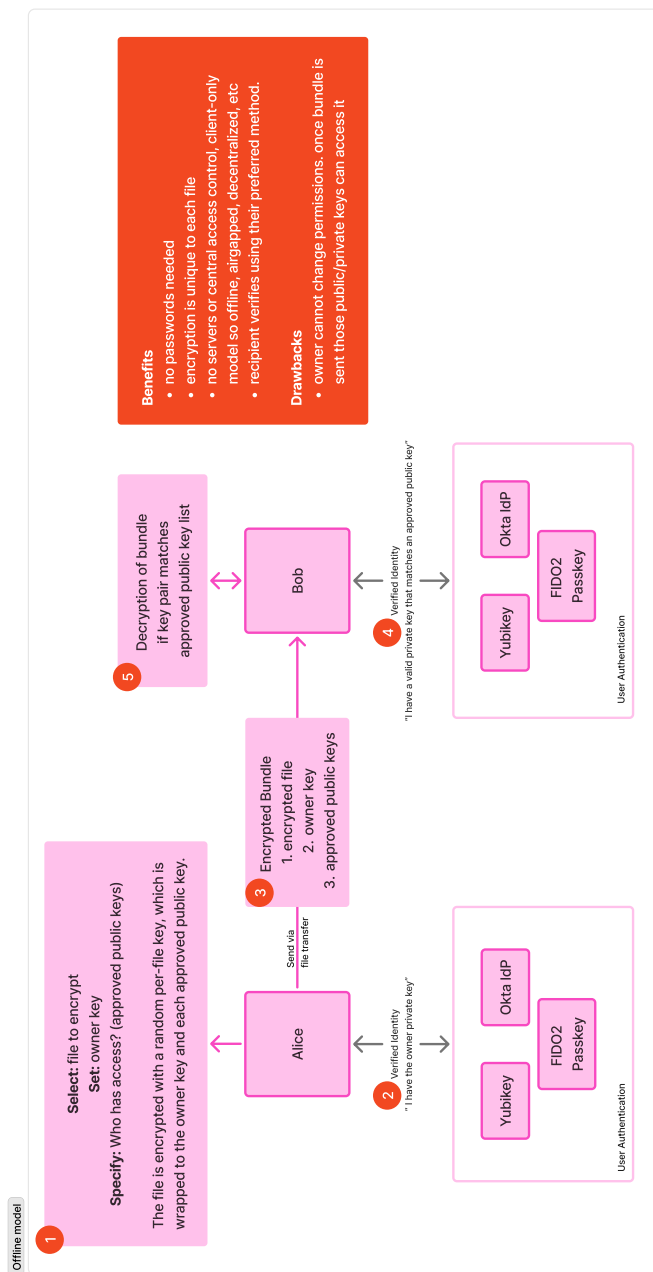


Figure E.1: Basic offline architecture of the passwordless document encryption system. All encryption, key derivation, and file handling occurs locally in the browser using WebAuthn PRF; no server-side state or session data is required.

E.2 Request Access Flow (as recipient)

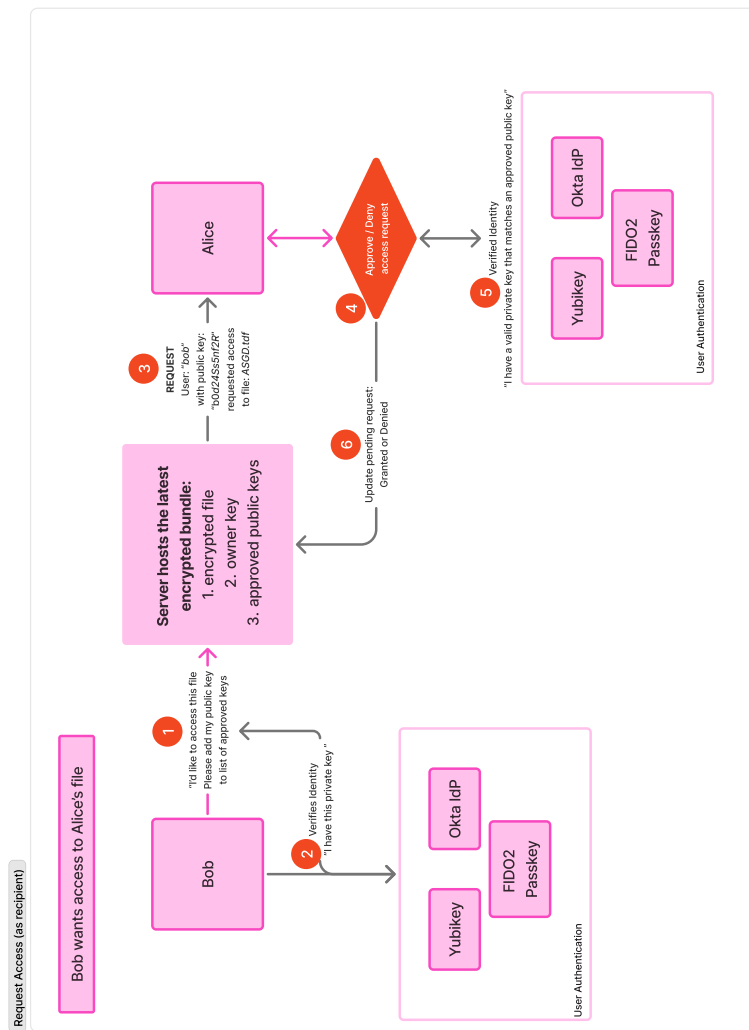


Figure E.2: Request access flow showing the interaction between a recipient (Bob), the server, and the sender (Alice). Bob requests access to an encrypted file by providing his public key; Alice reviews and approves the request after verifying her identity, and the server updates the approved key list.

E.3 Share Access Link (as sender)

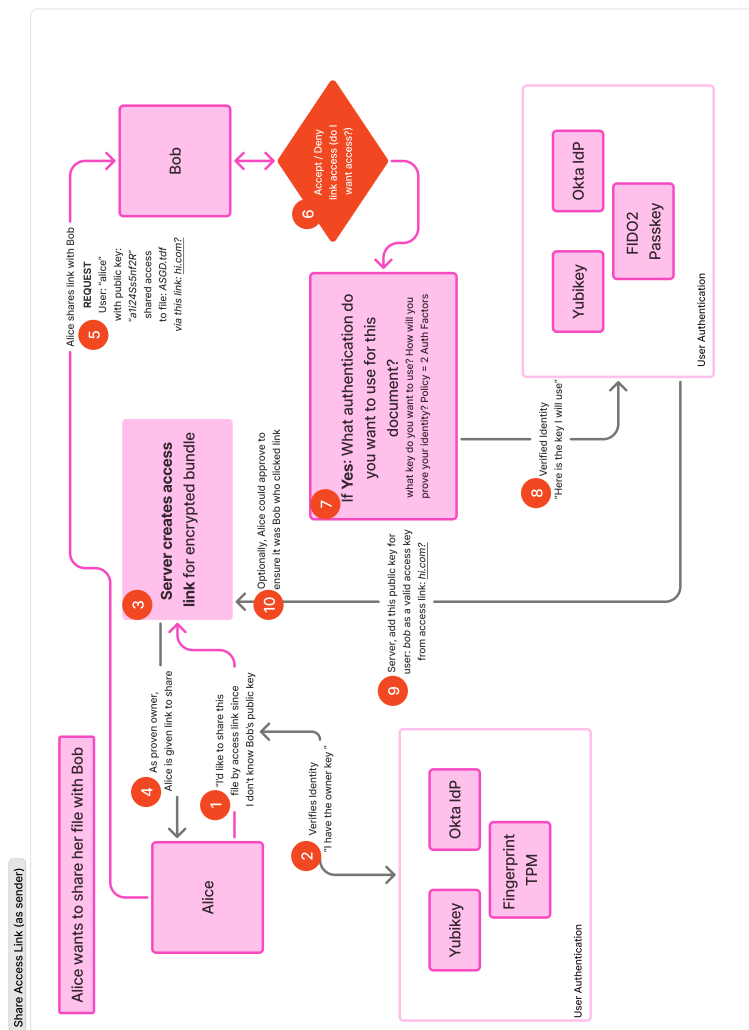


Figure E.3: Share access link flow showing how a sender (Alice) proactively shares an encrypted file with a recipient (Bob) using a generated link. Bob opens the link, provides his public key, and Alice approves the association, granting Bob access to the encrypted file.

E.4 Credential Creation Sequence Diagram

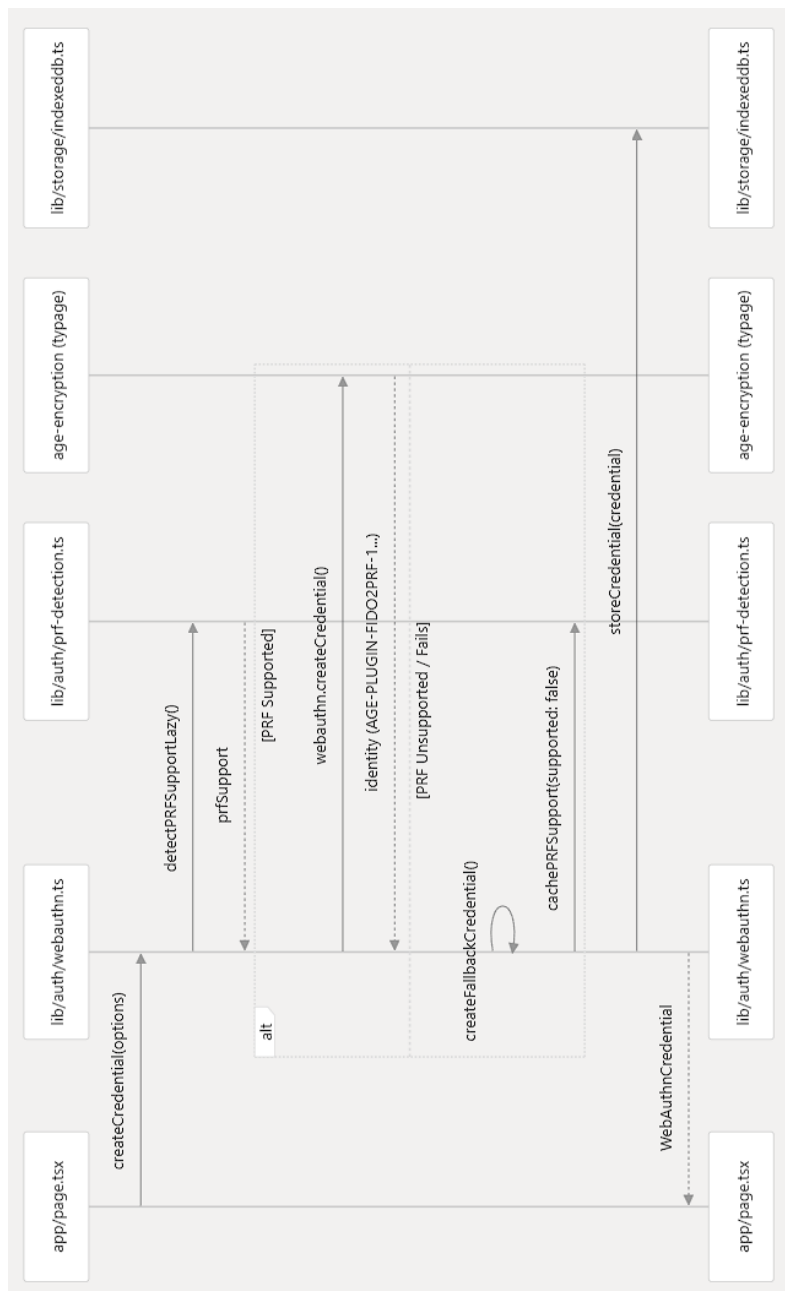
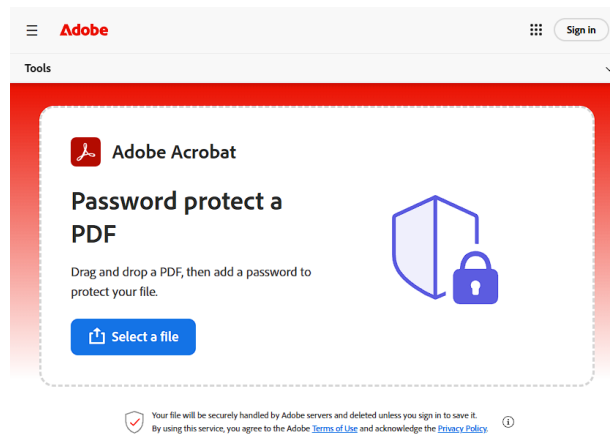
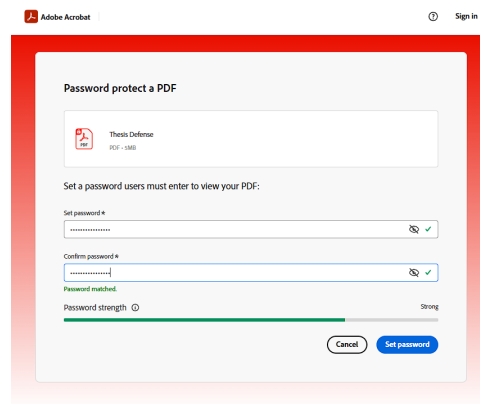


Figure E.4: Sequence diagram showing the steps performed across the user, browser, authenticator, and relying party during WebAuthn PRF passkey credential creation and the subsequent derivation of the file encryption key.

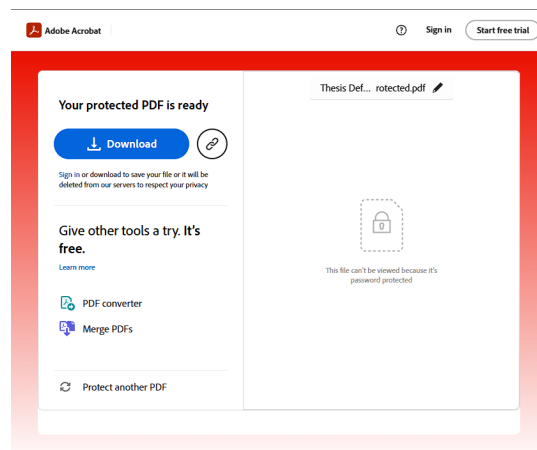
E.5 Adobe Acrobat Comparison Condition



(a)



(b)



(c)

Figure E.5: The Adobe Acrobat online password-protection flow used as the password-based comparison condition: (a) the landing page for selecting a file, (b) setting and confirming the password, and (c) the completed protected PDF ready for download.

System Artifact and Source Code

This appendix provides information for accessing the open-source artifacts and the live deployment of the passwordless document encryption system developed during this research.

F.1 Code Base Repository

The complete source code for the passwordless document encryption system (DocProtect) is available as an open-source project. The repository includes the TypeScript-based web application, WebAuthn PRF integration, age encryption pipeline using typage, OpenTDF-style manifest implementation, and accompanying documentation.

- **Repository:** <https://github.com/iteuscher/doc-protect>

F.2 Working Website and Access Instructions

A working deployment of the passwordless document encryption system is publicly accessible at the URL below. The website may be used to encrypt, decrypt, and share documents using passkeys directly from a standard web browser. No installation is required; only a modern browser with WebAuthn PRF support and a compatible authenticator (platform authenticator such as Windows Hello or Apple Touch ID, or a roaming authenticator such as a YubiKey) are needed.

- **Website:** <https://doc-protect.vercel.app>

Access Instructions

1. Navigate to <https://doc-protect.vercel.app> in a modern web browser (e.g., Chrome, Safari, Edge, or Firefox) that supports the WebAuthn PRF extension.
2. Upload a document to be encrypted using the file upload control on the home page.
3. When prompted, create a passkey using your device's available authenticator (e.g., fingerprint, facial recognition, PIN, or hardware security key).

4. Add one or more recipients by entering their email addresses. The recipient must also have created a passkey to be able to decrypt the file.
5. Download the encrypted file (with the .rico extension) and share it with the intended recipients through your preferred file transfer or email channel.
6. To decrypt a file, return to the website, upload the encrypted file, and authenticate with the passkey that was used to encrypt the file (or, if you are a designated recipient, with your own passkey).